Security Governance - Notes

IMPORTANT WARNING

- These notes have been made starting from my notes taken during lessons and the power points published by the professor, then rearranged through the help of Claude to produce a narrative flow.
- All the content belongs to the Professor of the course.
- While I try to ensure everything is inside these notes, please don't use them as a "source of truth", and study from official sources as well.

CHAPTER 1: Introduction

The Enterprise as a Complex System

Every organization exists to fulfil a **mission**, that is, the fundamental business objective that justifies its existence and defines what it delivers to the world. An energy provider exists to produce and sell energy to its customers; a manufacturer exists to produce and distribute goods; a bank exists to safeguard and move money. This mission is the anchor from which every other organizational choice descends, because once the objective is fixed, the enterprise must structure itself in a way that allows that objective to be reached reliably and repeatably.

From the outside, an enterprise can be understood as a kind of black box: it consumes inputs and produces goods or services that are offered to customers. Inside that black box, however, sits a highly structured machine composed of three interlocking ingredients. The first ingredient is **people** — the employees whose work actually moves the organization toward its objective. The second is **processes** — the structured sequences of activity through which work is carried out, formalized under the discipline of Business Process Management (BPM), in which people and technology transform inputs into outputs. The third is the **digital infrastructure** — the technological substrate of servers, networks, applications and data on which the people rely to perform their processes. The way these three are arranged depends heavily on scale: a small company tends to have a flat structure with few intermediaries, whereas a large enterprise develops a deep hierarchy with many layers of coordination.

This composition is precisely what makes the enterprise a **complex system**, and it is also the source of its first and most persistent vulnerability. Because the digital infrastructure is operated by human beings, the point of contact between people and technology becomes the weakest link in the whole arrangement. Managing the security of even a small company is therefore never a trivial task, and the difficulty grows sharply with organizational size and complexity.

The Concept of Governance

Among the many processes an enterprise runs, this treatment concentrates on **governance**. Governance, in its broadest sense, is the totality of the processes of governing — whether these are undertaken by a government, a market, or a network, and whether they act over a family, a tribe, a formal or informal organization, a territory, or across territories. Governance operates through the laws, norms, power, and language of an organized society. Expressed in operational terms, governance is the set of processes of interaction and decision-making among the actors involved in a collective problem, and these processes lead to the creation, reinforcement, or reproduction of social norms and institutions.

Two words distill the essence of this definition and should be held firmly in mind: **processes** and **norms**. To govern is to look at the business objective and to put in place everything necessary to reach it, which means identifying the processes required and then operating those processes so that the objective is achieved *in compliance with the surrounding environment.* Doing governance therefore always carries a double burden. It is not enough to design processes from a purely functional point of view, asking only whether they work; one must simultaneously keep the **compliance** dimension in view, ensuring that the processes respect the applicable norms. Those norms may be external laws, internal company rules, contractual obligations, or regulatory prescriptions. Governance without compliance is incomplete governance.

Enterprise, Corporate, and Business Governance

The most general form of this discipline is **enterprise governance**, which concerns how to govern the company as a whole. Formally, enterprise governance is the structure and the set of relationships that control, direct, or regulate the performance of an enterprise together with its projects, portfolios, infrastructure, and processes. In other words, it is the exercise of identifying the processes necessary to control the company itself. Enterprise governance is conventionally split into two complementary halves.

The first half is **corporate governance**, understood as the system of rules, practices, and processes by which a firm is directed and controlled. Corporate governance is essentially concerned with **compliance processes**: it is a general, mission-independent approach that guarantees the firm is being run in a controlled and accountable way, and it applies to any company regardless of what that company actually produces.

The second half is **business governance**, understood as the set of policies and business processes that determine the way the organization's business is actually run. Business governance is concerned with **performance processes**, and unlike corporate governance it is highly specific to the mission. Where corporate governance asks whether the firm is being directed and controlled properly in a generic sense, business governance asks whether the firm is performing well against its particular objective. The two are therefore distinguished cleanly: corporate governance is general and compliance-oriented, business governance is specific and performance-oriented.

The Hierarchical Structure and the Direct/Control Loop

An enterprise is typically organized as a **pyramid**. At the apex sit a small number of people who make broad, high-consequence decisions; those decisions then propagate downward through the structure, becoming progressively more concrete at each descent. This vertical arrangement gives rise to three well-known management levels, and the mechanics of corporate governance can be read directly off them.

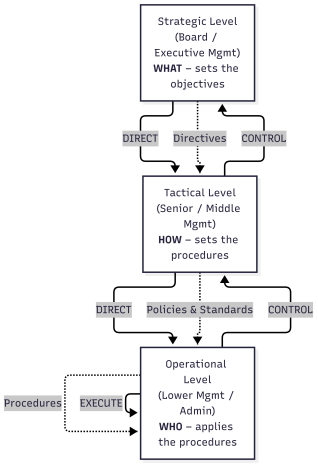
At the **strategic level** — populated by the Board of Directors and executive management — decisions about cybersecurity are taken at their most abstract. Directors formalize these decisions into **Directives**, documents that state the strategic objectives of the company. A directive at this altitude might declare that the infrastructure must be protected from external attackers, but it deliberately refrains from specifying *how* this is to be accomplished. The strategic level owns the **WHAT**: it sets the objectives.

At the **tactical level** — populated by senior and middle management — the mandate received from above is translated into more concrete objectives. Here the discussion turns to *how things should be done*, and the abstract goal begins to acquire shape. It is at this layer that one starts to identify the procedures needed to protect the assets, defining the **policies** and the **company standards** that will govern behaviour. These standards are not necessarily imposed from outside by bodies such as ISO; they are frequently the internal standards the company chooses to adopt for itself. The tactical level remains a

meta layer, in the sense that it defines the way things must be done without yet touching the machines. The tactical level owns the **HOW**: it sets the procedures.

At the **operational level** — populated by lower management and administration — the middle-level objectives are finally converted into practical reality. Here the abstract instruction to deploy, say, an identity management system becomes a concrete decision about who does exactly what, on which machine, with which configuration. This is the layer in which people put their hands on the systems. The operational level owns the **WHO**: it applies the procedures, and it is where things are actually done.

These three levels are bound together by a continuous loop composed of three motions. **Direct** is the downward flow: it translates big, abstract objectives into concrete implementation procedures as they descend from strategic to tactical to operational. **Execute** is the practical act of doing the work at the operational level. **Control** is the upward flow: it observes whether what is being done actually works as expected, and it feeds the resulting information back up to management. When the feedback arrives at the top, management obtains a snapshot of the real situation — an understanding of how the company is genuinely behaving — and on the basis of that snapshot it can decide to hold course or to change direction, re-drafting the objectives as needed. The following diagram captures this continuous circulation.



The single most important idea to extract from this picture is that **talking about governance means talking about the implementation of a continuous loop**. Governance is not a one-off act of decision but a perpetual cycle of directing, executing, controlling, and re-directing.

Vulnerabilities as the Enemies of Governance

Once this loop is running inside a real company, it must contend with **vulnerabilities**, which are the natural enemies of the governance process. Vulnerabilities arise for two broad reasons. The first is that the technical infrastructure itself changes over time and inevitably contains bugs, errors, and even backdoors. The second, and more insidious, is the interaction between the processes and the infrastructure — and, above all, the interaction between *people* and the infrastructure. It bears repeating as a central lesson that the most dangerous moment in the whole governance enterprise is the moment at which people come into contact with the systems.

Risk as the Governing Metric

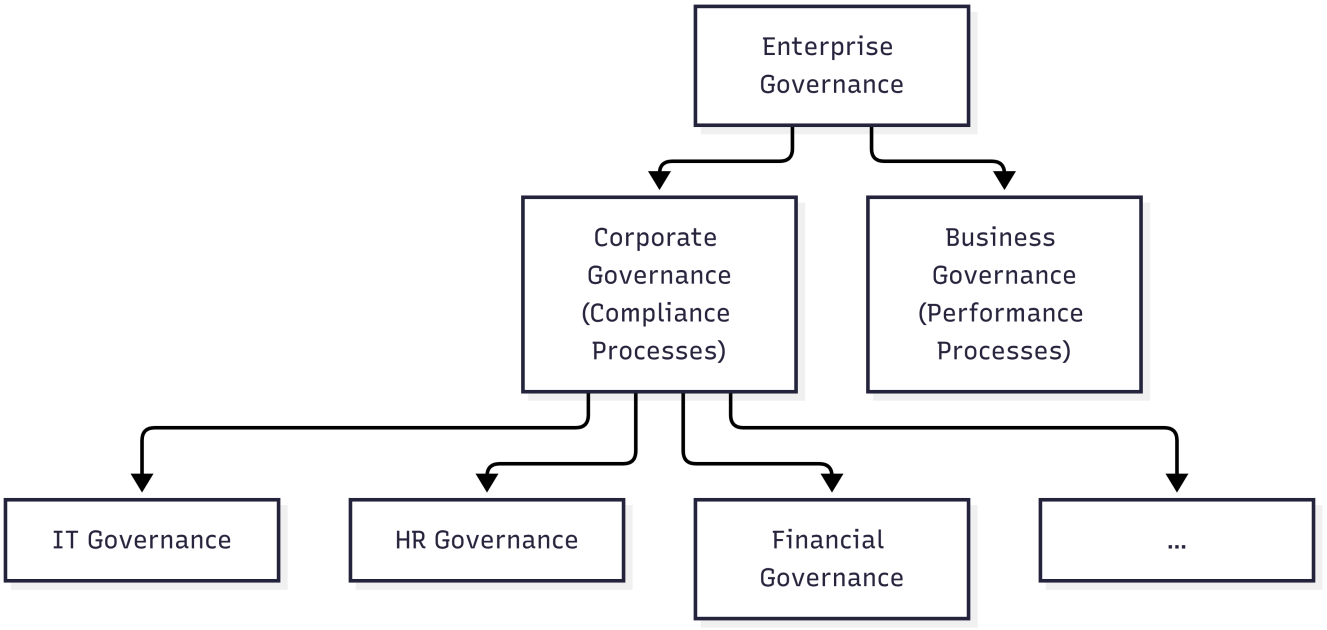
If the direct/control loop is to be steered intelligently, it must be steered against a measurable quantity. That quantity is **risk**, which may take financial, production-related, cybersecurity, or other forms. The IT Governance Institute captured this centrality when it redefined enterprise governance as the set of responsibilities and practices exercised by the board and executive management with the aim of providing

strategic direction, ensuring objectives are achieved, ascertaining that risks are managed appropriately, and verifying that the enterprise's resources are used responsibly.

Once risk is accepted as the governing metric, the entire governance problem collapses into a clean **optimization process**. The direct half of the loop is charged with a single objective: reduce risk, by putting in place actions that lower the risk level. The control half of the loop is charged with the complementary objective: measure the reduction, by taking measurements, recomputing the risk, and aggregating it into a coherent picture. Governance thus becomes the continual minimization of risk under observation.

Decomposing Governance: IT Governance and Assets

Supporting business and corporate governance in practice requires more specialized sub-governances, each dedicated to a particular domain of the enterprise. Enterprise governance decomposes into corporate governance and business governance at the top, and beneath these sit the domain-specific governance sub-systems: **IT governance**, **HR governance**, **financial governance**, and others. The following diagram shows this decomposition.



IT governance is defined as the set of processes that ensure the effective and efficient use of IT in enabling an organization to achieve its goals. It begins from the infrastructures and examines every kind of risk that arises from the digital environment, and especially the risks that arise from the *offering of services*. IT-based systems create serious risks precisely because they manage and store the majority — if not the entirety — of a company's electronic assets: the data and information stored inside the organization, the data and information transmitted across its networks, and all the systems and applications required to store, transmit, and process that data. These electronic assets are exposed to a wide range of threats aimed at compromising their three cardinal properties, **Confidentiality, Integrity, and Availability**, collectively abbreviated as **CIA**.

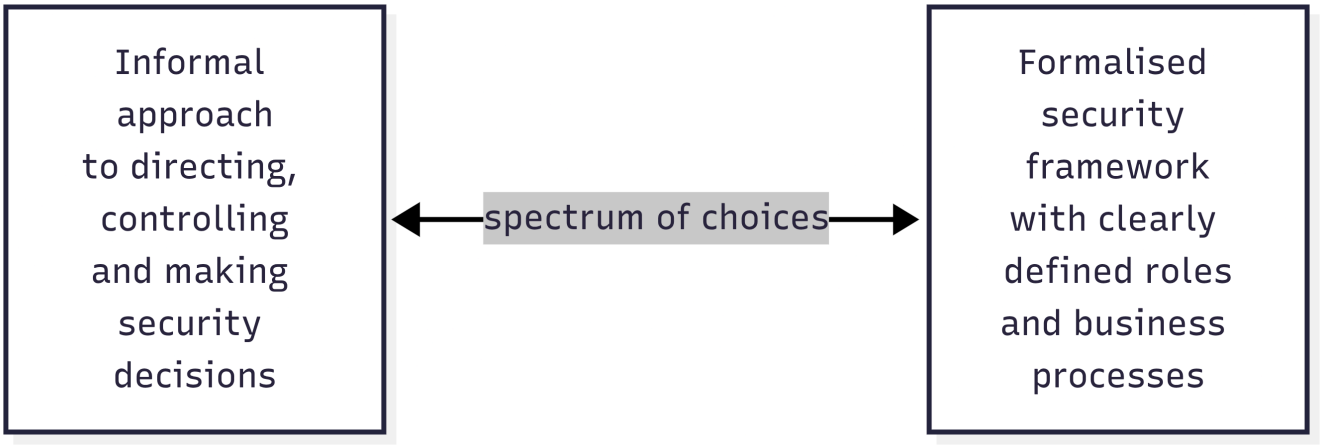
The decisive insight of IT governance is that the infrastructural view must be fused with the business view, because the two views assign radically different importance to physically identical machines. Consider a network of interconnected servers. On one server sits an archive of data; on another, identical machine sits the web server that hosts the company's online shopping site. Viewed through the infrastructure lens alone, the two servers look equivalent — both are connected, both are running, both are simply nodes in the topology. The moment the business lens is applied, the equivalence collapses. If an attacker brings down the shopping site, the company can no longer serve its customers and

immediately begins to lose money, which is a serious risk. If an attacker damages the archive, the data can very often be restored from other sources, which is a comparatively minor risk. The two machines are the same; the risk they carry is not. This is why IT governance insists on considering *all* aspects of the digital world — not merely the machines, but everything operating around them — and on first identifying which assets genuinely matter. Running a live service is an asset in the critical sense; the archive, in this example, is not an asset of the same order.

The threat landscape, moreover, is not confined to the outside. One must protect against external attackers arriving from the Internet, but one must equally guard against attackers already *inside* the organization. Employees who have become unhappy are a particularly grave danger: they know the assets intimately, they understand how the infrastructure is managed, and this superior knowledge makes them far more dangerous than an outsider who must first discover what an insider already knows.

Choosing an Approach: The Spectrum of Formalization

Having established that governance is a risk-driven control loop operating over identified assets, the practical question becomes how to implement that loop in a concrete company. There is no single universal answer — there is **no "one size fits all" approach** to security governance. Instead there is a spectrum. At one extreme lies a fully **formalized security framework**, with clearly defined roles and rigorously defined business processes. At the opposite extreme lies an **informal approach** to directing, controlling, and making security decisions. Every real company must find its proper place somewhere along this continuum.

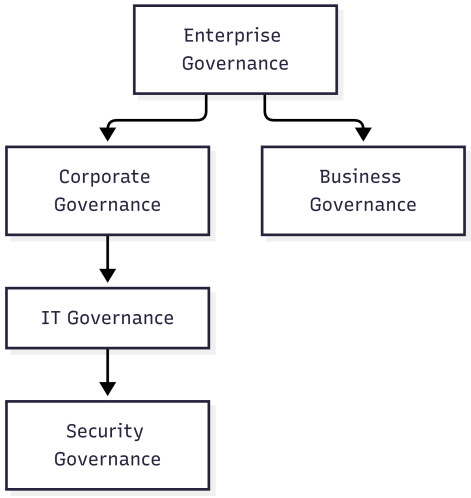


Four questions guide a company toward the right level of formalization. The first concerns **size and complexity**: how large and how complex is the organization? Small companies must lean on flexibility because they typically lack the resources for heavy formalism, while large companies will most probably require a formalized security framework simply to keep coordination tractable. The second concerns **resources**: what budget is actually available for security governance? A formalized approach is expensive — it demands certifications and sustained investment — so a company without money cannot realistically adopt it. The third concerns **mission and the importance of security to it**: what does the organization do, and how important is security to those aims? For a bank, security is a top priority and a matter of existential dependence; for a manufacturer, security still matters but the business does not hang on the same human-facing service dependencies. The fourth concerns **external considerations**: are there contractual, legal, regulatory, or sector-specific requirements pushing the company toward a particular level of formalism? A small company might in itself prefer an informal posture, yet find itself obliged to obtain certification because it works for a public organization that demands it.

Answering these questions well requires analysing the **context**, and in practical terms the correct approach comes down to identifying three things. One must identify the **what**, meaning the security decisions to be made. One must identify the **who**, meaning the deciders who will make them. And one must identify the **data**, meaning the information required to make sensible and informed choices. These three together — decisions, deciders, and the information feeding them — constitute what is meant by a **security framework**.

Positioning and Purpose of Security Governance

Security governance can now be located precisely within the larger structure. It is the means by which an organization controls and directs its approach to security, and when it is done well it coordinates all of the organization's security activities and enables the flow of security information and security decisions throughout the organization. Structurally, security governance is a **vertical** concern that cuts across the other governances: it sits within IT governance, which sits within corporate governance, which — alongside business governance — sits within enterprise governance. The nesting looks as follows.



The reasons to care about security governance follow directly from this position. It provides a structured approach to managing and mitigating cybersecurity risks within the organization. It helps protect sensitive data, maintain regulatory compliance, and strengthen the trust and confidence of stakeholders. And by implementing effective security governance, an organization reduces both the likelihood and the impact of security incidents, thereby safeguarding its reputation and its business operations.

This defines the arc of the entire subject. The study of security governance will proceed through models for information security governance and the vertical nature of security; through cybersecurity best practices, guidelines, and frameworks and how to use them; through the assessment and management of risk, which entails understanding threats, vulnerabilities, and attacks, evaluating their impact, and finding proper countermeasures; through the modelling and understanding of threats; through the management of incidents; and finally through legislation, compliance, and insurance, closing on open research issues in security governance.

A Model for Information Security Governance

Recap: What Information Security Governance Is

Before assembling the full model, it is worth restating the object of study with precision. **Information Security Governance (ISG)** is the process of establishing and maintaining a framework, together with the supporting management structure and processes, that provides assurance of several things at once: that information security strategies are aligned with and support the business objectives; that they are

consistent with applicable laws and regulations through adherence to policies and internal controls; and that responsibility is properly assigned throughout the organization — all of this undertaken in an effort to manage risk. Said more plainly, ISG is the global effort a company makes to ensure the well-being of its electronic resources.

The Principle of Cost-Effectiveness

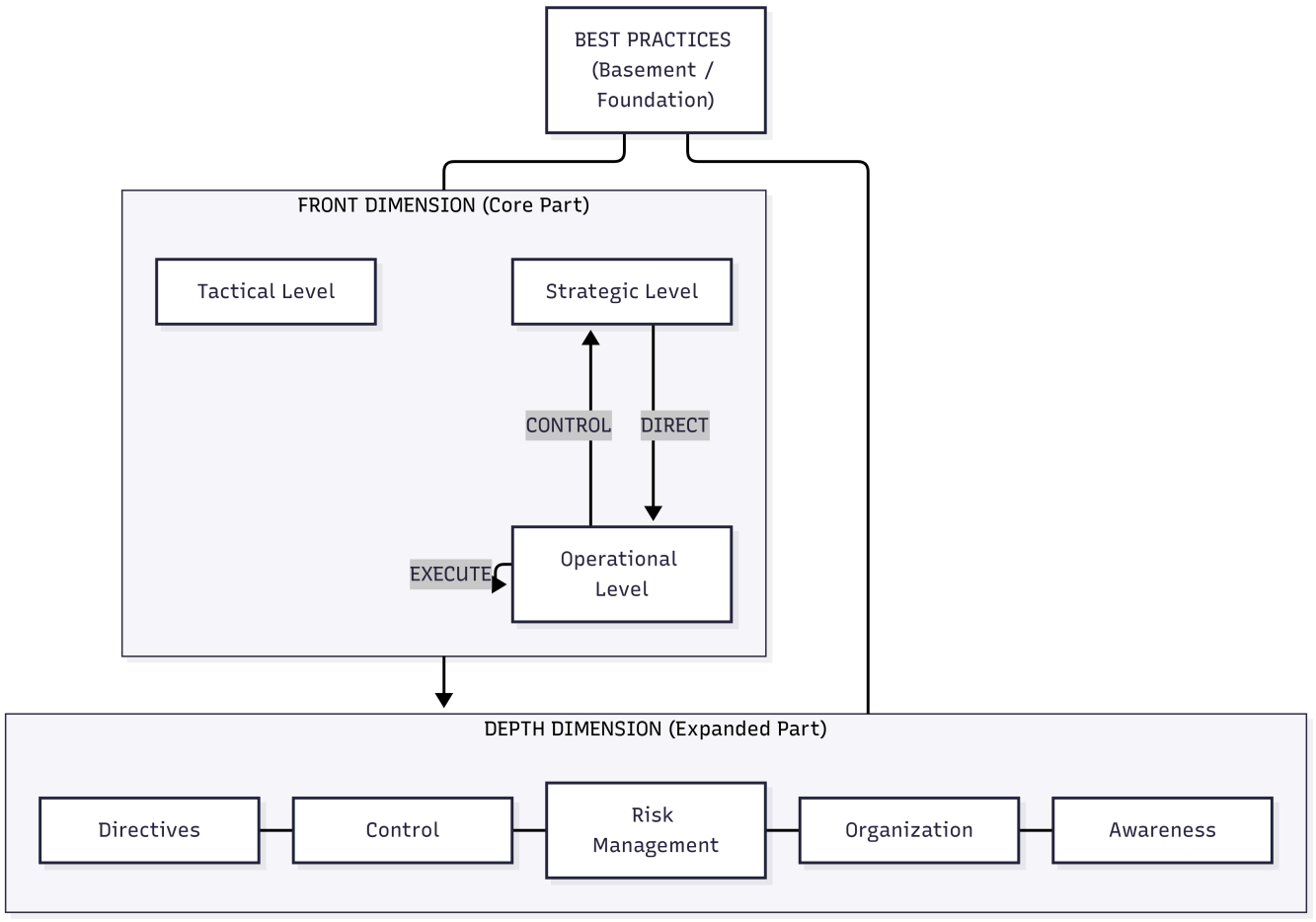
The first foundational principle on which any ISG framework must be built is that it has to be **cost-effective**. Security is expensive, and there must therefore be a deliberate balance between the cost of protecting electronic resources and the risk to which those resources are exposed. This balance has two failure modes, each equally to be avoided. **Overprotection** wastes money on defences whose cost exceeds the harm they prevent, generating unnecessary expense. **Underprotection** leaves genuine exposures unaddressed, allowing risks to materialize and strike the company. Good governance lives in the narrow band between these two errors.

The practical force of this principle becomes visible the moment one imagines the two possible worlds. Suppose a risk assessment has been carried out and has produced a list of risks, each tagged with an associated security level. In an idealized world with no budget limit, one could simply march down the list and remediate every risk one by one until none remained. Real organizations do not live in that world: they operate under a **fixed budget** and must decide where that budget goes, starting from the most critical risks and working downward. A characteristic situation then arises in which most of the budget has been consumed fixing the critical problems, and a residual amount remains. At this juncture the decision must be made carefully, weighing the cost of fixing a given remaining risk against the cost that would be incurred if that risk actually materialized — neither overspending on marginal exposures nor abandoning issues that quietly matter. Even the act of *identifying* a risk depends on acquiring and analysing data with the right instruments; if the proper instruments are not used, important points may simply be missed, and the balance will be struck on incomplete information. For all these reasons, a good **IT risk management strategy** is mandatory as the precondition for a good ISG strategy, and good governance as a whole demands a strategy that weighs multiple aspects rather than fixating on the infrastructure alone.

The Von Solms Model: Overview

The model used to organize all of these elements was introduced by **R. Von Solms in 2006**. It can be pictured as a solid three-dimensional wedge whose purpose is to gather every element one must keep in mind and to arrange those elements in an interconnected structure. The wedge has three distinguishable parts, and understanding the model means understanding what each part contributes.

The **Front Dimension**, also called the **Core Part**, is the triangular face of the wedge. It is the implementation of the control loop already studied, spanning the three management layers of the pyramid. The **Depth Dimension**, also called the **Expanded Part**, is the set of five layers extending backward from that front face: **Directives**, **Control**, **Risk Management**, **Organization**, and **Awareness**. Finally, the **basement** on which the whole wedge rests is the **Best Practices** layer, the foundation from which everything else is constructed. Best practices are the documents that collect the common, accumulated knowledge of the field in terms of cybersecurity and management. The overall structure is shown below.



The Front Dimension (Core Part)

The Front Dimension represents the execution of processes and actions and the influence of the Direct and Control loop upon those processes. It rests on two core principles.

Core Principle 1 states that the model covers the three well-known levels of management — strategic, tactical, and operational. This principle answers the question of *why all three levels must be covered by the governance process*: every level possesses its own distinct view of the company, and no single level can see the whole. At the top, a handful of people take general decisions and, when the direct process begins, they possess only ideas about what to do; the directive documents they eventually write are therefore quite general. At the bottom, people are in direct contact with the system, laying their hands on machines and producing procedures, and their scope is extremely detailed and correspondingly restricted. Because each person's view is limited in this way, the intermediate tactical layer is indispensable: its whole function is to translate the general into the detailed on the way down, and, on the way up, to translate the detailed back into the general. This is why the processes must be able to flow *vertically* in both directions. On the control path, the operational level begins by collecting information of great precision — numbers of alerts, flows across different machines, and similar indicators — and this precise information is progressively correlated with the procedures and abstracted as it climbs, so that the movement upward is a movement from a very detailed view toward an increasingly summarized one.

Core Principle 2 states that across these three levels there are three very distinct *actions*, and that control at the bottom is emphatically not the same activity as control at the top. The rationale is easy to appreciate from the Board's perspective: the Board is not interested in learning that 321 virus attacks occurred last week, that 27 software patches were applied, and that 7 anti-virus updates took place — this is far too much detail to plan with. What the Board wants to know is whether the company's access to the Internet causes any *unmitigated* risks to the company. If there are none, the Board is content; if

there are some, the Board wants to be told precisely which unmitigated risks these are. The action of control must therefore be qualitatively different at each altitude.

The Direct Part, Layer by Layer

The downward Direct process can be read as a matrix in which each management layer has a distinct meaning, a specific input, and a specific output, and in which the output of one layer becomes the input of the next.

At the **strategic level**, to direct means to **identify the assets, their relevance, and their required level of protection** — appropriate here because the strategic level alone possesses the overview of the whole company and can therefore say what must be protected and to what extent. Its **input** is the **context**, split into internal and external factors. The internal factors concern the company's own world: its strategic vision, the role of IT, its competitiveness, its mission, its constraints, and its production processes. The external factors concern the surrounding world: legal and regulatory prescriptions and other external risks. Its **output** is a set of **Directives** indicating, at a high level, what the Board expects to be done as far as the protection of the company's information assets is concerned.

At the **tactical level**, the directives received from above are *expanded* into sets of relevant information security **policies, company standards, and procedures**. Here the macro-objective is analysed against the situation and translated into middle-level objectives. The **input** is the set of directives produced above, and the **output** is the collection of policies, procedures, and standards with which the company must comply — the way digital resources are managed, the way accounts are handled, and so on.

At the **operational level**, the inputs are expanded further into sets of **administrative guidelines and administrative procedures**, and the technical measures are physically implemented and managed. The **output** is the set of **operating procedures** specifying exactly how things must be done, and this output forms the very basis of execution on the lowest level.

The Control Part, Layer by Layer

The upward Control process is governed by a single, decisive maxim: **you can only manage what you can measure**. To control properly one must measure; to measure one must know in advance which information and data to collect. This *measurability* characteristic cannot be an afterthought — it must sit at the centre of all directives, policies, standards, and procedures produced during the Direct part of the model, so that the objects being directed are constructed to be measurable in the first place. The Control matrix mirrors the Direct matrix but runs in the opposite direction, from operational up to strategic.

At the **operational level**, to control means that **measurement data is extracted from a wide range of entities**, either automatically or manually. Concretely, this means deploying monitors — **agents** — into the environment to collect and extract data. These agents may live on the machines themselves or in the network, and their power depends on their observation range. Here a fundamental tension must be respected: **the need for monitoring must not compete with the needs of the business**. Observing everything by placing agents everywhere is expensive and degrades the system's speed; when one interferes with the system to monitor it, one cannot do too much, or the system will suffer. The guiding rule is that the need for protection must exist and survive alongside the need of the business, without smothering it. The **input** at this level is the raw **measurements**, and the **output** is a set of **specialized reports** created on this level from the extracted operational data, which is then passed upward to the tactical level.

At the **tactical level**, control means **measurement and monitoring against the requirements of the relevant policies, procedures, and standards**. The tactical layer receives all the operational reports, aggregates them together, and attempts to identify existing threats, evaluating whether the policies in force are sufficient. Its **output** is a set of **tactical management reports** indicating the levels of compliance and conformance, which are then encapsulated and passed to the strategic level.

At the **strategic level**, control culminates in **Situational Awareness**. The **output** at this apex consists of **reports reflecting compliance and conformance to the relevant directives, including risk considerations** — the very snapshot the Board needs in order to decide whether to hold course or re-direct.

The Basement: Best Practices

Underneath both the Front and the Depth dimensions lies the layer of **best practices**, which sets the ground on which all operations are instantiated. Best practices are documents collecting the knowledge that people have acquired over the years in terms of security and management. The specific best practice one reaches for depends on the specific problem to be solved, and the required granularity depends on the management level being served.

The purpose of the whole ISG model, phrased memorably, is to help the organization in *"doing the right things right."* This slogan resolves into two questions that every **Information Security Manager (ISM)** must be able to answer. First: *how do I know what the right things are?* Second, supposing that is known: *how do I know I am doing them right?* The answer to both is: look to best practices. Formally, best practices — also called standards or guidelines — are a set of documents reporting the experiences and solutions arrived at by experts in information security management. They can be understood as the consensus of experts in the field, and they provide an internationally accepted framework usable as a building block for ISG. Many of them exist, each focused on related but different aspects, including the **ISO 27000 family**, **COBIT**, the **NIST SP 800-*** series, the **CSC** (Critical Security Controls), and the **NIST CSF** (Cybersecurity Framework), among others.

ISO 27002

Among these best practices, **ISO 27002** deserves close attention because companies use it to set up their infrastructures from the policy point of view. It is an International Standard designed to be used by organizations that intend to do any of three things: to select controls within the process of implementing an Information Security Management System (ISMS) based on ISO/IEC 27001; to implement commonly accepted information security controls; or to develop their own information security management guidelines.

ISO 27002 is fundamentally a collection of **controls** — points that need to be verified. In its 2013 edition it contains **14 security control clauses**, which collectively hold a total of **35 main security categories** and **114 controls**. (These controls are general security controls and are not themselves objects of certification; they function as instructions rather than as a pass/fail certificate.) The structure is strictly hierarchical: each clause that defines security controls contains one or more main security categories, and each main category in turn contains two things — first, a **control objective** stating what needs to be achieved, and second, one or more **controls** that can be applied to achieve that objective.

The description of each individual control is itself standardized into a fixed structure of three parts. The first part is the **Control** proper, which defines the specific control statement needed to satisfy the control objective. The second part is the **Implementation Guidance**, a longer text that provides more detailed

information to support the implementation of the control and the meeting of its objective; this guidance carries an explicit caveat, namely that it may not be entirely suitable or sufficient in every situation and may not fulfil an organization's specific control requirements. The third part is **Other Information**, which provides further considerations such as legal factors and references to other standards, and which is simply omitted when there is nothing further to say. In this way a control functions as a security checklist item that matches the requirements for certification, accompanied by a guideline explaining one possible way to implement something compliant with the check.

ISO 27001 and the Distinction Between the Two Standards

ISO 27001 is the companion International Standard that specifies the requirements for establishing, implementing, maintaining, and continually improving an ISMS within the context of the organization. It also includes requirements for the assessment and treatment of information security risks tailored to the organization's needs, and it is deliberately generic, intended to be applicable to all organizations regardless of type, size, or nature. Crucially, ISO 27001 is the standard that grants **certification**: it certifies that a system is compliant with its requirements, and it operates as a checklist of security checks that a company must satisfy to be formally certified.

The relationship between the two standards is best understood as a division of labour, and the difference between them is the difference between a requirement and a guideline. **ISO 27001** is very specific and strict; it spells out in detail what a company must comply with and must have in place in order to be formally certified. **ISO 27002**, by contrast, is a *guideline* document. It advises companies on what they should have in place as far as their information security management is concerned in order to follow best practice, guiding a company to structure its information security management according to the accumulated experience of other companies. It is deliberately rather high-level and does not drill down into very detailed specifics. The compact way to remember the pairing is that **27001 certifies and is strict, while 27002 guides and is advisory**.

The Directive and the Information Security Policy Architecture (ISPA)

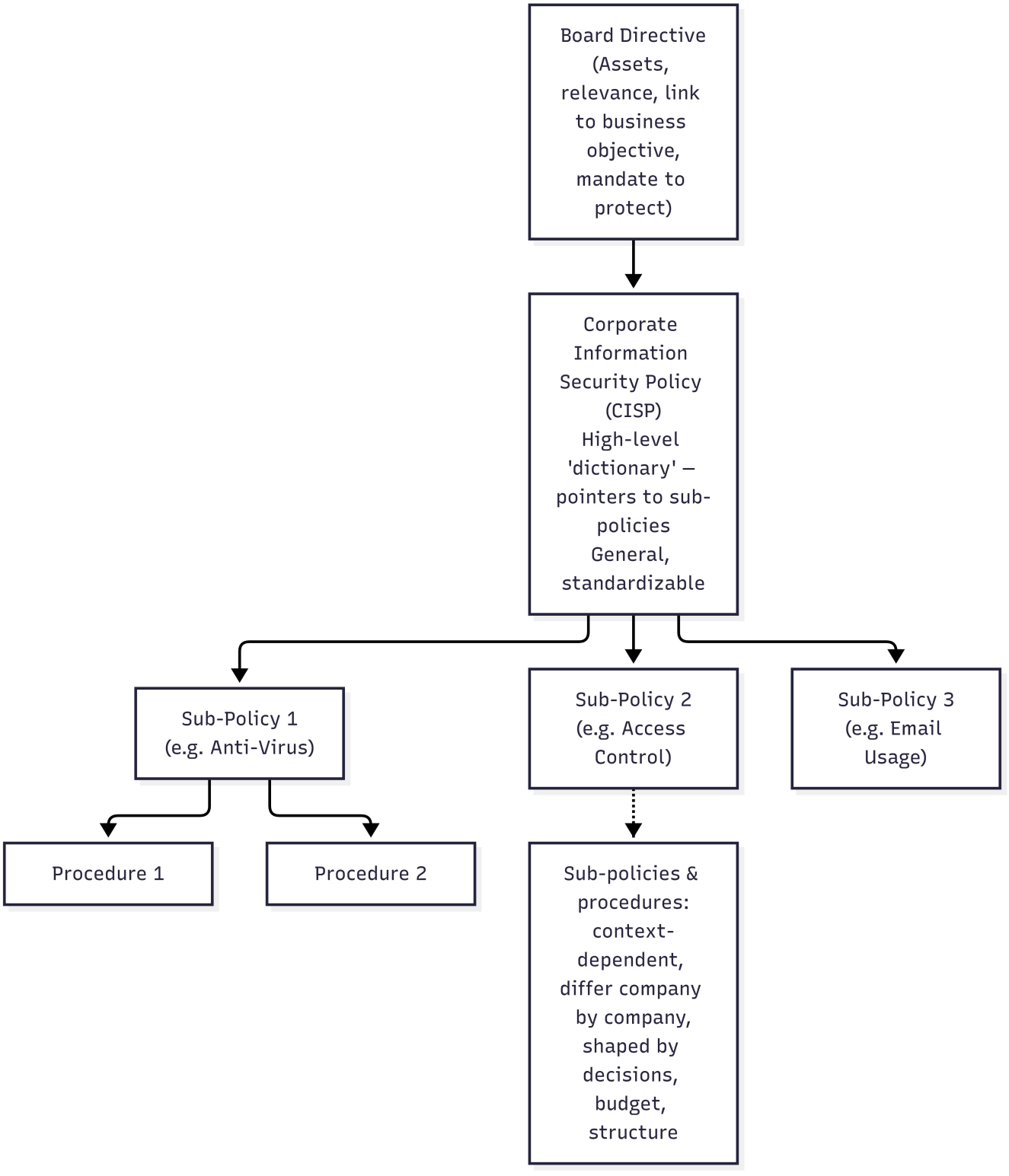
Why a Documented Direct Process Is Needed

Every best practice contains, in some form, the notion of a **Directive**, and the task it imposes is concrete: to set up the documents and policies that dictate how security is to be governed inside a company. Chapter 5 of ISO 27002, for instance, requires that decisions be taken and acted upon in a *structured* way, which in effect demands the design of a process that supports all three management layers. To meet that demand, an organization must develop a **framework** — a methodological instrument, a defined set of things that must be done — capable of supporting the Direct process. This framework is not a single document but an interconnected architecture of documents, each linked to the others, which together implement the guidelines of the downward direct flow.

The reason everything must be written down is that documentation is what confers **trust and value**. By formalizing rules and policies on paper, the organization gives weight and accountability to what it does; an undocumented intention carries no assurance, whereas a documented one can be communicated, enforced, audited, and relied upon. Because the Direct process flows from top to bottom, and because each layer operates at a different degree of abstraction, the architecture must provide a set of documents calibrated to the right level of information at each layer. A general document is produced at the top and is connected downward to progressively more specific documents produced in the layers beneath it.

The Document Tree

The architecture of the Direct process is best visualized as a **tree**. At the root sits the **Board Directive**. One level below sits the **Corporate Information Security Policy (CISP)**, which receives the directives from the board and transforms them into guidelines for the implementation of security controls. From the CISP, a set of **sub-policies** branches out, one for each distinct domain of concern — access control, human resource management, device management, and so on. From those sub-policies are derived the **company standards**, which express the minimum level of specification that must be achieved, and finally, at the operational layer, the **procedures**, which are protocols: ordered lists of concrete actions. The flow and its contents are shown below.



A crucial distinction runs through this tree. The **Board Directive** and the **CISP** are relatively **general and standardizable**, because almost every company shares essentially the same fundamental need for protection, and so the upper two documents can look broadly similar across organizations. The **sub-policies** and the **procedures**, by contrast, are strictly **context-dependent**: they vary from company to company and are shaped by the particular decisions the organization wishes to enforce, by its structure, and by the budget it has available.

The Board Directive

At the top of the tree, the Board Directive carries the raw material of the entire Direct process. It must contain two things above all: the **set of IT assets identified by the Board**, together with their relevance and their connection to the business objective, and the **mandate from the Board to protect those assets**. The inclusion of relevance is essential, because protection must proceed *asset by asset* — not every asset carries the same importance, and the directive must make those differences explicit so that protection effort can be allocated accordingly.

The Corporate Information Security Policy (CISP)

One level lower sits the CISP, the **high-level document that provides the basis for all lower-level documents related to information security**. Its function is to take the objective expressed in the Board Directive and translate it into a middle-layer objective, and from that translation it extends a set of pointers aimed at the specific sub-policy documents below. In this sense the CISP operates as a kind of **dictionary**: it allows the reader to interpret and map the sub-policies against the original board directive, binding the detailed and the general together.

The methodology offers a set of guidelines for writing a proper CISP, specifying both what it should contain and how it should be formalized. There are ten such guidelines.

First, the CISP must indicate **board and executive management support and commitment**, and it must be clear that the CISP flows from a higher-level directive; the link back to the Board Directive and the enforcement behind it must be visible. Second, it must be **accepted and signed by the CEO or an equivalent officer** — the signature of a board member is what gives the document its authority. Third, it **must not be a long document, nor written in technical form**: a maximum length of about four to five pages is appropriate, and it should contain high-level statements concerning information security rather than implementation detail. Fourth, it **should not change very often and must be stable** with respect to technical developments and changes; because it is an intermediate working document bridging the direction and the operational levels, frequent revision would destabilize everything hanging beneath it. Fifth, and as a direct consequence of the stability requirement, the CISP **must not contain any references to specific technologies and must be technology-neutral**, since technology evolves far too frequently to be enshrined in a stable document.

Sixth, the CISP must indicate **who owns the policy** and what the responsibilities of other relevant people are; stating roles and responsibilities is what creates a structure that links each action to a specific person, producing a map of who is supposed to do what and who is supposed to monitor it. Seventh, it must clearly indicate the **scope** of the policy — that is, all the people who will be subject to it. Eighth, it must refer to possible **disciplinary actions for non-conformance**, both to the CISP itself and to its lower-level constituent policies; these disincentives are necessary precisely because of the human factor, since people tend to look for an escape strategy when confronted with something difficult. Ninth, it must be **distributed as widely as possible** throughout the company and covered in all relevant awareness courses, so that employees understand both the policies and the reasons they exist. Tenth, it must contain a **Compliance Clause**, the element that ties the document directly into the Control process.

A representative CISP is organized into clearly named but deliberately general sections — the importance of information to the company, what information security is, why the company needs it, the information security commitment of the board, the scope, the information security statements that make up the policy, the responsibilities, and the compliance clause. The document is short, and its section titles are generic. Where it does become concrete is in the **scope**, which must define exactly who is affected by the policy: typically all of the company's IT assets stored, processed, and distributed via its information processing systems; any person granted authorization to access those resources, including permanent, temporary, third-party, and contractual employees and users; and all business partners and clients that access the company's IT assets in any way.

Sub-Policies

Descending one further level, the **sub-policies** take the mandate to protect the assets — already translated into macro-objectives by the CISP — and define specific policies for the specific aspects that must be considered. These documents are **company-dependent**: each organization must define them according to its own structure and circumstances. Nevertheless, certain categories of sub-policy apply to essentially everybody and are commonly defined by all organizations: a **Malicious Software Control Policy** (an anti-virus policy), an **Acceptable Internet Usage Policy**, an **Acceptable Email Usage Policy**, a **Logical Access Control Policy**, a **Disaster Recovery (Backup) Policy**, a **Remote Access Control Policy**, and a **Third Party Access Control Policy**.

One requirement overrides all others at this level and is marked as critically important: the ISPA must **clearly indicate where each of these different policies originates**. In concrete terms, every sub-policy must be *linked* or *traced back* to the CISP in some way, so that the chain of authority from the board directive down to the individual policy is never broken. A well-formed sub-policy therefore carries an explicit **Reference** section pointing *up* to the statements in the CISP that give it origin, and *down* to the lower-level procedure that supports it, along with a **Main Policy Statement** and its supporting sub-statements. For example, an Internet Acceptable Use sub-policy would state that use of the company's Internet service must be in support of official company work, that all user requests for connectivity must be approved and supported by the employee's line manager and made through a specified application procedure, and that it is the line manager's responsibility to ensure the user does not misuse the service.

Procedures

At the bottom of the tree lies the **operational level**, inhabited by the **procedures**, which are effectively **algorithmic steps**. Where a sub-policy declares what must be true, a procedure specifies the exact ordered actions that make it true. In the running example, a user requesting Internet connectivity within the company triggers an application procedure that states precisely what must be done: the applicant records identifying details, signs a declaration that they have read both the CISP and the relevant Internet Acceptable Use sub-policy and will act in line with them, and obtains the signatures of the line manager and the information security officer. A procedure of this kind must also **clearly state what it means to be compliant with it**, carrying its own compliance clause so that conformance can later be checked.

Once the full set of documents is in place — stating, from top to bottom, what the organization needs to do — the procedures are what get implemented in the **Execution** part of the model. Execution is simply the carrying-out of those procedures, and the role of the Control process that follows is to verify that everything is in fact working as the documents require.

The Control Part and Compliance

Compliance as the Scope of Control

Once the documents of the Direct process exist and the procedures have been executed, the model turns upward into the **Control** part, whose main scope is the **compliance check**. ISO 27002 makes this requirement explicit: after everything has been put in place, the organization must verify compliance at the various levels — compliance with external laws and contractual requirements, and compliance with the security policies and standards it has established internally. The standard devotes an entire clause to this, titled **Compliance**, with the objective of avoiding breaches of legal, statutory, regulatory, or contractual obligations related to information security and of any security requirements.

Two of its controls capture the essence of the task. The control on the **identification of applicable legislation and contractual requirements** demands that all relevant legislative, statutory, regulatory, and contractual requirements — and the organization's approach to meeting them — be explicitly identified, documented, and kept up to date for each information system and for the organization as a whole, with the specific controls and individual responsibilities also defined. The control on **compliance with security policies and standards** demands that managers regularly review the compliance of information processing and procedures within their area of responsibility against the appropriate security policies, standards, and other security requirements. ISO 27002 further requires that management initiate an **independent review**, carried out by individuals independent of the area under review — the internal audit function, an independent manager, or an external specialist — to ensure the continuing suitability, adequacy, and effectiveness of the organization's approach to managing information security; the results are recorded and reported back to the management that initiated the review, and if the approach is found inadequate, corrective actions must be considered.

The Measurability Problem

The central difficulty of the Control part is defining the **compliance criteria** — that is, deciding how to verify that the organization is in fact behaving correctly. This difficulty flows directly from the nature of the documents themselves. Policies, directives, and standards are written in **natural language**, and natural language is neither strict nor formalized; consequently it is genuinely hard to establish exactly what must be verified. The problem reduces to the governing maxim of the whole control process: **you can assess only what you can measure**. Things that cannot be measured cannot be controlled, so the organization must define measurements that make it possible to quantify how compliant it is. For this reason the compliance clauses, which encode these measurements, must provide a clear metric that can be evaluated and assessed.

Evaluating compliance is not equally hard at every level. At the **bottom** of the pyramid it is comparatively easy, because the operational layer deals in procedures and in concrete data drawn directly from the system, which can be monitored. If an access control policy declares that only authorized users may access a certain type of data, compliance can be checked simply by inspecting the system's logs. As one climbs **upward**, however, the criteria become far more general, and the natural question arises of what metric could possibly apply at those altitudes. The answer is the concept of **risk**. At the higher levels, verifying compliance means **assessing the risk that derives from non-compliance** with the policies and directives. The task, therefore, is to translate the technical data extracted from the environment into something that allows the risk level to be evaluated — to convert log entries and alert counts into a statement about exposure.

The Role of Time

In carrying out this exercise, **time plays a decisive and troublesome role**. Assessing risk is expensive in time for several compounding reasons. First, the necessary information is widely spread throughout the company and must be gathered from many places. Second, that data must then be analysed, which itself consumes time even when software is used to assist. Third, a conclusion must be derived from the analysis. Taken together, a full risk assessment can take **weeks or even months**. It cannot be performed daily; it is something that must be planned.

This temporal cost creates a structural tension with the domain itself. In cybersecurity, **weeks constitute a very large temporal frame** — the threat environment can change completely within such a window. Worse, the world is **dynamic**, so even if the organization manages to choose what seems like the right assessment interval, the context captured at the start of the assessment may no longer hold by the time the assessment concludes. Traditionally, compliance monitoring has been performed through periodic **ICT audit sessions**, in which ICT risks are evaluated, an audit report is produced, and its results are compared against the compliance clauses. The abiding issue with this approach is precisely timing: the world is dynamic, and monitoring ought ideally to be done in near real time, which the periodic-audit model struggles to deliver.

Guidelines for Writing Compliance Clauses

Unlike the Direct process, which comes equipped with templates and suggestions for writing the CISP and sub-policies, the Control process offers **no standardized content** for compliance clauses — specifying them is not an exact science, and very few guidelines are available. Only a small number of principles can be stated. A compliance clause must be **clear and precise**, deliberately avoiding the insertion of ambiguity; otherwise two people performing the same assessment against the same clause might reach different conclusions simply because the criteria were open to interpretation. A clause such as *"Employees must take Information Security seriously"* is a textbook failure, because the word *seriously* has no fixed meaning and cannot be assessed. Beyond clarity, a compliance clause should **express a way to measure the degree to which it is satisfied**, providing a usable metric rather than a vague aspiration.

Worked Example — A Clause for the Board Directive

Consider an extract from a Board Directive in which the board accepts the importance of the company's IT infrastructure to its strategic goals, recognizes the potential impact a compromise could have, and consequently demands a proper environment to protect the IT infrastructure against any disruptions or compromises, fully supporting a proper ISG environment. Here the **asset** is the IT infrastructure and the **protection need** is protection against compromises. Two candidate compliance clauses illustrate the difference between a weak and a strong formulation.

Option 1 states that the board requires proper feedback, every three months, of the level of compliance with the directive. Its merit is the presence of a clear **time window**. Its defect is that the phrase *level of compliance* is never defined anywhere — it is left ambiguous exactly what is to be assessed. **Option 2** states that the board requires detailed feedback, every three months, of any serious risks that may compromise the protection of the company's ICT infrastructure. This option retains the same time window but is markedly better, because it also clarifies the **metric**: the thing to be reported is *risk*. Option 2 is therefore the superior clause.

Worked Example — Clauses for the CISP

The second example concerns the CISP, which, as established, is a document articulated as a collection of statements that act as pointers to sub-policies. Because of this structure, it is preferable to attach a

compliance clause to **each statement** (or each category) rather than to the document as a whole. Taking Statement 6.1 — which declares that the company will have a proper information security organizational structure to manage information security, ensuring that security roles are assigned, that users are aware of the policy and of the disciplinary consequences of non-compliance, and that implementation is continuously coordinated and reviewed — two candidate clauses can again be compared.

Option 1 states that the effectiveness of the company's information security organizational structure in managing and enforcing the requirements of the ISPA shall be evaluated every six months, with the results incorporated into higher-level reporting. **Option 2** states that the way the information security function is organized, and the reporting structures within that function, shall be evaluated every twelve months to ensure the structure remains adequate to protect all the company's electronic assets, with the results forming part of the annual evaluation and reporting of organizational structures. Both options share the strength of a defined **time frame**. Option 1's weakness is that it does not specify *what* must be reported, so a change in the person writing the report would produce a different view each time. Option 2 improves on this because it refers to a document that is already expected to be produced annually and will therefore most probably be structured in a consistent way — yet it, too, leaves the **metric** unexpressed, failing to say explicitly what is to be measured. The honest conclusion is that **no option here is perfect**, but Option 2 is better than Option 1. The recurring lesson across both examples is that a good clause pins down both a time window and a measurable metric, and that most real clauses succeed on one dimension while remaining imperfect on the other.

Risk Management

Risk as the Element That Drives Control

From the control point of view, the single element that makes the control loop implementable is **risk**. Risk, however, is perceived differently at every layer of the hierarchy, and to deal with it coherently the organization needs a dedicated process for its analysis: **Risk Management**. This process must be **vertical**, assessing risk at every level, and the closer it operates to the bottom of the pyramid, the more tightly it is bound to the technological layer.

Formally, risk management is the process of identifying and assessing all potential risks, as well as introducing the controls that should mitigate those risks to acceptably low levels. It is one of the security processes required to identify the risks that may impact the well-being of an organization. Its defining spirit is to begin by looking for what might be dangerous, to establish to what extent it is dangerous, and then to seek possible solutions evaluated against a **cost–benefit principle** — the same cost-effectiveness discipline that governs the whole of ISG.

The Two Dimensions of Risk

Although there are several ways to perform the process, risk is generally understood through **two orthogonal dimensions**. The first is the **probability or frequency** — how likely it is that something bad will happen. The second is the **magnitude of gains or losses**, usually called the **impact** — how severe the consequence would be if it did happen. The aim of risk management is accordingly to determine two things: what the impact will be if the risk materializes, and how often the risk might materialize. These two dimensions combine into the canonical formula:

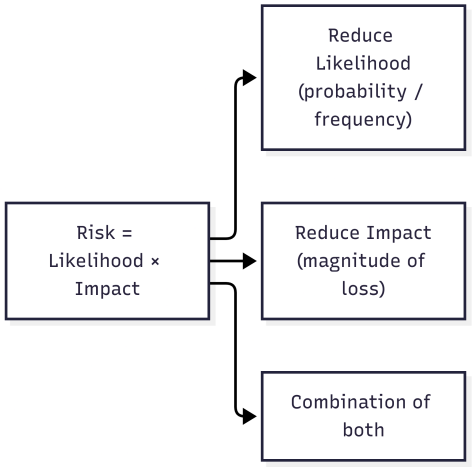
$$\text{Risk} = \text{Likelihood} \times \text{Impact} = (\text{Threat} \times \text{Probability}) \times \text{Impact}$$

The relationship is often displayed as a coloured matrix with likelihood on the vertical axis and impact on the horizontal axis, in which the combinations shade from green in the low–low corner, through amber in the middle band, to red where high likelihood meets high impact — a visual map that lets managers read off the severity of any risk at a glance from its coordinates.

The power of treating these dimensions as independent is best seen through examples. Suppose the incident of concern is the **loss of data**. One cause might be a **fire** destroying the data centre: with proper security protections in place the probability of this is quite low, yet should it occur it could destroy the centre completely, giving a very high impact. The result is a **critical risk even though the probability is low**. The same loss of data might instead arise from **ransomware**: here the probability is higher than that of fire, while the impact depends on the type of data affected and may well be smaller. This gives a risk that is again medium-to-high but with a smaller impact. Because the two scenarios occupy different regions of the likelihood–impact space, the appropriate **countermeasures differ** — the organization may choose to act one way against fire and an entirely different way against ransomware. Different models exist that decompose probability into more granular dominating factors, but in general the two governing quantities remain likelihood and impact.

How to Reduce Risk

The aim of the whole governance loop is to **reduce the level of risk**, and since risk is the product of likelihood and impact, there are exactly three levers available. One may **reduce the potential impact** of the risk; one may **reduce the probability or frequency** of the risk; or one may apply **a combination of both**. Which lever is pulled, and how hard, is itself a cost–benefit decision.



Risk Management, ISO 27002, and Governance

ISO 27002 treats IT risk analysis as an **essential part of best practice in IT**. It holds that an organization must identify its security requirements, and it names three main sources of such requirements. The first is the **assessment of risks** to the organization, taking into account its overall business strategy and objectives; through a risk assessment, threats to assets are identified, vulnerability and likelihood of occurrence are evaluated, and potential impact is estimated. The second is the body of **legal, statutory, regulatory, and contractual requirements** that the organization, its trading partners, contractors, and service providers must satisfy, together with their socio-cultural environment. The third is the organization's own set of **principles, objectives, and business requirements** for handling, processing, storing, communicating, and archiving information in support of its operations. The standard stresses that the resources spent implementing controls must be balanced against the business harm that would likely result in their absence — once again the cost-effectiveness balance — and it

points to ISO/IEC 27005 for detailed guidance on risk assessment, treatment, acceptance, communication, monitoring, and review.

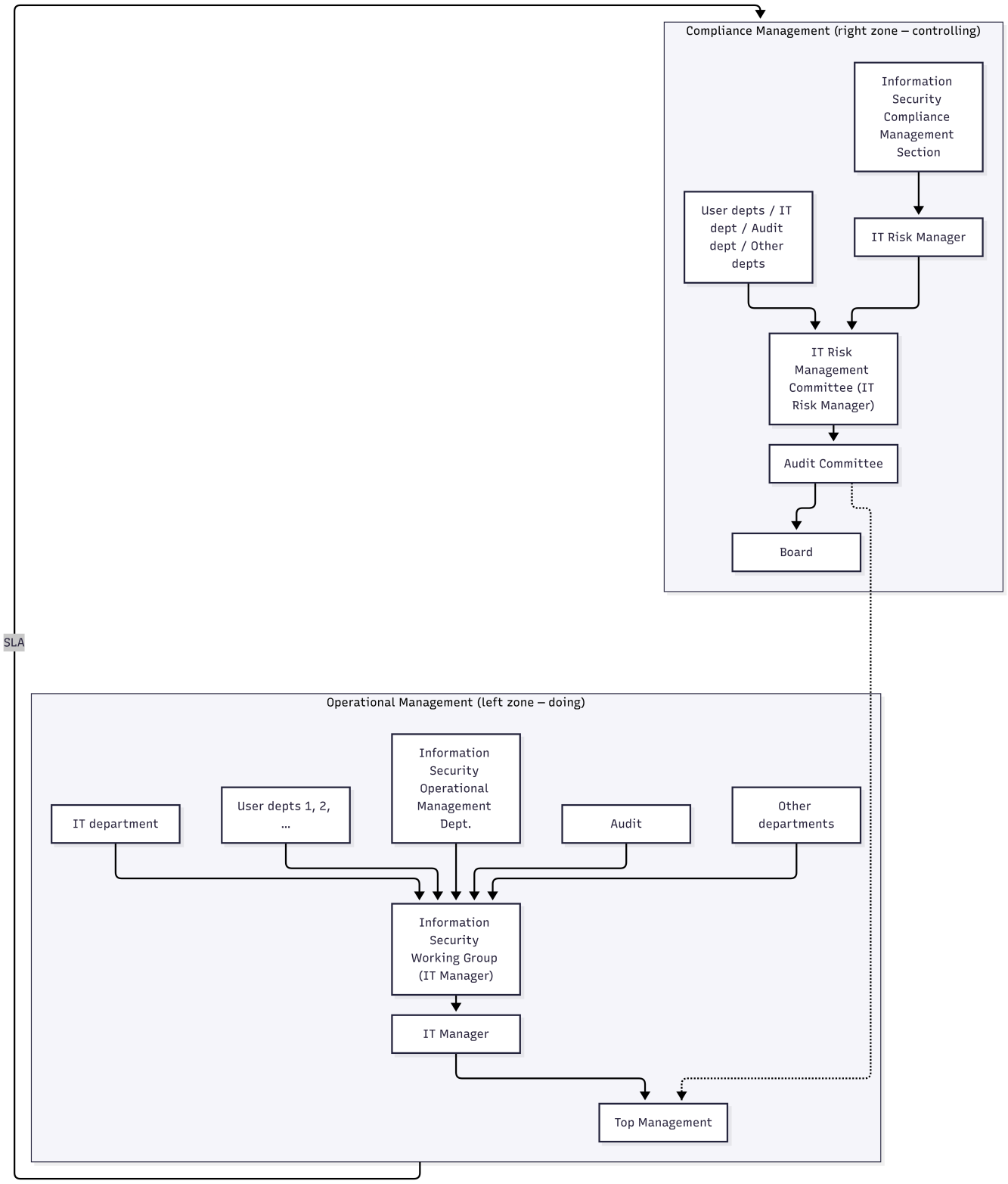
A structural principle closes the topic. All risks that could possibly have a negative effect on the well-being of the organization, once they materialize, are definitively the **responsibility of management**. It follows that **all levels of organizational management** must be involved in the process of risk management, and that it is imperative for information and IT-related risks to be managed in an **integrated manner together with business risks** rather than in a technical silo. This is especially important in cybersecurity, because the people at the strategic level typically have no technical background; it therefore falls to the middle level to assess everything worth investigating, to highlight the critical issues, and to bring them to the attention of the managers who take decisions, since those managers must be made aware of all the potential bad situations that could occur.

Organization of Information Security

Two Orthogonal Security Functions

The way information security is organized inside a company is itself a matter of great importance, and every best practice document underlines this — ISO 27002, for instance, dedicates a clause titled *Organization of Information Security* to it. The guiding recommendation is that the organization should contain **at least two distinct components**, and that these two components are **orthogonal** to one another. The first looks after **day-to-day operational aspects** — operational security. The second is responsible for the **compliance monitoring function** — compliance management. The reason for the separation is structural: the people who *do* things must not be the same people who *check how things are done*, otherwise control would be grading its own work.

This produces a two-zone organizational chart. The **left zone**, Operational Management, is where the operational activities are actually carried out, implementing the bottom of the pyramid. The **right zone**, Compliance Management, is where the control process is implemented and feedback is provided back to the Direct process. The two zones meet at the top, at Top Management, and are connected to each other through a **Service Level Agreement (SLA)** that governs the relationship between what is operated and what is audited.



In the operational chart, an **Information Security Working Group** led by the IT Manager aggregates input from the user departments, the dedicated Information Security Operational Management department, the audit function, the IT department, and other departments, and reports upward through the IT Manager to Top Management. In the compliance chart, an **Information Security Compliance Management Section** feeds the **IT Risk Manager**, who sits on an **IT Risk Management Committee**; that committee collects input from all the departments, assembles a consolidated view — the matrix of how things are done — and passes it to an **Audit Committee** that reports to the Board. In narrative terms, IT management on the operational side gathers information from the operational layer and composes it into a matrix view, which it hands to the person performing the audit; the audit side then collects input from across the departments and relays it to the risk management team, which in turn reports to top management.

Information Security Operational Management

The operational dimension is the set of people charged with ensuring that the system is functioning, organized into groups that monitor different departments, aggregate their information, and report to IT management. The activities it encompasses are the concrete, everyday actions of running security. They include **logical access control management**, meaning the real actions of adding to, changing, and deleting user access rights from access control lists. They include **identification and authentication management**, meaning the real actions of adding to, changing, and deleting entries in the user ID database and password files. They include **firewall management** — configuring firewalls with the authorized access rights, connecting workstations to LANs and to the Internet. They include **virus and malicious software management**, such as installing and updating antivirus software, together with the **handling of antivirus and related security incidents**. They include the **setting and updating of the security settings and configurations** of workstations and servers, the **ensuring of availability through UPS systems**, and the **ensuring of backups and the secure storage of those backups**, among other such day-to-day duties.

Information Security Compliance Management

The compliance dimension manages a different and orthogonal set of concerns, all directed at verifying that things are done in the right way and at assessing whether risk exists or persists. The activities that must be managed here include the **level to which previously identified IT risks are managed and mitigated**; the **level of information security awareness of users**; the **availability, completeness, and comprehensiveness of the information security policies, procedures, and standards**; the **level of compliance to those policies, procedures, and standards**; the **impact on the company's IT risk level when policies are not complied with**; the **compliance with regulatory, legal, and statutory requirements**; and **software licensing issues**, among others. In practice this side also takes the compliance clauses defined in the documents and attempts to apply them, verifying not only that risks are controlled but that the whole documentary edifice is current, complete, and actually followed.

Awareness and the SETA Programme

Why Awareness Matters at Every Level

A recurring principle of the whole model is that **all levels are involved in the ISG process**, and awareness is the mechanism by which that involvement reaches the human core of the company. Information security procedures, guidelines, and practices must be drafted and conveyed to **all** users of information and IT in the organization, which means that every information worker must be made aware of — and trained in — the information security policy together with its associated procedures, guidelines, and practices. This is precisely why the board directive and CISP documents must be distributed as widely as possible: awareness is the capability of the company to carry a genuine security attitude, to recognize security issues, and to know how to handle them, and it cannot exist unless the knowledge is spread.

The SETA Programme and Its Three Temporal Horizons

To build this capability the model recommends developing a **Security Education, Training and Awareness (SETA)** programme — an instrument operating at the human level of the company, whose purpose is to inject the security factor into people. SETA should be an *extension* of the general knowledge employees already possess to do their jobs; its objective is to teach each of them to do that

same job **securely**. The ambition is to move the awareness level from the basics to something that becomes automatic in the person's everyday life, creating a common understanding of both the issues and the solutions.

The programme has three stated objectives: to improve awareness of the importance and the need to protect organizational information resources; to acquire the necessary skills and know-how to do jobs more securely; and to create an understanding and insight into *why* it is important to protect organizational information assets. These three objectives map onto three distinct activities, each operating over a different time horizon, as captured by the differentiation between awareness, training, and education.

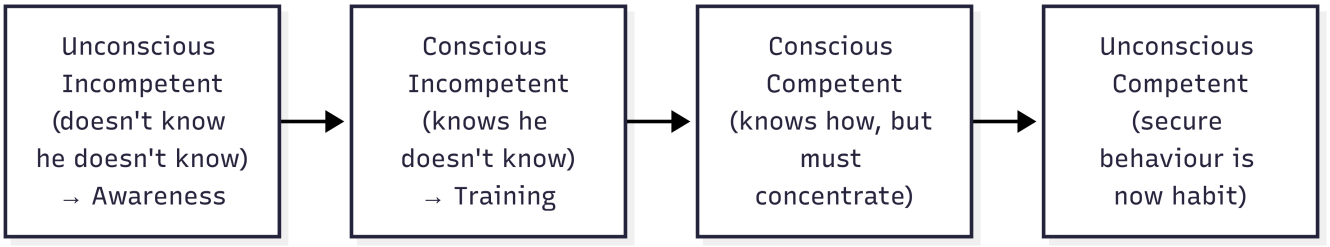
Awareness answers the attribute *what*, operates at the level of *information*, has the objective of making people *alert to* danger, is delivered through media such as videos, newsletters, and posters, and has a **short-term** impact — this is the first stage, developing the capability to understand what is dangerous. **Training** answers the attribute *how*, operates at the level of *knowledge*, has the objective of building *skill*, is delivered through practical instruction such as lectures, workshops, and hands-on practice, and has a **medium-term** impact — this is the stage that explains how to behave. **Education** answers the attribute *why*, operates at the level of *insight*, has the objective of *understanding*, is delivered through theoretical instruction such as seminars and literature study, and has a **long-term** impact — this is the most challenging stage, making people understand *why* they should behave in a certain way, and it is effective only over the long run.

Attribute	Awareness	Training	Education
Attribute (question)	What	How	Why
Level	Information	Knowledge	Insight
Objective	Alert to	Skill	Understanding
Teaching method	Media (videos, newsletters, posters)	Practical instruction (lecture, workshop, hands-on)	Theoretical instruction (seminar, literature study)
Impact timeframe	Short-term	Medium-term	Long-term

The Conscious Competence Learning Model

The journey an employee takes through a SETA programme is described by the **Conscious Competence Learning Model**, a four-stage progression from ignorance to instinct.

The starting point is **Unconscious Incompetence**: the person does not even realize that they do not know how to do a certain thing safely. The priority here is to make the individual aware that they are incompetent as far as that specific task is concerned, and this is the province of **awareness** exercises. The second stage is **Conscious Incompetence**: the employee now knows that they lack the skill, and the priority becomes **training** them to do the job in a secure manner. The third stage is **Conscious Competence**: the employee knows what to do and how to do it to keep the job secure, but still has to *concentrate* in order to perform the necessary procedures correctly. The fourth and final stage is **Unconscious Competence**: through enough practice and experience, all the security-related practices and skills have become inherent to the person's normal daily actions and behaviour — security has become a **habit** requiring no conscious effort.



The Pillars of Training

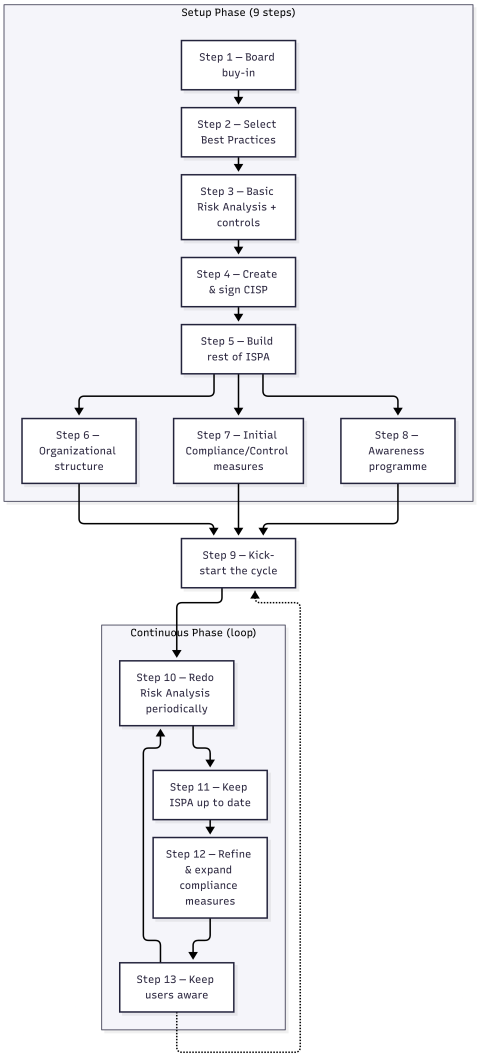
Underpinning the programme are the substantive topics that training must actually cover. At the level of *motivation*, employees must be taught why information is such an important asset, what the information security policy and procedures are, what the role and responsibility of every employee is, and what the consequences of not complying with the policy will be. At the level of *concrete practice*, the training should address user identification and authentication through passwords, how to choose a password, and the prohibition on sharing user IDs and passwords; virus control; backing up information; the sharing and storing of confidential information; secure email usage; secure Internet usage; social engineering; the handling of mobile devices such as notebooks and PDAs; the legal usage of software; office manners and discipline such as a clean-desk policy; and the required actions whenever a security incident or breach is suspected.

A Methodology for Establishing an ISG Environment

Putting the Whole Model Together

Having examined the Front Dimension, all five layers of the Depth Dimension, and the Best Practices basement, the final question is how to assemble the pieces into a working environment — *how do we put it all together?* The answer is a high-level **methodology of 14 steps**, deliberately written for the hardest case: it is a *complete* methodology that assumes no ISG environment exists at all and that everything must be started from scratch. In most real companies the situation is considerably better, so the methodology also carries a standing instruction to **re-use as much as possible** to avoid wasting time and money: the actual situation must be compared against the steps, and must be synchronized and integrated with them wherever possible.

The 14 steps divide into two phases. The **Setup Phase** comprises the first nine steps (Steps 1 through 9), executed largely in sequence although Steps 6, 7, and 8 branch out in parallel from Step 5. The **Continuous Phase** comprises the final five steps (Steps 9 through 13, with Step 9 acting as the bridge that kick-starts the loop), which then repeat perpetually, implementing the Direct–Control flow on an ongoing basis.



The Setup Phase (Steps 1–9)

Step 1 — Get the Board's buy-in about IT risk management and information protection. This is a critically important starting point, and without it the project will certainly struggle to progress properly. It is acceptable that one cannot initially obtain a *clean* Board Directive; what is essential is a genuine commitment from the board to support the project, which is enough to begin. Indeed, a basic, poor risk assessment may be performed first to identify the assets, under the approval of management, because the Direct process cannot start until it is known what must be protected. The formal Board Directive can come later — but it must be secured.

Step 2 — Select some guiding Best Practices. It is fundamental to choose an existing international best practice to serve as the foundation of the project and to provide motivation and direction. Many exist, and the essential point is simply to *have one*.

Step 3 — Perform a basic Risk Analysis and determine all needed controls. Some form of risk analysis is mandatory in order to identify the genuinely critical assets and to avoid wasting money and investment. This analysis requires involving a wide spectrum of people — board members, line management, users, system owners — and it must ensure that the relevant controls are installed and operational.

Step 4 — Create a CISP and have it signed by the Chairman/CEO. A CISP must be drafted, circulated among the stakeholders, and then submitted to top management. Recall that a more formal Board Directive on information security is essential in order to write a consistent CISP. The draft, once signed, becomes official company policy, and it forms the basis and motivation for all future steps.

Step 5 — Create the rest of the ISPA. The documents composing the full architecture must now be defined, taking as input the risk analysis from Step 3 and the CISP from Step 4, and following the guidelines discussed earlier. Throughout, the **connections between the documents must be preserved**, so that every sub-policy and procedure traces back up the tree.

Step 6 — Create the organizational structure for ISG. Specific attention must be paid to both the Operational Management and the Compliance Management sides, identifying the teams to be involved and the people responsible for them, and assigning responsibilities. Because this step is closely related to Step 7, it is preferable to perform the two **in parallel**.

Step 7 — Create an initial set of Compliance/Control measures and begin using them to produce reports on all three management levels. It is important here to obtain buy-in from the company's internal and external IT audit departments as well as the legal department; if these were already involved in Step 3, the process is much easier. Creating such measures is not straightforward, and their effectiveness and value will have to be refined over time — the point is to start with an initial set that forms the basis of the Control part of the model.

Step 8 — Create an Awareness Programme, including aspects such as information security job responsibilities. This step is core to the success of the whole effort and must be performed on a continuous basis, with all the documents of the ISPA forming part of the programme.

Step 9 — Get the cycle going and kick-start the process. At this point the whole programme must be initiated; if one already exists, the revised programme must be integrated with the existing one to make the new one operational. Step 9 is the hinge between the two phases.

The Continuous Phase (Steps 10–13)

Step 10 — Redo the Risk Analysis from time to time to identify changes in risks and controls. Risks are dynamic: old ones disappear as patches are installed, ports are closed, and access controls are deployed; new ones materialize as new software is installed or configuration parameters change; and existing ones shift in impact, since a single mitigation action may decrease the impact of several other threats at once. Periodic reassessment keeps the risk picture current and the controls operational.

Step 11 — Keep the ISPA up to date and aligned with the newly identified risks, ensuring that all changed risks are reflected by updating the content of the ISPA and its compliance clauses where necessary.

Step 12 — Refine and expand the Compliance/Control measures to cater for newly identified risks, enforce compliance, and keep reporting to top management. The choice and creation of compliance clauses and monitoring measures remain challenging, and the process never stops: experience is gathered continuously and used to refine existing measures and to create new ones.

Step 13 — Continue to make all users more information-security aware. This process can never stop and must be enforced on a continuous basis, after which the loop returns to Step 10.

CHAPTER 2: Frameworks, Standards, Best Practices

1. The Problem of Governing Known Risk

In May 2017, hospitals across the United Kingdom discovered their computers displaying a single, chilling message: their files had been encrypted and would remain inaccessible unless a ransom was paid. The consequences were immediate and tangible. Patients were redirected to other facilities, appointments were

cancelled, and several medical services were disrupted. The malware responsible was **WannaCry**, a ransomware worm that propagated rapidly across unpatched Windows machines.

The most instructive feature of this incident is not the sophistication of the attack, but its avoidability. The underlying Windows vulnerability had already been publicly disclosed, and Microsoft had released the corresponding security patch (MS17-010) *before* the attack took place. The vulnerability, in other words, was **known**. This raises the central question that motivates the entire discipline of security governance: if the risk was known and a remedy existed, why was the organization not prepared to manage it?

The answer is rarely technical. Patching a vulnerability is a solved problem in engineering terms. The failure lies instead in the absence of a **structured, organization-wide process** for discovering assets, assessing their exposure, prioritizing remediation, and ensuring that the remedy is actually applied across every machine. Managing known risk is a governance problem, and governance problems are addressed through frameworks, standards, and best practices. These three instruments form the conceptual backbone of this chapter.

2. Foundational Definitions

Before examining individual instruments, it is essential to distinguish three terms that are frequently used interchangeably in casual speech but carry precise and distinct meanings in security governance.

A **cybersecurity framework** is a structured, risk-based approach that helps an organization organize, assess, and improve its cybersecurity activities and outcomes. Its defining characteristics are that it is *structured* and *risk-based*. Being structured matters because it provides a **common language**: when multiple organizations describe their security posture using the same vocabulary and the same categories, they can communicate, compare, and align with one another, which is indispensable for coordination and, ultimately, for certification. Being risk-based matters because it directs the organization toward doing the right things *before* damage occurs, rather than reacting after the fact. A framework provides guidance; it tells an organization what it should account for and how to think about security, without dictating the precise technical implementation.

A **cybersecurity standard** is a formal set of requirements or specifications that an organization can implement and audit against to demonstrate and certify conformity. The crucial distinction from a framework is formality and auditability. A standard contains specific requirements, and because those requirements are precise, an independent party can verify compliance and issue a certification. The canonical example is **ISO/IEC 27001**. Standards function as the foundation for governing security: they are standardized, so they supply a common language across organizations, and that shared language is precisely what makes certification meaningful.

A **best practice** is a procedure or method proven by research and experience to produce effective or optimal results and suitable for widespread adoption. Best practices are the most concrete of the three: they are *actionable* and *less formal* than standards. They describe proven actions an organization can take to implement what a framework recommends. Typical examples include patch management, multi-factor authentication, vulnerability disclosure, access-control hygiene, and user awareness training. Over time, best practices that prove their value tend to become embedded in standards and referenced by frameworks, so the three categories are not isolated but continuously feed into one another.

The relationship can be stated compactly: a **framework** provides guidance for managing cybersecurity risk, a **standard** provides specific requirements that can be implemented and assessed, and a **best practice** provides proven actions to implement. To illustrate the formality gradient with a mundane

analogy, consider the "policy" of how to contact a professor. A policy is a high-level set of rules defining what is allowed and expected. The first rule might define the acceptable channel of contact (email); the second might require that the email be meaningful, with a clear leading subject; a third might require that the message provide sufficient context. This simple structure—high-level rules refined into specific, verifiable expectations—mirrors exactly how governance instruments descend from abstract guidance to concrete, checkable requirements.

3. Why Frameworks and Standards Matter

Frameworks and standards together provide a **roadmap to assess, improve, and communicate an organization's security posture**. They are, in the most fundamental sense, the foundations upon which security is governed. Three key aspects explain their enduring value. First, they offer **standardized approaches**, ensuring that different teams, departments, and even different companies operate from a shared understanding. Second, they are **risk-based and adaptable**, so that effort is directed where exposure is greatest and so that the same framework can serve organizations of radically different size and sector. Third, they institutionalize **continuous improvement**, treating security not as a project with an endpoint but as a process that is perpetually refined.

The most widely recognized instruments of this kind include the NIST Cybersecurity Framework (CSF), ISO/IEC 27001 and 27002, the CIS Controls, and COBIT, among many others.

4. Historical Evolution: From Standards to Frameworks to Best Practices

The modern landscape did not emerge all at once; it is the product of roughly three decades of accumulation, in which each layer built upon the previous one.

The lineage begins in the United Kingdom in the 1990s with **BS 7799**, a British information security standard that introduced one of the first structured approaches to information security management. In 1995, **BS 7799-1** was published as a code of practice—a catalogue of information security controls and guidance. In 1998, **BS 7799-2** added the management-system component, introducing the pivotal idea of a structured **Information Security Management System (ISMS)**: the notion that security should be managed through a deliberate, documented, continuously governed system rather than a set of ad hoc technical measures. In 2000, **ISO/IEC 17799** adopted this earlier British work at the international level, and in 2005 **ISO/IEC 27001** became the formal requirements standard for ISMSs, while **ISO/IEC 27002** evolved as its companion guidance on controls.

In parallel, best practices emerged as proven procedures that organizations could apply even before adopting a formal certification or framework. The authority that would come to formalize much of this thinking in the United States is the **National Institute of Standards and Technology (NIST)**, a federal agency founded in 1901 that develops scientific, technological, and measurement standards to promote innovation and industrial safety.

The framework era, as distinct from the standards era, crystallized in the mid-2010s. In 2013, Executive Order 13636 directed NIST to work with stakeholders to develop a *voluntary* framework for reducing cyber risk to critical infrastructure. In 2014, NIST issued Version 1.0 of the **Framework for Improving Critical Infrastructure Cybersecurity**, developed with extensive private-sector input and designed explicitly as voluntary guidance built on existing standards, guidelines, and practices—a design choice that made it flexible and broadly adoptable well beyond critical infrastructure. Also in 2014, the **Cybersecurity Enhancement Act** reinforced NIST's role, mandating support for the development of a voluntary, consensus-based, industry-led set of standards, guidelines, best practices, methodologies,

procedures, and processes. This Act is historically significant because it explicitly connected the three concepts that remain central today: standards, frameworks, and best practices. In 2018, NIST released **CSF Version 1.1**, adding cyber supply-chain risk management, self-assessment guidance, and clarifications on identity-related concepts. The NIST CSF is today recognized worldwide as a basis of security governance.

5. The Organizational Landscape and the Two Core Layers

The ecosystem of frameworks is vast. Beyond the general-purpose instruments, there exist sector-specific and purpose-specific frameworks: DORA and the SWIFT Customer Security Programme for finance, NIS2 and the EU Cybersecurity Act for the European Union, FISMA and FedRAMP for U.S. federal and cloud systems, CMMC for the U.S. defense supply chain, the HIPAA Security Rule for healthcare, PCI DSS for payment cards, IEC 62443 for industrial and operational technology, TISAX for automotive, and NERC CIP for the electricity sector. National frameworks exist as well, including the Italian National Cybersecurity Framework, Germany's BSI IT-Grundschutz, France's ANSSI guidance, the UK's NCSC Cyber Assessment Framework, and Australia's Essential Eight. Further specialized families cover application security (OWASP SAMM, OWASP Top 10, BSIMM, NIST SSDF), cloud security (CSA Cloud Controls Matrix, ISO/IEC 27017, FedRAMP), Zero Trust (NIST SP 800-207, CISA Zero Trust Maturity Model), maturity models (C2M2, CMMC, COBIT), and threat-modeling and intelligence schemes (MITRE ATT&CK, the Cyber Kill Chain, STRIDE, STIX/TAXII). The sheer breadth of this catalogue is itself a lesson: there is no single instrument, and competent governance means selecting and combining the right ones.

For the purposes of structured study, the core instruments can be organized into two complementary layers that answer two different questions.

The **framework layer** answers the strategic question: *what should I account for, and how should I organize security?* It provides principles and practices for managing and improving security. Its representatives are **ISO 27001, the NIST CSF, and the Italian Cybersecurity Framework**.

The **implementation layer** answers the operational question: *how do I apply the strategy?* It provides specific safeguards and measures to mitigate security risks. Its representatives are **ISO 27002, NIST SP 800-53, and the CIS Controls**.

Together, these two layers constitute **security governance**. A finer-grained mapping sharpens the distinction between the instruments and the questions each one is best suited to answer:

Layer	Main question	Instruments
Management system	How should information security be managed continuously?	ISO/IEC 27001
Control guidance	Which information security controls can be implemented?	ISO/IEC 27002
Risk framework	How can cybersecurity risk be organized and communicated?	NIST CSF, Italian NCF
Detailed controls	Which safeguards can be selected, tailored, and assessed?	NIST SP 800-53
Practical safeguards	What should be prioritized and implemented first?	CIS Controls

The logical progression of this chapter follows these layers. First come the frameworks—principles and standards giving the general idea of what to do within an organization. Then comes implementation—how to satisfy the security requirements the framework demands. Once implementation is understood, the governance pyramid can be reassembled in full.

---

6. ISO/IEC 27001

ISO/IEC 27001 is the first and best-known standard in the ISO 27000 family, and it is the world's foremost standard for Information Security Management Systems. It is the most international of the governance instruments, recognized in over sixty countries, which is precisely what gives it its value as a lingua franca of security certification.

6.1 The ISO 27000 Family

ISO 27001 does not stand alone; it sits at the head of a large family of related standards, each addressing a facet of information security management. ISO/IEC 27000 provides the overview and vocabulary; **27001** specifies the requirements for an ISMS; **27002** supplies the code of practice for implementing the controls; 27003 gives implementation guidance; 27004 addresses measurement; 27005 addresses information security risk management; and 27006 and 27007 deal with audit and certification bodies. Further members extend the family into specialized domains—27011 for telecommunications, 27017 and 27018 for cloud and personally identifiable information in the cloud, 27031 for ICT business-continuity readiness, 27032 for cybersecurity, the 27033 series for network security, 27035 for incident management, 27037 for digital evidence, and 27799 for health information. For the study of governance, the two members that matter most are **27001**, which defines *what* must be managed, and **27002**, which explains *how* the controls can be implemented.

6.2 The Management-System Approach

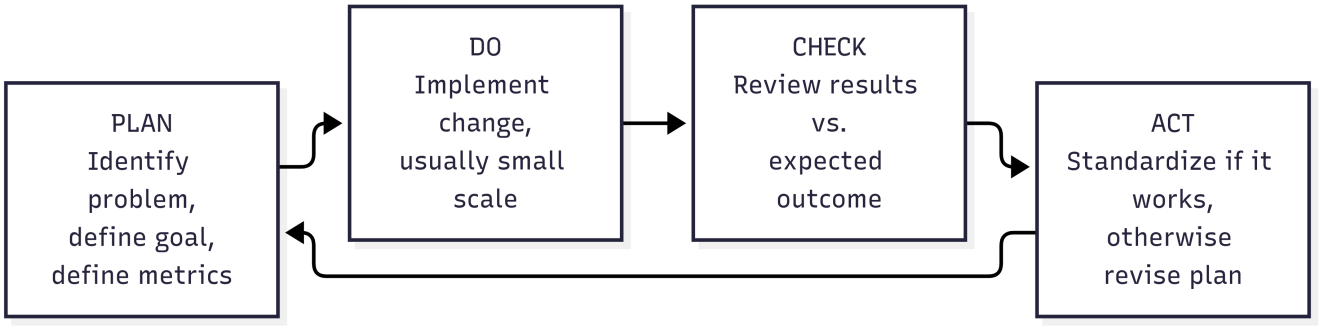
The single most important conceptual property of ISO 27001 is that it follows a **management-system approach**. This means security is treated as an **ongoing organizational process** rather than a one-time technical project. The standard specifies the requirements for establishing, implementing, maintaining, and *continually improving* an ISMS. Its purpose is to ensure that information security is managed systematically through governance, risk assessment, controls, monitoring, and improvement. Concretely, an organization adopting ISO 27001 must define its scope, assign responsibilities, assess and treat its risks, measure its performance, and continually improve the system. The requirements it specifies are known as **security controls**, and organizations are expected to be compliant with them. These controls are deliberately not highly detailed, because they must cover a very wide range of topics: the scope and objectives of the organization, the human dimension, the assessment and management of risk, the measurement of performance, and the continuous improvement of the ISMS.

6.3 The Deming Cycle (PDCA)

The engine that drives the "continual improvement" character of ISO 27001 is the **Deming Cycle**, also known as **PDCA**, a continuous-improvement method used to test changes in a structured way. Its four phases form a loop that never terminates.

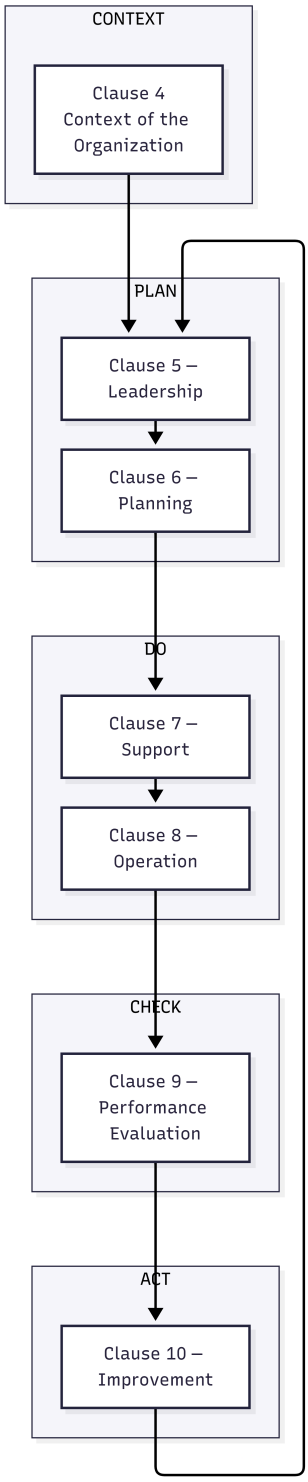
In the **Plan** phase, the organization identifies a problem, defines a goal, and decides in advance how success will be measured. In the **Do** phase, it implements the change, typically on a small scale to limit exposure. In the **Check** phase, it reviews the results and compares them against the expected outcome,

often on the basis of concrete measurements. In the **Act** phase, it standardizes the improvement if it worked, or revises the plan and repeats the cycle if it did not. The iterative nature of the loop is the entire point: security is never "finished," and each pass through the cycle refines the system a little further.



6.4 The Structure of ISO 27001: Clauses

ISO 27001 is organized into **clauses**, each of which is a section of the document. Clauses 1 to 3 are introductory, providing context and definitions. The **mandatory requirements reside in Clauses 4 to 10**, and these seven clauses map directly onto the phases of the Deming Cycle. Clause 4, the context of the organization, underlies and informs every phase of the cycle. Clauses 5 and 6 (Leadership and Planning) constitute the *Plan* phase. Clauses 7 and 8 (Support and Operation) constitute the *Do* phase. Clause 9 (Performance Evaluation) is the *Check* phase. Clause 10 (Improvement) is the *Act* phase. The standard is thus organized *across* the cycle: context covers all the steps, and the remaining clauses occupy their positions around the loop.



Each clause deserves examination in its own right, because together they define the complete anatomy of a managed security system.

Clause 4 — Context of the Organization. The organization must understand itself, the interested parties around it, and the scope of its ISMS. This clause establishes the boundaries within which everything else operates: what is being protected, who cares about it, and how far the management system reaches.

Clause 5 — Leadership. This clause makes information security a *leadership responsibility, not merely a technical activity.* It contains three sub-requirements. Under *5.1 Leadership and commitment*, top management must actively support the ISMS, align it with the business strategy, provide the necessary resources, and ensure the system achieves its intended outcomes. Under *5.2 Policy*, the organization must define and communicate an information security policy that sets direction, supports objectives, and reflects a commitment to compliance and continual improvement. Under *5.3 Organizational roles,*

responsibilities, and authorities, roles must be assigned clearly so that responsibilities are understood and reporting lines are effective. A recurring and non-negotiable principle of the standard appears here: **every person must be assigned a role and a responsibility, and this assignment must be formalized.**

Clause 6 — Planning. This clause turns context and leadership into a practical plan for managing risk and improving security. Under *6.1 Actions to address risks and opportunities*, the organization identifies the risks and opportunities related to the ISMS and plans actions to reduce threats, prevent problems, and improve effectiveness—this is where the security controls needed to assess and secure risks are brought to bear. Under *6.2 Information security objectives and planning to achieve them*, the organization sets **measurable** security objectives and defines who will do what, by when, and with which resources. Under *6.3 Planning of changes*, changes to the ISMS are managed in a controlled way so that security is not weakened by poorly planned updates. Such change management may be performed **manually**, or **automatically** through self-adaptive systems that detect and respond to vulnerabilities on their own.

Clause 7 — Support. This clause ensures the ISMS is supported by competent people, clear communication, and proper documentation. It concerns resources, competence, awareness, communication, and documented information. Under *7.1 Resources*, the organization provides the people, tools, budget, and infrastructure needed to run the ISMS. Under *7.2 Competence*, it ensures that those performing security-related work have the necessary knowledge, training, and experience. Under *7.3 Awareness*, it makes sure staff understand the security policy, their responsibilities, and the consequences of non-compliance. Under *7.4 Communication*, it defines what must be communicated, to whom, when, and through which channels—exactly the kind of formalized communication exemplified earlier by the rules governing a meaningful, context-rich email. Under *7.5 Documented information*, it creates, maintains, and controls the documents and records needed to support and to *prove* that the ISMS works.

Clause 8 — Operation. This is the clause where the ISMS becomes operational—where risks are assessed, treatments are chosen, and controls are applied in practice. Under *8.1 Operational planning and control*, operational processes are planned and controlled so the ISMS is implemented as intended, with explicit reference to the implementation guidance of ISO 27002. Under *8.2 Information security risk assessment*, a consistent method for identifying and evaluating risks is defined. Under *8.3 Information security risk treatment*, controls or measures are selected and implemented to treat the risks deemed **unacceptable**.

Clause 9 — Performance Evaluation. This clause checks whether the ISMS is delivering results and whether leadership is using the evidence to steer improvements. Under *9.1 Monitoring, measurement, analysis, and evaluation*, the organization tracks performance using indicators, metrics, and analysis. Under *9.2 Internal audit*, it regularly checks whether the ISMS conforms both to ISO 27001 and to the organization's own requirements, continuously auditing and searching for evidence of risk. Under *9.3 Management review*, top management reviews the ISMS to confirm it remains suitable, effective, and aligned with business needs. Notably, even here the standard remains non-prescriptive about exact technical steps: it tells the organization *that* it must monitor, audit, and review, without dictating the precise procedure.

Clause 10 — Improvement. This clause concerns conformity and the organization's capacity to improve continuously, including how it reacts after an incident. Under *10.1 Nonconformity and corrective action*, the organization investigates problems, fixes their root causes, and prevents recurrence. Under *10.2 Continual improvement*, it keeps strengthening the ISMS over time on the basis of audits, incidents, measurements, and changing risks.

6.5 Annex A and the Statement of Applicability

Beyond the ten clauses, ISO 27001 includes **Annex A**, a reference set of information security controls that functions as a **checklist**. In the 2022 revision, Annex A contains exactly **93 controls**. Organizations are not required to implement all of them indiscriminately; instead, they evaluate each control's applicability on the basis of their risk-treatment decisions. These decisions are documented in a central artefact called the **Statement of Applicability (SoA)**, which links risks, selected controls, and the justification for each inclusion or exclusion.

A well-constructed SoA records, for each control, the Annex A control identifier and name, whether the control is applicable, a justification for its inclusion or exclusion, and the implementation status of the controls deemed applicable. It normally also references the relevant policies, procedures, or evidence. The SoA is thus the document that connects abstract risk decisions to concrete controls and to the proof that those controls exist.

The relationship between Annex A and ISO 27002 is the natural bridge to the implementation layer: **ISO 27001 (through Annex A) defines *what* the 93 controls are, while ISO 27002 defines *how* each of those controls can be implemented.** ISO 27002 begins precisely from the controls catalogued in Annex A and expands each one into detailed guidance.

6.6 Could ISO 27001 Have Prevented WannaCry?

Returning to the motivating incident with the apparatus of ISO 27001 in hand reveals a subtle but critical lesson about the limits of certification. Imagine being the CISO of an organization with 2,000 Windows computers at the moment WannaCry strikes, having already implemented ISO 27001, and discovering that hundreds of machines remain unpatched despite Microsoft's prior release of MS17-010. How could this happen?

The decisive insight is that **possessing an ISO 27001 certificate does not prove that every computer was patched.** A certificate attests that a *management system* exists and functions, not that every technical control is perfectly executed at every instant on every asset. The standard, properly applied, nonetheless supplies the activities that *should* have prevented the situation: maintaining an **asset inventory** so that every Windows system is known; performing **risk assessment** so that the exposure is recognized; operating **vulnerability management** so that the available patch is identified and applied; conducting **monitoring** so that unpatched machines are flagged; preparing **incident response** so that an outbreak can be contained; and sustaining **security awareness** so that people understand their obligations. The failure in a real organization is therefore not the absence of the framework but the gap between holding a certificate and genuinely operating every clause and control the framework demands—most of all the Clause 8 operational discipline that turns risk treatment into applied, verified safeguards.

7. The NIST Cybersecurity Framework (CSF) 2.0

If ISO 27001 is the most *international* governance instrument, the **NIST Cybersecurity Framework** is the most *widely used* security governance framework in the world. Where ISO 27001 is a certifiable standard built around a management system, the NIST CSF is a voluntary, non-certifiable framework built around the organization and communication of risk. The two are complementary rather than competing, and much of the CSF's power comes from its flexibility and its universal applicability.

The framework focuses on using **business drivers** to guide cybersecurity activities and on treating cybersecurity risk as an integral part of the organization's broader risk-management processes. Although it was originally developed to improve cybersecurity risk management in critical infrastructures, it is

deliberately constructed so that any organization, in any sector or community, can adopt it. It provides a common organizing structure that assembles standards, guidelines, and practices already shown to work effectively in the field. Its applicability spans every kind of technology-dependent organization, whether the focus is on information technology (IT), industrial control systems (ICS), cyber-physical systems (CPS), or the broader world of connected devices and the Internet of Things (IoT).

The framework consists of three parts, which together answer three different governance needs: the **Core**, the **Implementation Tiers**, and the **Profiles**.

7.1 Features of the NIST CSF

The defining feature of the CSF is that it is **technology-neutral**. It remains effective regardless of the specific technologies in use and actively supports technical innovation, because it references a variety of existing standards, guidelines, and practices that themselves evolve alongside technology. Rather than prescribing particular products or configurations, it describes outcomes.

This neutrality enables the framework to provide a **common taxonomy and mechanism** through which an organization can accomplish five distinct things. It can describe its *current* cybersecurity posture; it can describe its *target* state for cybersecurity; it can identify and prioritize opportunities for improvement within a continuous and repeatable process; it can assess its progress toward the target state; and—recurring once more as a central theme of all governance—it can **communicate** about cybersecurity risk among internal and external stakeholders. Communication is not a peripheral benefit but one of the explicit purposes the framework is designed to serve.

7.2 The Core and Its Four Elements

The **Core** is the heart of the framework. It provides a set of activities to achieve specific cybersecurity outcomes and references examples of guidance for achieving those outcomes. A crucial clarification distinguishes the CSF Core from an ISO-style checklist: **the Core is not a checklist of actions to perform.** Instead, it presents key cybersecurity *outcomes*, identified by stakeholders as helpful in managing cybersecurity risk. The difference is more than semantic. A checklist enumerates tasks to tick off; an outcome catalogue describes states to achieve, leaving the organization free to determine how best to reach them.

The Core is built from four nested elements, descending from the most general to the most specific.

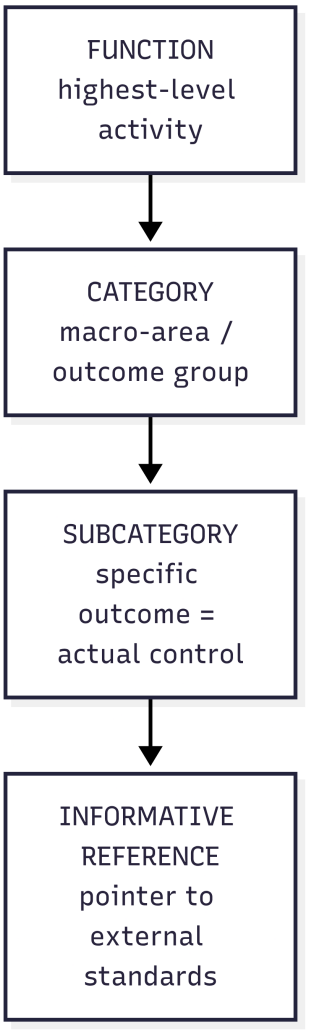
Functions organize basic cybersecurity activities at their highest level. They are the broad pillars of the framework.

Categories are subdivisions of a Function into groups of cybersecurity outcomes closely tied to programmatic needs and particular activities. They represent the **macro-areas** in which a Function operates. Examples include "Asset Management," "Identity Management and Access Control," and "Detection Processes."

Subcategories further divide a Category into specific outcomes of technical or management activities. They are the level at which the framework specifies the concrete actions to be taken—the actual security controls—and they provide the set of results that support the achievement of each Category's outcomes. Examples include "External information systems are catalogued," "Data-at-rest is protected," and "Notifications from detection systems are investigated."

Informative References are specific sections of standards, guidelines, and practices—common among critical-infrastructure sectors—that illustrate concrete methods for achieving the outcomes associated

with each Subcategory. They are, in effect, **pointers to other standards** that complement and operationalize the information contained in the Categories and Subcategories.



7.3 The Six Functions

In its original form the CSF comprised five Functions. The 2.0 revision introduced a sixth, **Govern**, which occupies a special position: whereas the other five Functions are each specific to particular operational aspects of cybersecurity, Govern is cross-cutting and *covers all the others*. Governing security means, in essence, possessing expertise across every function, with responsibility threading through the entire process—which is precisely why a standardized, structured approach is indispensable.

The six Functions, with the organizational understanding each one develops, are as follows. **Identify (ID)** develops the organizational understanding needed to manage cybersecurity risk to systems, people, assets, data, and capabilities—it supplies the controls necessary for understanding and deciding an organization's starting objectives. **Protect (PR)** develops and implements the appropriate safeguards to ensure delivery of critical services. **Detect (DE)** develops and implements the activities needed to identify the occurrence of a cybersecurity event. **Respond (RS)** develops and implements the activities to take action regarding a detected incident. **Recover (RC)** develops and implements the activities to maintain resilience plans and restore any capabilities or services impaired by an incident. **Govern (GV)** establishes and monitors the organization's cybersecurity risk-management strategy, expectations, and policies, guiding, prioritizing, and overseeing all the other activities.

Each Function is examined below in terms of its Categories.

Govern (GV). Govern establishes the strategic conditions that make the other five functions effective. Its Categories are *Organizational Context (GV.OC)*, understanding the organization's mission,

stakeholders, dependencies, and legal, regulatory, and contractual requirements; *Risk Management Strategy (GV.RM)*, establishing priorities, constraints, risk appetite, risk tolerance, and assumptions for cybersecurity decisions; *Roles, Responsibilities, and Authorities (GV.RR)*, defining accountability, decision-making authority, and responsibilities; *Policy (GV.PO)*, establishing, communicating, and enforcing cybersecurity policies; *Oversight (GV.OV)*, using risk-management results and performance information to review and adjust the strategy; and *Cybersecurity Supply Chain Risk Management (GV.SC)*, identifying, assessing, managing, monitoring, and improving the risks arising from suppliers and third parties.

Identify (ID). The governing maxim of this Function is that *you cannot protect what you have not identified.* Its Categories are *Asset Management (ID.AM)*, inventorying and managing data, devices, systems, and services; *Risk Assessment (ID.RA)*, identifying and evaluating cybersecurity risks; and *Improvement (ID.IM)*, using lessons learned to improve risk management.

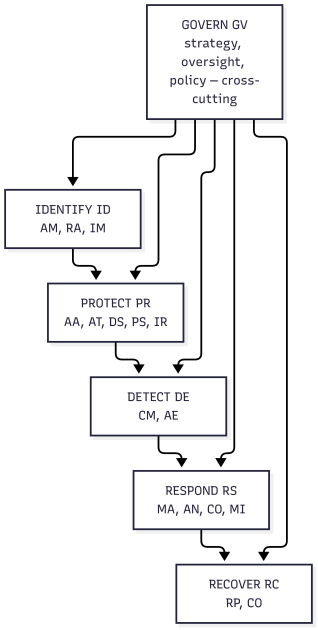
Protect (PR). The core principle here is to *reduce the likelihood and impact of an attack.* Its Categories are *Identity Management, Authentication, and Access Control (PR.AA)*, managing identities, authentication, and permissions; *Awareness and Training (PR.AT)*, training users and partners to perform their cybersecurity duties; *Data Security (PR.DS)*, protecting the confidentiality, integrity, and availability of data; *Platform Security (PR.PS)*, hardening and securing platforms and devices; and *Technology Infrastructure Resilience (PR.IR)*, ensuring the infrastructure can withstand and recover from disruption.

Detect (DE). The core principle is that *faster detection means faster response and less damage.* Its Categories are *Security Continuous Monitoring (DE.CM)*, continuously monitoring systems and networks, and *Adverse Event Analysis (DE.AE)*, identifying and analyzing abnormal activity.

Respond (RS). The governing idea is that *a good response reduces the operational and reputational impact of an incident.* Its Categories are *Incident Management (RS.MA)*, maintaining and executing incident-response procedures; *Incident Analysis (RS.AN)*, analyzing the incident to support response and recovery; *Incident Response Reporting and Communication (RS.CO)*, coordinating internal and external communications; and *Incident Mitigation (RS.MI)*, containing, eradicating, and reducing the incident's impact.

Recover (RC). The essential insight is that *recovery is not only restoration but also improvement.* Its Categories are *Incident Recovery Plan Execution (RC.RP)*, executing recovery processes and restoring services, and *Incident Recovery Communication (RC.CO)*, communicating recovery status and return-to-normal progress.

The complete Core can be visualized as the six Functions wrapped around a single wheel, with Govern at the center informing all the others:



7.4 Implementation Tiers

The second part of the framework, following the Core, is the set of **Implementation Tiers**. The Tiers provide context on *how an organization views cybersecurity risk* and on the processes it has in place to manage that risk. They range from **Tier 1 (Partial)** through **Tier 2 (Risk Informed)** and **Tier 3 (Repeatable)** to **Tier 4 (Adaptive)**, describing an increasing degree of rigor and sophistication in risk-management practices.

Two caveats are essential to interpreting the Tiers correctly. First, the Tiers give an indication of how an organization has implemented its practices and are useful for supporting improvement, but they **do not provide any certification**. Second, and emphatically, **the Tiers do not represent maturity levels.** An organization at Tier 1 is encouraged to consider moving toward Tier 2 or higher, but the purpose of the Tiers is to support decision-making about how to manage cybersecurity risk and about which dimensions of the organization are higher priority and deserve additional resources. Progression to a higher Tier is encouraged only when a cost-benefit analysis indicates that it would achieve a feasible and cost-effective reduction of cybersecurity risk—climbing the Tiers is a deliberate economic choice, not an automatic goal.

The character of each Tier can be understood across three dimensions: the **risk-management process**, the **integrated risk-management program**, and the degree of **external participation**.

At **Tier 1 — Partial**, the risk-management process lacks formalization and is managed on an ad hoc, sometimes reactive basis; the prioritization of activities may not be driven by organizational risk objectives, the threat environment, or business requirements. There is limited awareness of cybersecurity risk at the organizational level, risk is managed irregularly and case by case according to varied experience, and the organization may lack information-sharing processes altogether. External participation is characterized by **no collaboration**.

At **Tier 2 — Risk Informed**, risk-management practices are approved by management but may lack clearly articulated policies, and prioritization still may not flow directly from organizational risk objectives. There is awareness of cybersecurity risk at the organizational level, but no organization-wide approach to managing it; information is shared internally on an informal basis, not all levels of the organization are involved, and risk assessments of internal and external assets occur but are not typically repeatable or recurring. External participation is characterized by **low collaboration**.

At **Tier 3 — Repeatable**, policy is formally approved and defined, and it is regularly updated; there exists an organization-wide approach to managing cybersecurity risk. External participation rises to **high collaboration**.

At **Tier 4 — Adaptive**, standards and best practices are applied, and the organization runs a continuous-improvement process; its organization-wide approach uses risk-informed policies, processes, and procedures to address potential cybersecurity events as they evolve. External participation reaches **full collaboration**.

	Risk Management Process	Integrated Program	External Participation
Tier 1 — Partial	Ad hoc, reactive, not formalized	Limited organization-level awareness	None
Tier 2 — Risk Informed	Management-approved, policies may be absent	Aware but not organization-wide; informal sharing	Low
Tier 3 — Repeatable	Formally approved policy, regularly updated	Organization-wide approach	High
Tier 4 — Adaptive	Standards and best practices, continuous improvement	Organization-wide, risk-informed, event-adaptive	Full

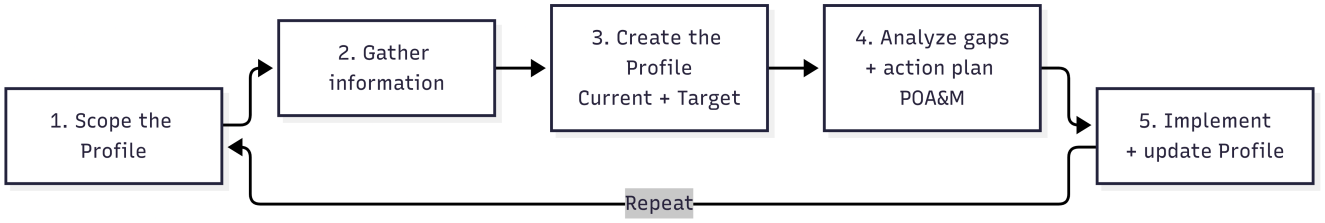
7.5 Profiles

The third part of the framework is the **Profile**. A Framework Profile is the alignment of the Functions, Categories, and Subcategories with the particular business requirements, risk tolerance, and resources of an organization. Profiles can describe either the current state or the desired target state of specific cybersecurity activities. The **Current Profile** indicates the cybersecurity outcomes that are presently being achieved, while the **Target Profile** indicates the outcomes needed to meet the organization's desired risk-management goals. The comparison between the two is what enables a **gap analysis**: the difference between where the organization is and where it wishes to be defines the work that remains. Importantly, the framework does not prescribe any Profile templates, preserving flexibility in how the comparison is implemented.

> **The Community Profile.** Beyond the Current and Target Profiles of a single organization, the framework recognizes a third construct: the **Community Profile**, a baseline of CSF outcomes created and published to address shared interests and goals among a group of organizations. A Community Profile is typically developed for a particular sector, subsector, technology, or threat type, and an organization can adopt it as the starting point for its own Target Profile rather than building one from nothing. The Community Profile is, in spirit, the NIST analogue of the sector-level Contextualization encountered later in the Italian National Framework.
>
> **The Organizational Profile lifecycle.** Creating and using an Organizational Profile is not a single act but a repeatable five-step cycle, which constitutes the practical method by which the framework drives continuous improvement:
>
> 1. **Scope the Organizational Profile.** Document the high-level facts and assumptions that define the Profile's scope. A Profile may cover an entire organization or be narrowed to a single concern, such as the financial systems or the handling of ransomware threats.
> 2. **Gather the information needed.** Collect organizational policies, risk-management priorities and resources, enterprise risk profiles, business impact analysis (BIA) registers, the cybersecurity

requirements and standards the organization follows, and the practices, tools, and work roles already in place.

3. **Create the Organizational Profile.** Determine which information to record for each selected outcome and document both the Current state and, considering the risk implications, the Target state.
4. **Analyze the gaps and create an action plan.** Conduct the gap analysis between Current and Target Profiles and develop a prioritized action plan — expressed, for instance, as a risk register, a risk detail report, or a Plan of Action and Milestones (POA&M) — to close those gaps.
5. **Implement the action plan and update the Profile.** Execute the plan to move the organization toward the Target state, then repeat the cycle as often as needed.



7.6 How to Use the NIST CSF

The framework supports a range of practical uses within an organization. It can serve as a basic review of existing cybersecurity practices; as the foundation for establishing or improving a cybersecurity program; as a vehicle for communicating cybersecurity requirements with stakeholders; as an input to buying decisions; as a means of identifying opportunities for new or revised informative references; as a methodology for protecting privacy and civil liberties; and as an instrument for self-assessing cybersecurity risk.

Risk communication across the organization. One of the framework's central purposes is to improve the flow of cybersecurity information between the three layers of an organization. Communication is bidirectional. **Executives** set mission priorities, risk appetite, and budget, which cascade downward; **managers** translate these into Target Profiles and track the action plan; and **practitioners** implement the target state and measure operational risk, feeding key performance and key risk indicators back upward. In this way, practitioners report implementation progress and emerging risks to managers and executives, while executives communicate expectations and resources back down — the loop that keeps strategy and operations aligned.

Integration with enterprise risk management. Cybersecurity risk is one of several risks an enterprise faces, alongside financial, privacy, supply-chain, reputational, and technological risks. The framework is explicitly designed to be used *in conjunction with* other risk instruments and to feed into **Enterprise Risk Management (ERM)**, translating cybersecurity terminology into the general risk language executives understand so that cybersecurity can be balanced as one element in a portfolio of enterprise risk. It also complements the **NIST Risk Management Framework (RMF)** — notably SP 800-37 and SP 800-30 — and its approach to selecting controls from SP 800-53.

Cybersecurity risk versus privacy risk. Cybersecurity and privacy are independent disciplines whose objectives nonetheless overlap. Cybersecurity risks arise from the loss of confidentiality, integrity, or availability of systems and data; privacy risks arise from the *processing* of individuals' data and can occur even in the absence of any security incident. The two overlap in the region of **cybersecurity-related privacy events** — for example, a data breach that leads to identity theft. Privacy harms range from dignity-type effects, such as embarrassment or stigma, to tangible harms,

> such as discrimination, economic loss, or physical harm. The NIST Privacy Framework and the Cybersecurity Framework are intended to be used together to address these distinct but intersecting aspects.



> This same convergence of cybersecurity and data protection is what the Italian National Framework later operationalizes through its dedicated GDPR contextualization. Finally, the framework extends to newer risk domains: **supply-chain risk** is addressed through the Govern function's C-SCRM category (with deeper guidance in SP 800-161), and **risks from emerging technologies** such as artificial intelligence are addressed in coordination with the NIST AI Risk Management Framework (AI RMF), which borrows the same Functions-Categories-Subcategories structure.

7.7 The Framework in Action: A Worked Example

The abstract machinery of the CSF becomes concrete when applied to a scenario. Consider a **university research department** that wishes to protect sensitive research data, cloud services, staff accounts, and laboratory systems. The first governance step is to define the **organizational scope**, which in this case encompasses the research servers and laboratory systems; the cloud storage and collaboration platforms; the research data and personal information; the staff, researchers, students, suppliers, and external partners; and the legal, contractual, and university security requirements that apply.

With scope established, the department constructs its **Profiles** by examining each relevant Function and Category, recording the current state, the target state, and the priority. The result is a structured gap analysis of the kind shown below.

Function and category	Current state	Target state	Priority
GV.OC — Organizational Context	Critical services and external dependencies not fully documented	Document critical services, stakeholders, dependencies, requirements	High
GV.RR — Roles and Responsibilities	Security responsibilities informally assigned to IT staff	Approve clear responsibilities across management, IT, researchers, suppliers, IR	High
GV.SC — Supply Chain Risk Mgmt	Cloud and software suppliers reviewed inconsistently	Establish supplier security requirements, due diligence, monitoring, obligations	High
ID.AM — Asset Management	Hardware inventoried; cloud services and datasets incomplete	Maintain updated inventory with owners, classifications, criticality	High
ID.RA — Risk Assessment	Performed only after major incidents or projects	Perform periodic and event-driven assessments via documented method	High
PR.AA — Access Control	MFA protects admins but not all users	Require MFA for all accounts; review privileged access regularly	High

Function and category	Current state	Target state	Priority
PR.DS — Data Security	Backups exist; encryption and restore testing vary	Encrypt sensitive data, define retention, test restoration regularly	High
DE.CM — Continuous Monitoring	Logs collected from selected systems, reviewed manually	Centralize logs, generate alerts for suspicious activity	Medium
RS.MA — Incident Management	General IT procedures only; no research-specific playbook	Establish, test, maintain IR procedures and escalation paths	High
RC.RP — Recovery Plan Execution	Services restorable but priorities and objectives unclear	Define recovery priorities, responsibilities, RTOs, RPOs, exercises	Medium

The department then situates itself on the **Tier** scale. It is best characterized as **Tier 2 — Risk Informed**, because it recognizes cybersecurity risks and performs some risk-management activities, but its practices are not yet consistently established or applied across the organization. The evidence for this classification is telling: security risks are discussed in IT and project meetings; some systems use MFA, backups, logging, and access reviews; risk assessments occur for selected projects or incidents; supplier risks are known but not managed through a consistent process; cybersecurity information flows mainly through informal communication; and procedures vary between laboratories and research teams.

The chosen **target is Tier 3 — Repeatable**, in which risk-management practices are formally approved, documented, consistently implemented, and regularly reviewed across the department. Reaching Tier 3 requires a concrete set of actions: approving an organization-wide risk-management policy; assigning formal roles and responsibilities; maintaining complete asset and data inventories; applying a single risk-assessment method to all relevant systems; requiring MFA and periodic access reviews; standardizing supplier-security requirements; centralizing monitoring and incident reporting; testing incident-response and disaster-recovery plans; and using metrics and management reviews to track improvement.

7.8 What Tier Was WannaCry?

The framework also offers a diagnostic lens on the WannaCry failure. Reconsider the organization in the aftermath of the attack, having discovered that IT knew some machines were unpatched, that there was no complete inventory of Windows systems, that patching was performed manually whenever administrators happened to have time, that the security team had previously warned management about the risk, that there was no organization-wide process for prioritizing vulnerabilities, and that some systems could not be patched immediately because of compatibility or availability concerns, and that although an incident-response procedure existed, it had never been tested through a large-scale exercise —prompting management to ask, "How did we not know this was going to happen?"

This profile corresponds unmistakably to **Tier 1 — Partial**. The reactive, ad hoc patching, the absence of a complete inventory, the lack of any organization-wide vulnerability-prioritization process, and the informal, unheeded internal warnings are the textbook signature of the Partial Tier. Improving beyond it would mean precisely the moves that define the ascent toward Tier 3: building a formal asset inventory, instituting a documented and repeatable vulnerability-management process, assigning clear responsibilities, and establishing an organization-wide, management-endorsed approach to prioritizing and treating risk.

The scenario therefore sharpens the chapter's recurring lesson: the organization failed not for lack of documented policies and controls, but because those controls were partial, untested, and unverified in operation — the gap between a control's *design* and its demonstrable *operation* that the implementation layer, and the homework's "How could this happen?" question, both exist to expose.

8. The Italian National Cybersecurity Framework (NCF)

Having examined one international standard (ISO 27001) and one international framework (NIST CSF), the natural next step is a **national** framework: the Italian National Cybersecurity Framework, formally the *Framework Nazionale per la Cybersecurity e la Data Protection*. Its existence illustrates an important principle of governance—that a framework may need to be adapted to the economic and institutional realities of the country in which it operates, without abandoning international compatibility.

8.1 Motivations

The Italian NCF was created to pursue several interlocking objectives, each responding to a specific feature of the national context.

The first and most elevated aim is to bring **cyber-risk awareness to the highest levels of the business**, so that cybersecurity is no longer treated merely as a matter for technical staff. The framework seeks to make organizations fold cyber risk into their general risk-management processes, treating it as a component of *economic* risk rather than a purely technical nuisance.

This ambition is shaped decisively by the **structure of the Italian economic landscape**. A striking **69% of the national GDP** is generated by small and medium-sized enterprises (SMEs), and there are very few large national enterprises—on the order of **0.1%**. A framework intended for Italy therefore cannot be designed around the resources and sophistication of large corporations; it must be usable by a vast population of small organizations with limited budgets and limited specialist staff.

The framework further aims to create something **recognized at the international level**, to **improve information-sharing capacity**, and to **increase the duty of care at the national level**. Finally, it embraces a principle of economy and pragmatism: **do not reinvent the wheel.** There is no sense in constructing a wholly new framework from scratch when a recognized and well-tested one already exists. Accordingly, the Italian NCF takes the **NIST CSF** as its starting point, inheriting its structure of Functions, Categories, and Subcategories and adapting it to the Italian situation.

8.2 What the National Framework Is and Is Not

A precise understanding of the NCF's nature requires drawing a sharp boundary around what it is *not*. The National Framework is **not a standard**, and consequently **it is not certifiable**. This distinguishes it fundamentally from ISO 27001.

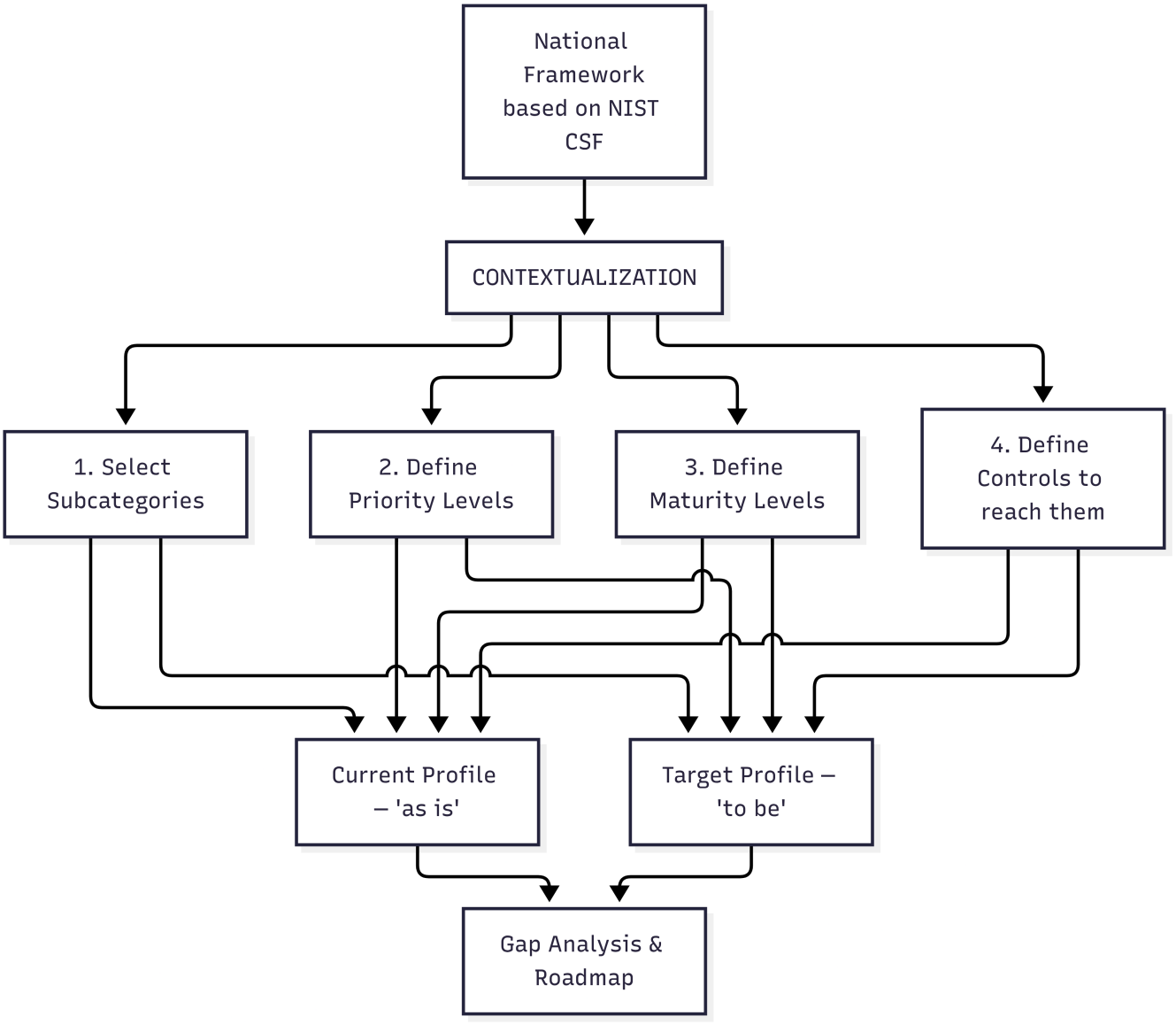
What it *is* instead is a **tool for self-assessment**. It allows an organization to assess its current cybersecurity posture—its **current profile**—and to define the posture it wishes to attain—its **target profile**. It then supports the organization in performing the **gap analysis** between the two and in defining a **roadmap** to close that gap. In spirit and mechanism it is far closer to the NIST CSF than to ISO 27001: it organizes and communicates risk and guides improvement, rather than imposing auditable requirements leading to a certificate.

8.3 Contextualization

The central and distinctive mechanism of the Italian NCF is **Contextualization**: the process by which the framework is "customized" so as to adapt it to a specific context, whether a sector, a public administration, or an individual organization. Contextualization is the operation that turns a generic national framework into a concrete, tailored instrument.

A Contextualization is defined through four steps. First comes the **selection of Subcategories**—choosing, from the full catalogue inherited from the CSF structure, those that are relevant to the context at hand. Second comes the **definition of a Priority Level** for each selected Subcategory. Third comes the **definition of Maturity Levels**. Fourth comes the definition of the **Controls** needed to reach those maturity levels. In this way the framework layers two additional dimensions—priority and maturity—onto the Functions, Categories, Subcategories, and Informative References it inherits.

Once a Contextualization has been established, it becomes possible to define the two profiles familiar from the CSF: the **Current Profile**, representing the *"as is"* state of the organization, and the **Target Profile**, representing the *"to be"* state it aspires to. The gap between the two again drives the improvement roadmap.



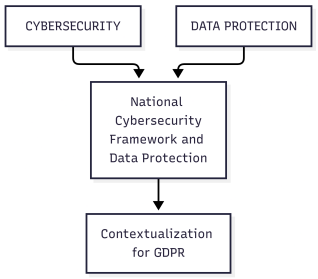
The flexibility of Contextualization is deliberately broad. A Contextualization can be defined for a single organization; for an entire economic or productive sector; for groups of organizations grouped by scale, such as SMEs or large enterprises; for organizations belonging to regulated sectors, such as public administrations or banks; and for critical infrastructures. This range directly answers the structural

concern noted earlier: because a Contextualization can be built specifically for SMEs, the framework can serve the overwhelming majority of the Italian economy without demanding the resources of a large enterprise.

[Photo: Contextualization architecture diagram] The architecture of the framework places the **National Cyber Security Framework** across the top as the common reference. On its left sits the **Implementation Tier** dimension, drawing on enterprise risk-management references such as CAS, COSO, and ISO. On its right sits the **Priority Levels / Maturity Levels** dimension, drawing on IT and security standards such as COBIT, SANS, and ISO. Between these two flanks, the central body of the diagram stratifies the economy into layers—Critical Infrastructures at the top, Large Organizations in the middle, and Small and Medium Enterprises at the base—crossed vertically by production sectors and regulated sectors. The key theoretical message of the layout is that the single national framework can be contextualized simultaneously along two axes: *vertically* for a given productive or regulated sector, and *horizontally* as a general framework contextualization driven by enterprise risk management on one side and security standards on the other.

8.4 Contextualization for GDPR

A particularly significant Contextualization is the one that integrates **data protection** into cybersecurity. The reasoning is that cybersecurity and data protection, though historically distinct disciplines, converge on the same assets and the same risks. By combining them, the framework produces a unified **National Cybersecurity Framework and Data Protection**, and this combined instrument can then itself be contextualized for the **GDPR**—the European General Data Protection Regulation.



This integration is reflected in the evolution to **Framework 2.0**, whose architecture adds an explicit **Data Protection Regulations** dimension—with **GDPR** as its leading entry—alongside the existing IT and security standards. In other words, data-protection regulation is elevated to a first-class reference axis of the framework, standing on equal footing with the technical security standards that inform priority and maturity levels.

8.5 Framework 2.0: The Four Placement Cases

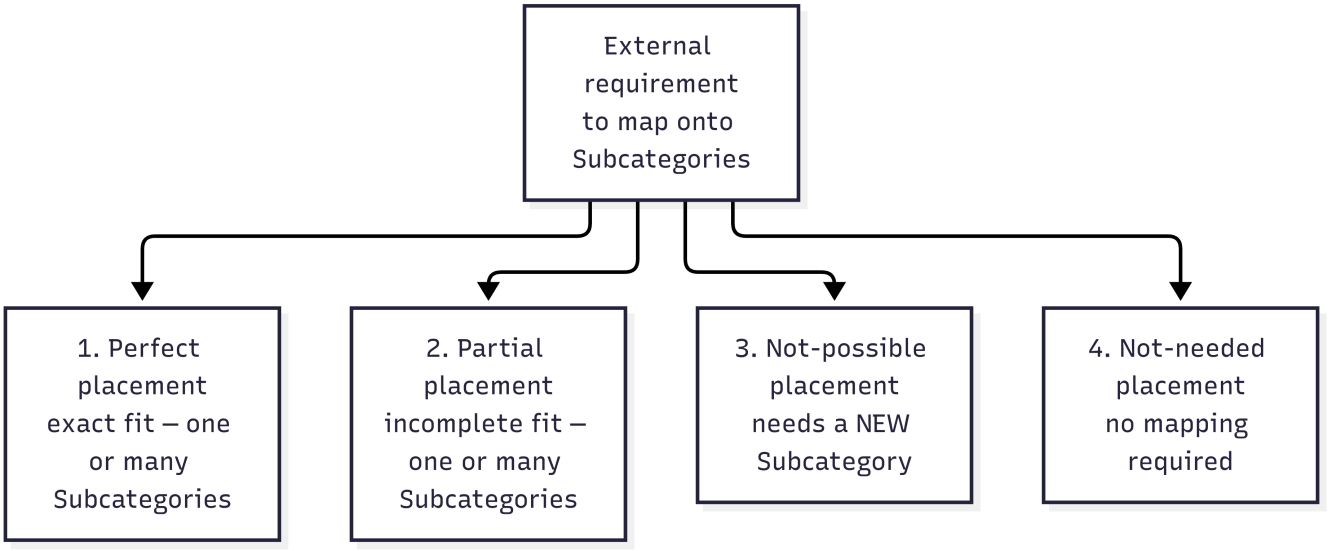
When an external requirement, control, or regulatory obligation must be mapped onto the framework's structure of Subcategories, four distinct cases can arise. Understanding these cases is essential to performing a Contextualization correctly, because they determine whether the existing structure suffices or must be extended.

The first case is **perfect placement**, in which the requirement maps cleanly and completely onto the existing structure. This may occur on a single Subcategory or across more than one Subcategory, but in either situation the fit is exact.

The second case is **partial placement**, in which the requirement maps onto the existing structure only incompletely—covering part but not all of a Subcategory. Again this may occur on a single Subcategory or on more than one.

The third case is **not-possible placement**, in which the requirement cannot be accommodated by any existing Subcategory at all. This situation signals a genuine gap in the framework's structure and creates the **need for a new Subcategory** to be added.

The fourth case is **not-needed placement**, in which a mapping is simply not required—the requirement does not call for placement within the framework.



---

9. Implementation: ISO/IEC 27002

With the framework layer complete, the chapter now turns to the **implementation layer**—the instruments that answer the question of *how* to apply the strategy. The first of these is **ISO/IEC 27002**, the natural companion to ISO 27001.

9.1 Nature and Purpose

ISO/IEC 27002 is the **companion standard on information security controls**. Where ISO 27001 specifies *what* must be managed, ISO 27002 explains *how* the controls can be understood and implemented. It provides a reference set of generic controls together with detailed implementation guidance, and it is designed to be used within an ISMS based on ISO 27001, for implementing commonly accepted controls, or for developing organization-specific guidance. In practical terms, it gives security teams the detailed direction they need to select and apply controls consistently.

A defining characteristic sets 27002 apart from 27001: **it is not a certification standard.** Certification is always against ISO 27001, never against ISO 27002. The reason is fundamental and worth dwelling on: **there is no single correct way to implement a control.** Because implementation legitimately varies according to an organization's circumstances, technologies, and risk profile, 27002 can offer guidelines and best practices but cannot impose the kind of uniform, verifiable requirements that certification demands. It describes the detail of each control, starting from Annex A of ISO 27001 and expanding each entry into actionable guidance.

9.2 Structure of ISO/IEC 27002:2022

The 2022 edition reorganized the control catalogue into **four themes**, or macro-areas, a simplification intended to make the catalogue easier to navigate and apply. The total control set comprises **93 controls**, distributed across the four themes as follows.

The **Organizational** theme contains **37 controls**, covering governance, policies, supplier relationships, incident management, and related management practices. The **People** theme contains **8 controls**, addressing matters such as screening, awareness, training, and the responsibilities of personnel. The **Physical** theme contains **14 controls**, concerning the protection of facilities, equipment, and physical environments. The **Technological** theme contains **34 controls**, covering access control, logging, malware protection, secure development, network security, and related areas.

Theme	Number of controls
Organizational	37
People	8
Physical	14
Technological	34
Total	**93**

An instructive observation emerges from comparing these themes. The **People** controls tend to be nearly the same for every organization—background screening, training, and disciplinary processes look broadly similar regardless of industry—whereas the **Technological** controls may vary considerably from one organization to another, reflecting differences in systems, architectures, and technical environments.

The individual controls within each theme can be surveyed to convey the catalogue's breadth. The **Organizational** controls (5.1–5.37) include policies for information security; information security roles and responsibilities; segregation of duties; management responsibilities; contact with authorities and with special interest groups; threat intelligence (new in 2022); information security in project management; inventory of information and assets; acceptable use and return of assets; information classification and labelling; access control and identity management; supplier security policies; information security in cloud services (new); incident management and ICT continuity; and legal, compliance, documentation, and audit requirements.

The **People** controls (6.1–6.8) comprise screening (background verification of candidates prior to employment); terms and conditions of employment; information security awareness, education, and training; a disciplinary process for handling policy violations; responsibilities that remain after termination of employment; confidentiality or non-disclosure agreements; remote-working security controls; and a mechanism for the prompt reporting of security events.

The **Physical** controls (7.1–7.14) cover physical security perimeters; physical entry controls; securing offices, rooms, and facilities; physical security monitoring (new); protection against physical and environmental threats; working in secure areas; clear desk and clear screen; equipment siting and protection; security of assets off-premises; storage media; supporting utilities; cabling security; equipment maintenance; and secure disposal or re-use of equipment.

The **Technological** controls (8.1–8.34) are conveniently grouped into four clusters. *Access and Identity* (8.1–8.6) includes user endpoint devices, privileged access rights, access control, authentication, identity management, and privileged utilities. *Data Protection* (8.10–8.12, 8.24) includes information deletion (new), data masking (new), data leakage prevention (new), and cryptography. *Security Operations* (8.15–8.22) includes logging and monitoring, clock synchronization, web filtering (new), network security, configuration management (new), and vulnerability management. *Secure Development and Acquisition* (8.25–8.34) includes the secure development lifecycle, secure coding (new), security testing, outsourced development, and separation of environments.

9.3 Annex A versus ISO 27002: Normative versus Guidance

The precise relationship between ISO 27001's Annex A and ISO 27002 is the key to understanding how the two standards interlock, and it rests on a single distinction: **Annex A is normative; ISO 27002 is guidance.**

Annex A of ISO 27001 contains a catalogue of control objectives and controls that organizations select as part of their ISMS. It is **normative**—binding and linked directly to the risk-treatment process—but it is also terse, typically stating only the control's name and a one-sentence statement of what the control requires. ISO 27002:2022, by contrast, provides **detailed implementation** guidance, purpose statements, and attributes for the *same 93 controls* referenced in ISO 27001, helping translate the austere Annex A entries into actionable operative measures.

The difference is vividly illustrated by a single control. In Annex A of ISO 27001, the control on access to program source code appears as little more than a title and the normative statement that access to program source code shall be restricted. In ISO 27002, the same control is accompanied by extensive implementation guidance: that source code and associated items such as designs, specifications, and verification plans should be strictly controlled to prevent the introduction of unauthorized functionality and to preserve confidentiality; that source libraries should preferably not be held in operational systems; that source code and libraries should be managed according to established procedures; that support personnel should not have unrestricted access; that updates and the issuing of source to programmers should occur only after appropriate authorization; that program listings should be held securely; that an audit log of all accesses should be maintained; that maintenance and copying should be subject to strict change-control procedures; and that, where source code is to be published, additional integrity controls such as digital signatures should be considered. The same control thus exists in both documents, but Annex A declares the *obligation* while ISO 27002 supplies the *method*.

10. Implementation: NIST SP 800-53

The second instrument of the implementation layer is **NIST Special Publication 800-53**. If ISO 27002 is the implementation companion to the ISO 27001 management-system standard, SP 800-53 plays an analogous role on the NIST side, translating high-level framework outcomes into a concrete, detailed catalogue of controls—though it does so with far greater granularity and a distinctly American, federal orientation.

10.1 The Special Publications Series

NIST periodically publishes technical reports that provide guidelines, recommendations, and reference material, particularly in the field of information security. These are known as **Special Publications (SPs)**. The **SP 800 series** is NIST's primary channel for publishing computer, cyber, and information security guidelines, recommendations, and technical specifications. SP 800-53 is one member of this series, and it is among the most important.

NIST Special Publication 800-53 provides a comprehensive catalogue of **security and privacy controls** for information systems and organizations. Its controls are deliberately **flexible and customizable**: organizations select and tailor them according to their mission, business needs, risk tolerance, and operating environment. Crucially, like ISO 27002, SP 800-53 is **a control catalogue and implementation reference, not a certification standard** such as ISO 27001. It supplies the raw material of controls; it does not issue certificates.

The publication pursues three explicit aims. The first is to provide a **catalogue of security and privacy controls** for federal organizations and information systems. The second is to provide a **process to select controls** that protect an organization's mission, functions, image, reputation, assets, and individuals—and the state itself—from cyberattacks, disasters, malfunctions, and human errors. The third is to provide a **methodology for selecting critical controls**, which is the concept of the **baseline**.

10.2 Key Concepts

Several concepts underpin the structure of SP 800-53 and recur throughout its use. **Security controls** are the safeguards and countermeasures that protect the confidentiality, integrity, and availability of systems and information. **Privacy controls** are the administrative, technical, and physical safeguards that manage privacy risks and support compliance with applicable privacy requirements. **Control families** are groups of controls organized by topic—for instance, access control, incident response, risk assessment, and supply-chain risk management. **Control enhancements** are additional requirements that strengthen or extend a base control for higher-risk environments. **Tailoring** is the process of adapting controls to a specific organization, system, mission, technology, or risk profile.

10.3 Revision 5 and the Twenty Control Families

The current edition, **Revision 5**, marks a significant structural change: it **integrates security and privacy controls into a single consolidated catalogue**, rather than treating them as separate concerns. This consolidation reflects the growing recognition that security and privacy are deeply intertwined.

Revision 5 organizes the catalogue into **20 control families**. These families span the full breadth of organizational security and include Access Control, Audit and Accountability, Identification and Authentication, Incident Response, Risk Assessment, System and Communications Protection, and Supply Chain Risk Management, among others. Each family contains the security controls related to its general security topic, and the organization into families exists specifically to ease the control-selection and specification process.

The twenty families, each denoted by a two-letter identifier, are the following:

ID	Family	ID	Family
AC	Access Control	PE	Physical and Environmental Protection
AT	Awareness and Training	PL	Planning
AU	Audit and Accountability	PM	Program Management
CA	Assessment, Authorization, and Monitoring	PS	Personnel Security
CM	Configuration Management	PT	PII Processing and Transparency
CP	Contingency Planning	RA	Risk Assessment
IA	Identification and Authentication	SA	System and Services Acquisition
IR	Incident Response	SC	System and Communications Protection
MA	Maintenance	SI	System and Information Integrity
MP	Media Protection	SR	Supply Chain Risk Management

Within this structure, each control generally includes a **base control**, a **discussion**, **related controls**, **control enhancements**, and **references**. As with the NIST CSF Core, the controls are intended to be

outcome-oriented and adaptable rather than implemented as an identical checklist in every organization—a philosophy consistent across all the NIST instruments.

10.4 The Structure of a Security Control

Each security control in SP 800-53 follows a consistent internal structure composed of five components, and understanding this anatomy is essential to reading and applying the catalogue.

The **Control** section prescribes the specific security-related activities or actions to be carried out by organizations or by information systems. The **Supplemental Guidance** section provides non-prescriptive, additional information that helps interpret and apply the control. The **Control Enhancements** section provides statements of additional security capability that either add functionality and specificity to the base control or increase its strength, for use in higher-risk environments. The **References** section lists the applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidelines relevant to the control. Finally, the **Priority and Baseline Allocation** section provides both the recommended priority codes used for sequencing implementation decisions and the initial allocation of controls and enhancements to the baselines.

This structure can be made concrete with a representative control drawn from the Audit and Accountability family, **AU-3, Content of Audit Records**. Its *Control* statement requires that the information system generate audit records establishing what type of event occurred, when and where it occurred, the source and outcome of the event, and the identity of any individuals associated with it. Its *Supplemental Guidance* clarifies that the content satisfying this requirement may include time stamps, source and destination addresses, user or process identifiers, event descriptions, success or failure indications, filenames involved, and the access-control or flow-control rules invoked. Its *Control Enhancements* add, among others, the capability to generate records containing additional organization-defined detailed information, and the capability to provide centralized management and configuration of the content captured in audit records. Its *References* in this instance are none. Its *Priority and Baseline Allocation* assigns the control priority P1 and allocates the base control AU-3 to the LOW baseline, AU-3 with enhancement (1) to the MODERATE baseline, and AU-3 with enhancements (1) and (2) to the HIGH baseline. This single example demonstrates how the five components work together to move from a terse requirement to a fully specified, risk-calibrated control.

10.5 Baselines: SP 800-53B

The mechanism for selecting controls in a principled way is provided by a **companion document, SP 800-53B**, devoted to the concept of the **security control baseline**. Its aim is to assist organizations in making the appropriate selection of controls for their information systems.

Baseline controls are the starting point for the control-selection process. They are chosen on the basis of the **security category** and associated **impact level** of the information system in question. Three baselines have been identified, corresponding to **low-impact, moderate-impact, and high-impact** information systems. An organization first categorizes its system by impact level and then adopts the matching baseline as its point of departure, afterward tailoring the controls to its specific circumstances.

The baseline concept carries notable **limitations** that bound its general applicability. It is tightly tied to the notion of *federal* information systems and to U.S. legislation, policies, directives, instructions, regulations, and memoranda—more than fifty such instruments in total, all U.S.-based. It is also **very complex** and oriented toward operational personnel rather than strategic decision-makers. These limitations explain why SP 800-53, for all its thoroughness, is best understood as a deeply detailed federal control catalogue rather than a lightweight, universally portable instrument.

A worked scenario clarifies how baselines operate in practice. Suppose an organization runs an internal web application for a federal agency that processes sensitive but unclassified data, where a breach would cause **serious—though not catastrophic—impact** on confidentiality, integrity, or availability. Under FIPS 199, such a system is categorized as **Moderate-impact**. The organization would then turn to SP 800-53B and select the **Moderate security control baseline**, which includes roughly **287 security controls and enhancements** drawn from SP 800-53. From this starting point it would tailor the set to its particular environment.

---

11. Implementation: CIS Controls

The third and final instrument of the implementation layer is the **CIS Controls**, published by the **Center for Internet Security (CIS)**, a U.S. non-profit organization focused on improving global cybersecurity standards and practices. CIS collaborates with experts drawn from industry, government, and academia to develop best practices and guidelines that help organizations secure their IT systems and data against cyber threats. Where SP 800-53 is exhaustive and federal, the CIS Controls are prioritized and pragmatic, designed to tell an organization not merely *what* could be done but *what to do first.*

The CIS Controls are a **prioritized set of actions** designed to help organizations strengthen their cybersecurity posture. Developed by a global community of cybersecurity experts, they provide clear, actionable steps to protect against the most prevalent threats. They are organized into categories and **ranked by effectiveness and ease of implementation**, which makes them exceptionally practical for organizations of every size.

11.1 Design Principles and Structure

Three design principles govern the construction of the CIS Controls. The first is that **offense informs defense**: controls are selected and prioritized using *empirical knowledge* of how attackers actually behave and how their behavior can be stopped. The second is **focus and feasibility**: each safeguard is specific and practical to implement, deliberately avoiding "nice-to-have" or purely theoretical requirements. The third is that the controls are **measurable and aligned**: safeguards are written to be measurable and to align with other frameworks, including the NIST CSF, ISO 27001, OWASP, and MITRE ATT&CK.

Structurally, **CIS Controls v8.1** consists of **18 top-level controls** broken down into **153 safeguards**, each describing a single actionable requirement. The eighteen controls are grouped into three tiers of ascending sophistication. The **Basic Controls (1–6)** cover fundamental cybersecurity measures. The **Foundational Controls (7–16)** cover more advanced security practices. The **Organizational Controls (17–18)** cover the policies and processes that govern security. A defining feature of the scheme is that the **controls are numbered by priority**: the numbering is not arbitrary but reflects the order in which controls should be addressed.

> Cutting across the eighteen controls is a second organizing dimension introduced to sharpen the catalogue: every Safeguard is associated with one of six **asset classes**, which identify the part of the enterprise the Safeguard acts upon. These are **Devices** (enterprise assets such as end-user devices, servers, IoT and non-computing devices, network devices, and removable media), **Software** (applications, operating systems, and their services, libraries, and APIs), **Data** (sensitive data, log data, and physical data), **Users** (the workforce, service providers, and user, administrator, and service accounts), **Network** (network infrastructure and architecture), and **Documentation** (plans, policies, processes, and procedures). Pairing each Safeguard with an asset class makes explicit *what* is being

> protected and allows an organization to reason about coverage across its real inventory rather than against an abstract list.

[Photo: The 18 CIS Controls] The eighteen controls, arranged around a central lock emblem, are: (1) Inventory and Control of Enterprise Assets; (2) Inventory and Control of Software Assets; (3) Data Protection; (4) Secure Configuration of Enterprise Assets and Software; (5) Account Management; (6) Access Control Management; (7) Continuous Vulnerability Management; (8) Audit Log Management; (9) Email and Web Browser Protections; (10) Malware Defenses; (11) Data Recovery; (12) Network Infrastructure Management; (13) Network Monitoring and Defense; (14) Security Awareness and Skills Training; (15) Service Provider Management; (16) Application Software Security; (17) Incident Response Management; and (18) Penetration Testing. The theoretical point conveyed by the arrangement is that the lowest-numbered controls address the most fundamental and highest-priority hygiene—knowing what assets you have—while the higher numbers progress toward advanced and organizational practices.

11.2 Implementation Groups

To make the 153 safeguards usable by organizations of radically different capacity, CIS assigns them to **Implementation Groups (IG)**—IG1, IG2, and IG3—based on an organization's size, risk, and resources.

IG1, described as **basic cyber hygiene**, comprises approximately **56 safeguards** that *every* organization should implement, focused on the most common attack vectors. **IG2 and IG3** progressively add more advanced safeguards for organizations with higher risk, more complex environments, or regulatory obligations.

The IG1 safeguards cover the essentials of defensive hygiene: maintaining an **inventory** of devices and software (Controls 1–2); applying **secure configuration** of systems and applications (Control 4); enforcing **multi-factor authentication** and least privilege for accounts and access (Controls 5–6); performing **patch management and vulnerability management** (Control 7); and sustaining **backup and tested data recovery, basic logging, anti-malware defenses, and awareness training** (Controls 8–14). These are the **first controls to implement** when building or improving a security program, a principle CIS captures in its slogan: **"start with IG1."**



11.3 Mapping to Other Frameworks and the CIS Workflow

A major practical virtue of the CIS Controls is their **interoperability**. CIS Controls v8.1 are mapped to and referenced by multiple legal, regulatory, and policy frameworks, including NIST CSF 2.0, ISO 27001, PCI DSS, SOC 2, and CMMC. The addition of a Govern function and updated mappings in v8.1 improves consistency specifically with the NIST CSF 2.0 functions. The consequence is powerful: an organization can **implement the CIS Controls once and then use the mappings to demonstrate alignment across several governance and compliance regimes** simultaneously, avoiding duplicated effort.

This leads to a recommended **CIS Controls workflow**. First, use the CIS Controls as a prioritized roadmap, starting with the IG1 safeguards and extending to IG2 and IG3 according to the organization's risk profile and regulatory drivers. Second, treat each safeguard as a measurable requirement backed by evidence of both its *design* and its *operation*, rather than as a generic "good practice." Third, use the Controls to structure the organization's security governance, and then plug in the other frameworks—NIST CSF, ISO 27001, the Italian NCF—as overlays and mappings for reporting purposes.

11.4 Benefits of the CIS Controls

The advantages of the CIS Controls follow directly from their design. They offer **prioritized, actionable steps**, focusing effort on the most impactful risk-reduction measures. They deliver genuine **attack-surface and risk reduction** by directly targeting common attack vectors such as unmanaged assets, misconfigurations, missing patches, and weak access control. Through IG1 they establish an **essential cyber-hygiene baseline** that provides a realistic minimum program for an organization of any size. They enable the **efficient use of limited resources**, helping allocate scarce budget and staff to the highest-value controls first. They provide **multi-framework alignment**, mapping cleanly to NIST CSF, SP 800-53, ISO 27001, PCI DSS, and HIPAA, which eases compliance. And they constitute a **widely recognized "reasonable" standard**, used globally and increasingly cited by regulators and insurers as evidence of due diligence.

11.5 Treating the WannaCry Risk

The CIS Controls bring the WannaCry narrative to its operational conclusion. Having, through the earlier frameworks, *identified* the central risk—that unpatched Windows systems could be exploited and cause widespread compromise—and having *decided* that the risk must be treated, the security team faces the final, concrete question: which controls to actually implement, given a single month in which to act.

The appropriate measures are precisely those drawn from the prioritized CIS hygiene: a **formal patch-management process**, a complete **asset inventory**, **network segmentation**, and **vulnerability scanning**. These directly dismantle the conditions that made the attack possible. By contrast, measures such as a new company logo or an annual security presentation, whatever their other merits, do nothing to reduce the technical risk at hand and would be mis-prioritized responses to the threat.

A final and subtle lesson concerns the difference between *claiming* a control and *evidencing* it. Suppose the organization asserts that it performs vulnerability scanning regularly. What would actually convince an auditor that this control is implemented? Statements such as "we have a vulnerability-management policy," "the CISO says scanning is performed," "a scanner is installed," or "the vendor says the scanner works" are all insufficient, because a policy is not its execution, an assertion is not proof, and an installed or vendor-endorsed tool is not evidence of operation. What genuinely demonstrates the control are **scan reports from the last six months** together with **evidence that identified vulnerabilities were assigned and remediated**. This distinction—between the *design* of a control and its demonstrable *operation*—is the heart of auditability, and it is exactly the discipline whose absence allowed a known, patchable vulnerability to bring hospitals to a standstill.

CHAPTER 3: Risk Management

An Introduction to Risk Management

Security governance rests on a simple but demanding idea: an organization must be able to decide, deliberately and repeatedly, what could go wrong, how badly, and what to do about it. Everything technical — firewalls, patches, access controls — is downstream of that decision-making. This chapter

builds the conceptual machinery that makes those decisions disciplined rather than improvised, beginning with the vocabulary of risk, moving to what it means to *manage* risk as a continuous organizational function, and then settling on the reference standard that structures the whole activity, **ISO 31000**, with its three interlocking layers of principles, framework, and process.

1. What Is Risk?

Informally, a **risk** is the potential that something goes wrong and thereby causes harm or loss. That intuition is correct but useless for analysis, because it cannot be measured or compared. The working definition is sharper: a risk is **the likelihood of an incident combined with its consequence for an asset**. Risk is therefore not a single quantity but a *pairing* — how probable an unwanted event is, weighed against how much damage it would do to something we care about.

Each term in that definition is itself a precise object.

An **asset** is anything of value to a party. The crucial word is *anything*. When an organization is dissected for the purpose of risk analysis, it is a mistake to count only the tangible, material elements — servers, buildings, money. Intangible assets are frequently the most valuable and the most fragile. **Reputation** is the canonical example: if word spreads that a hospital suffered a serious incident, patients lose trust and avoid it, and that loss of trust can outweigh any direct physical damage. The analyst must therefore enumerate *all* the elements that contribute to the construction and standing of the company, not just the ones that appear on an inventory.

A **party** is the organization, company, person, group, or body on whose behalf the risk assessment is conducted. From the standpoint of risk treatment, the party is simply *whoever is interested in performing the analysis* — it could be a single department or the entire company. Identifying the party is not a formality: it fixes the **boundary** of the analysis, drives which assets are relevant, and shapes how those assets are classified. Change the party, and the very list of assets changes with it. The same physical system looks like a different problem depending on who is asking.

An **incident** is an event that harms or reduces the value of an asset — any event producing damage, disruption, or loss. An incident is never considered in the abstract: it is always related back to the assets it touches.

A **likelihood** is the chance of something occurring — a measurement of the probability of an event happening. In practice it is an analysis of all the events that could lead to a given incident actually manifesting.

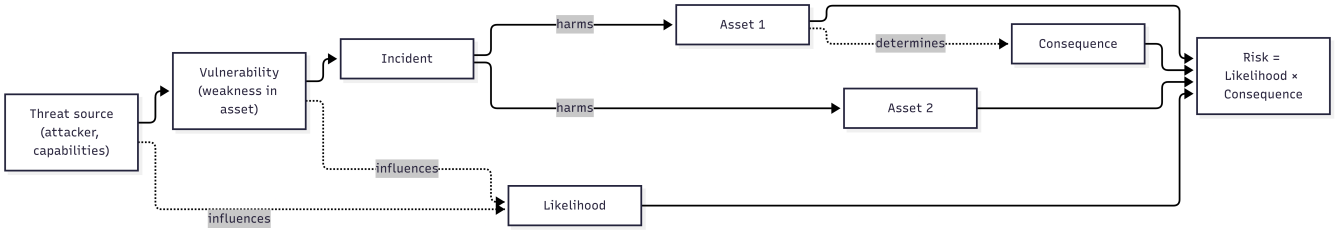
A **consequence** is the impact of an incident on an asset, expressed as harm or reduced asset value.

Putting these together: for every incident, we relate it to the assets it could affect; for each such asset we estimate the **probability** the incident happens and the **consequences** it would produce; and from the estimation of likelihood and impact we derive the **risk** on that asset.

1.1 Why Risk Management Is Hard: the web of relationships

The definitions hide a structural difficulty. There is a list of assets. For each asset there is a list of incidents — but a single incident may harm several different assets at once. For every incident the likelihood and consequence are not free parameters; they depend on the **vulnerability** present in the asset and on the **type of attacker** that wishes to exploit it, since not all attackers possess the same capabilities. The result is a dense, many-to-many (N–N) network of relationships in which every factor influences the others and much of the behaviour is, from the analyst's seat, effectively random. Managing

risk is therefore not a trivial bookkeeping task; it is the disciplined handling of this tangled, uncertain web.



2. What Is Risk Management?

Risk management comprises the coordinated activities used to direct and control an organization with regard to risk. In governance terms, managing risk is nothing other than implementing the **direct-and-control loop** with risk as its subject: a structured set of processes that lets us evaluate risks, mitigate them, and then monitor the effects of the mitigation to verify that the intervention produced the intended outcome.

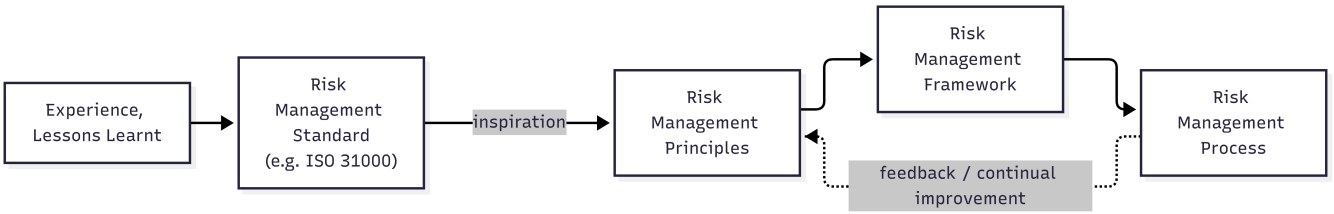
A risk management process is only worth running if it satisfies three joint requirements, which recur throughout the discipline:

- **Adequate** — the process must fit the specific company under assessment. There is no single fixed process valid for every organization; it must be sized and shaped to the context, matching the available resources and the outcomes that matter.
- **Efficient** — it must evolve smoothly across the life of the company without blocking normal activity or being intrusive. A process that grinds the business to a halt defeats its own purpose.
- **Effective** — we must be able to *quantify* the benefit the process brings. If the effect cannot be measured, the loop cannot be closed.

These requirements have a hard economic edge. Performing an assessment has a real cost: the people who perform it, the people who must step away from their normal work to supply information to the assessors, and possibly third parties contracted to run part of the process. For the whole exercise to be justified, it must ultimately yield a **positive return** — the value protected or created must exceed the cost of protecting it. Note that "value creation" here is not merely monetary: preventing damage, avoiding the expense of handling an incident, and preserving reputation are all forms of value, even when they never appear directly as revenue.

2.1 Where processes come from: the inspiration pyramid

A company does not invent its risk management process from scratch each time. The process is customized, but the customization starts from something. The chain of inspiration runs as follows: **standards** encode accumulated experience and lessons learnt; from standards come **risk management principles**; principles inspire a **framework**; and the framework is what allows an organization to design its concrete **process**. Feedback flows back up the chain — once a process is running, it is observed to check whether it remains adequate, efficient, and effective, and wherever something is unclear or not working, the process is understood and improved.



3. A Standard for Risk Management: ISO 31000

The first and most general standard in this space is **ISO 31000**. It is a *generic* standard for the risk management process: it does not confine itself to cyber risk but addresses risk of every kind. Inside it is the description of the main sub-processes — working in synergy — that an organization must embrace to speak meaningfully of managing risk. It can be applied at every moment in the life of an organization: when the processes are first designed, during everyday operation, and whenever something changes in the scope or business of the organization. It can be applied to any activity, including decision-making at all levels.

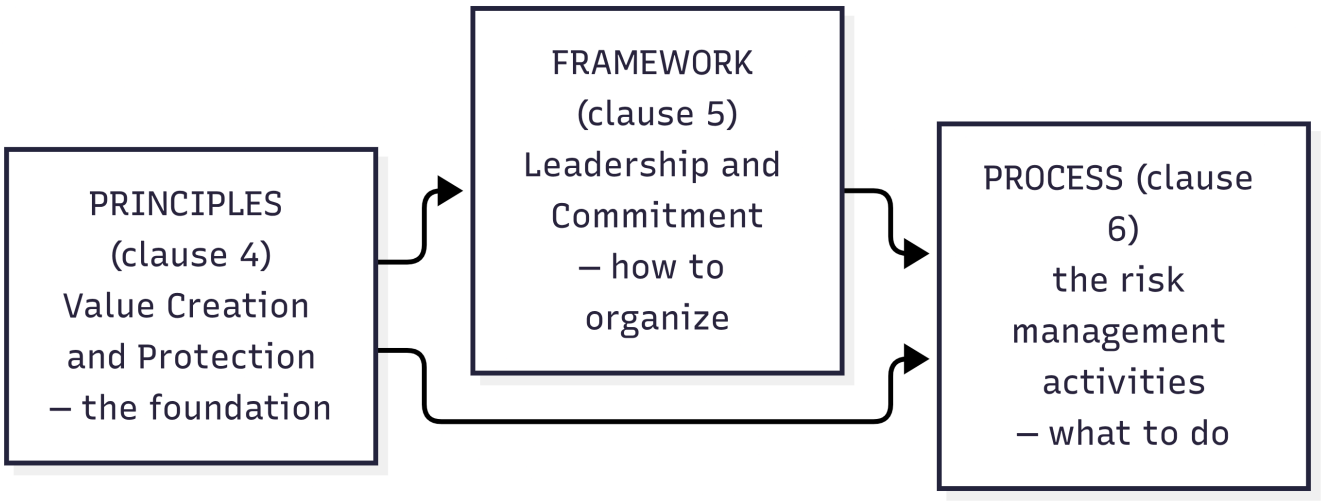
Several properties define its character:

- **It cannot be used for certification.** ISO 31000 is a *recommendation* — it states the principles and the set of activities an organization should design and implement, and it provides guidance for internal or external audit programmes, but a company cannot be "ISO 31000 certified."
- **It is customizable to any organization and its context**, and it is **not industry- or sector-specific** — it offers a common approach to managing any type of risk.
- **It is international.** As part of the ISO family, it serves as a shared benchmark: an organization can compare its own risk management practices against an internationally recognised reference, which also makes it an instrument for understanding the risk *posture* of another company.
- Its **last release is 2018**.

The standard's content is organized into three tightly related parts, each corresponding to a clause and each depicted as one of three interconnected wheels:

1. **Principles (clause 4)** — the base ground, the big ideas that must be kept in mind when identifying the activities of the process.
2. **Framework (clause 5)** — how the organization structures itself, with deadlines and responsibilities, to support the process cycle.
3. **Process (clause 6)** — the concrete sub-processes to be implemented.

The principles are the foundation over which everything is built; the framework tells us *how* to design the sub-processes; and the process is the set of activities themselves. One cannot design any sub-process without a framework telling us how to do it, and one cannot build a sensible framework without the principles underneath.



4. ISO 31000 — Principles (Clause 4)

The principles are drawn as a wheel: one central hub surrounded by eight spokes. The hub is the overriding purpose, and the spokes are the qualities every good risk management effort must display.

4.1 The hub: Value Creation and Protection

At the centre sits **Value Creation and Protection**. The main objective of risk management is always to protect what represents value for the company and to increase that value as far as possible — putting in place actions that prevent damage from occurring and thereby avoid the expenses of dealing with incidents. As stressed earlier, value is not only money: indirect value such as reputation counts, and although an improved reputation is not itself revenue, revenue tends to follow it as a side effect. The task is to deploy all the instruments that strengthen the processes bringing value to the organization.

4.2 The eight principles

Surrounding the hub are eight principles. Each answers the question: *what must be true of the risk management effort for it to actually serve value creation and protection?*

Integrated. Risk management is an integral part of *all* organizational activities. It must not run as a side effect of the real work, nor as a bolt-on; it works in synergy with everything the company does, and data collection in particular must be woven into the way the company operates. Integration is also what makes risk management **non-intrusive and transparent** — the two are only achievable if the processes are genuinely embedded. The practical importance of integration is easy to see through an example: imagine a machine running software on an operating system riddled with vulnerabilities. The obvious move is to eliminate the vulnerabilities, perhaps by buying and installing a new OS. But doing so may break compatibility and leave the whole system non-functional. One can only foresee and weigh this trade-off if the risk process is integrated with knowledge of how the system actually works — otherwise a "fix" becomes a new incident.

Structured and Comprehensive. A structured and comprehensive approach contributes to consistent and comparable results. The organization should not improvise a new method each time; it needs an internal, repeatable methodology. The reason is the direct-and-control loop: different iterations of the process must be **comparable**, otherwise it is impossible to tell whether the loop is succeeding. Comprehensiveness also means not restricting attention to the technical layer alone — the roles people hold and the business aspects must be included.

Customized. The framework and processes are tailored and proportionate to the organization's external and internal context and to its objectives. No approach works in every company unchanged, because each company's context differs; one starts from the general principles and then performs the customization.

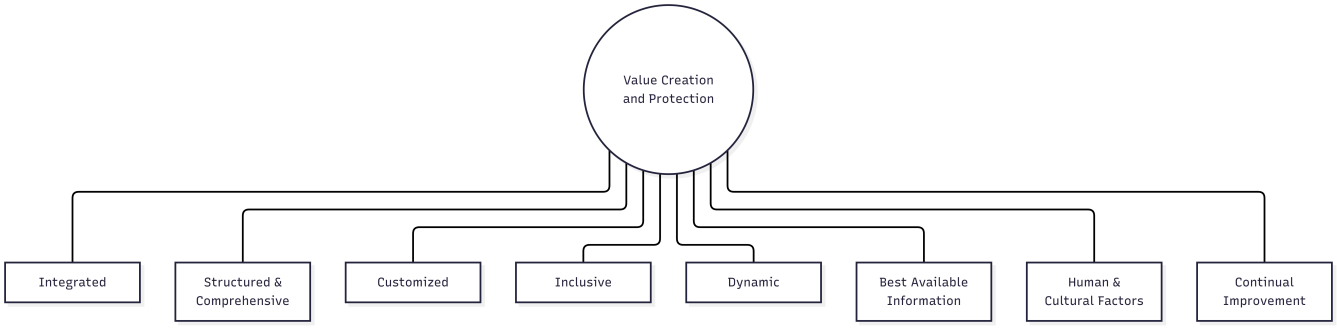
Inclusive. Involving stakeholders increases awareness and leads to better-informed risk management. All the stakeholders with an interest in the assessment should be considered and brought in.

Dynamic. Risks and context are not static — the system evolves, and the process must follow the changes, both internal and external. Changes must be anticipated and managed in an appropriate and timely manner.

Best Available Information. Information and uncertainty are the base for all risk management activities. An assessment is an *estimation* made to support decision-making, so the decisions must rest on the best information available — information that is timely, clear, and available to the relevant stakeholders. A clear view of the situation is only possible with the most accurate information obtainable.

Human and Cultural Factors. Human and cultural factors influence all aspects of risk management. The human context itself matters, because there are behaviours that shape how people actually carry out the work, and these must be taken into account rather than assumed away.

Continual Improvement. Risk management is improved continually through learning and experience. The process should keep evolving toward its best possible form.



5. ISO 31000 — Framework (Clause 5)

If the principles say *why* and *what qualities*, the framework says *how the organization arranges itself* so the process can run and keep running.

Purpose. The framework exists to assist the organization in integrating risk management into its significant activities and functions.

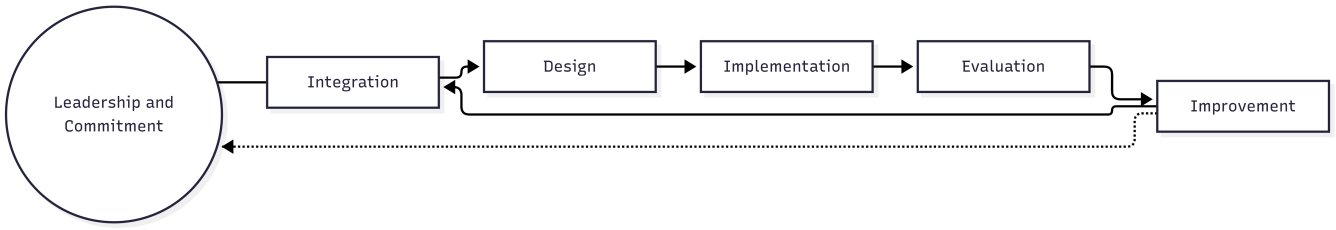
Effectiveness. The effectiveness of the framework depends on how well it is integrated into the **governance** of the organization, including its decision-making. Risk management that sits outside governance is ornamental; embedded in governance, it shapes real decisions.

Customization is needed. As with everything in ISO 31000, the framework is not taken off the shelf unchanged — it must be customized to the organization.

The framework is again drawn as a wheel, with a hub and five surrounding elements. The hub is **Leadership and Commitment**: the framework only works with an explicit endorsement from top management, which assigns roles and responsibilities to people inside the company. Without that endorsement, the process has no authority and no owners. The five surrounding elements form a cycle around it:

- **Integration** — embedding risk management into the organization's structure and activities.
- **Design** — designing the framework appropriately for the context.
- **Implementation** — putting the designed framework into operation.
- **Evaluation** — assessing whether the framework is performing as intended.
- **Improvement** — refining the framework continually based on what evaluation reveals.

Together these support the normal process cycle, continually looping back through leadership and commitment at the centre.



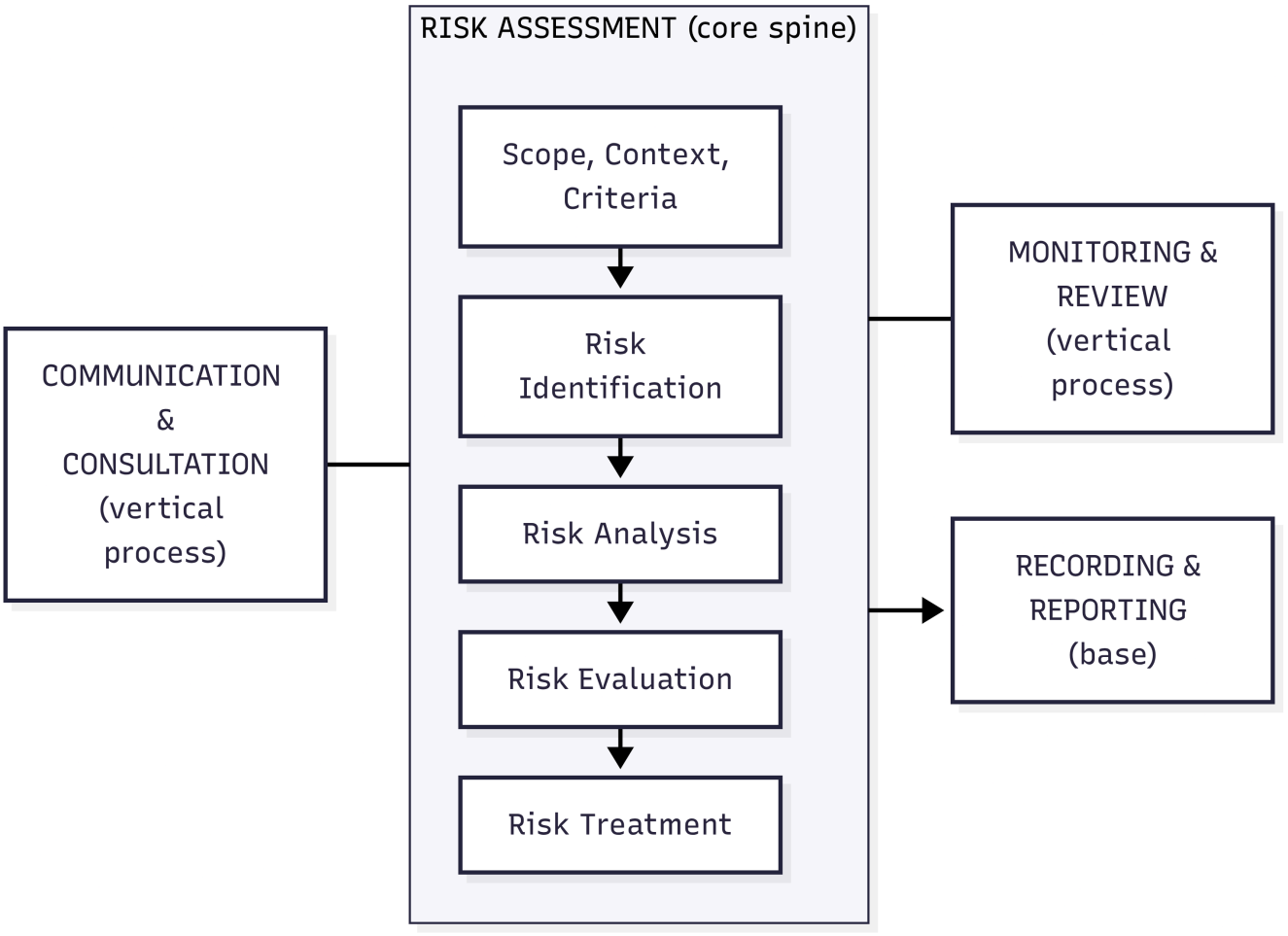
6. ISO 31000 — Process (Clause 6)

The process clause suggests how to structure the concrete processes involved in risk management. It is drawn as a single circle whose internals reveal its anatomy: a vertical spine of core activities flanked on the left by **Communication and Consultation**, on the right by **Monitoring and Review**, and resting on a base band of **Recording and Reporting**. The whole picture decomposes into a small number of sub-processes that are deliberately interconnected and integrated — none stands alone.

At the top level, the general process is composed of **three main sub-processes**:

- **Communication and Consultation** — the activities aiming to provide, share, or obtain information and to interact with stakeholders regarding the management of risk. This is everything describing *how communication happens*: the management of all the information flowing behind the risk assessment, every way of acquiring and transferring information between the people involved.
- **Risk Assessment** — the activities aiming to understand and document the risk picture for specific parts or aspects of a system or organization. This is the analytical core.
- **Monitoring and Review** — checking the current status to identify deviations from the expected one, and determining the effectiveness of the risk management process, framework, risks, and treatments. It gathers data from the *process's own* point of view and supports continual improvement.

Communication and Monitoring are often called **vertical processes** because they run alongside the entire assessment, flanking it from start to finish; the assessment itself is the central spine. Beneath everything sits **Recording and Reporting**, which documents what was done and its outcomes.



7. Communication and Consultation

This sub-process supports all the information management behind the assessment. Efficient and adequate communication and consultation support **awareness** throughout the organization, and the sub-process may concern any part or activity of the overall risk management effort. It is realized through **four main activities**, in sequence.

7.1 Establish a Consultative Team

The first activity is to identify everyone who provides a contribution to the process and assemble them into a **consultative team** (or, in a small company, a single responsible person) with clearly defined responsibilities. The team participates in the process and supplies the knowledge that feeds it; it must therefore include **experts who know where to retrieve the relevant information**. Typically it includes internal stakeholders — decision makers, risk managers, employees with insight into the organization, board members, and customers — and it must also incorporate **stakeholders who provide information from the external domain**.

Two practical constraints matter. The team must **not be too large**, or reaching consensus becomes unworkable; depending on the company, up to around ten people is a reasonable ceiling. And the **roles and responsibilities** of each member must be clearly defined and specified.

7.2 Define a Plan for Communication and Consultation

The consultative team (or the responsible party) should itself help define the plan and the procedures. The point is to fix *how* communication happens rather than leaving it ad hoc — not one day by email, the next by phone call, in an improvised fashion. The organization establishes procedures for supporting any of the overall risk management processes, ensuring for example that different areas of expertise are

brought together during assessments, that the interests of all relevant stakeholders are considered, that the risk evaluation criteria are appropriate, and that decision-making is informed. The plan must be **shared**, and its criteria checked for appropriateness to the type of assessment being performed.

7.3 Ensure Endorsement of the Risk Management Process

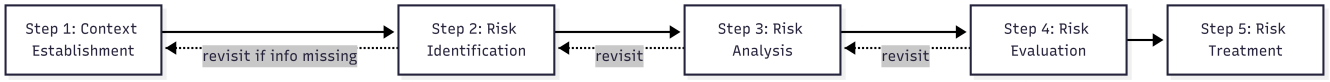
Good communication and consultation procedures help secure **endorsement of and support for** the risk management process. This requires the approval of top management and, just as importantly, a **common agreement and mutual understanding** of how risk should be managed across the people who must do the work.

7.4 Communicate Risk Assessment Results

Once the assessment is performed, its results must be communicated — not only to the parties directly related to the assessment but to all relevant parties in the organization, so that people can adapt their behaviour to the risks (the awareness objective). Communicating results serves concrete ends: it can demonstrate **policy adherence or compliance** with directives and regulations, and it **justifies treatment plans**, including the resources required for mitigation. By letting those with a vested interest understand the basis on which decisions were made and why particular actions are required, communication in turn helps ensure endorsement of the **risk treatment plans** from key stakeholders.

8. Risk Assessment

Risk assessment is the analytical heart of the process, and ISO 31000 divides it into **five steps**: Context Establishment, Risk Identification, Risk Analysis, Risk Evaluation, and Risk Treatment. Typically this runs as a **linear** progression — identify the context, then identify risks, analyse them, evaluate them, and treat them. But because the process must remain adequate, efficient, and effective, every step is carried out while holding all relevant information in view; if at some point the information proves insufficiently accurate, or something is discovered to be missing from an earlier phase, the analyst **goes back and redoes** the affected step. The linearity is the default path, not a prohibition on iteration.



8.1 Step 1 — Context Establishment

Goal: identify and describe the context of the risk assessment. The first task is to identify and document the context relevant to the assessment, split along two perspectives:

- **External Context** — the description of the societal, legal, regulatory, and financial environment and of the relationships with external stakeholders. Here we capture all the factors that influence the organization from the outside: regulations, and any **legal requirements** we must satisfy.
- **Internal Context** — the description of the relevant goals, objectives, policies, and capabilities that may determine how risk should be assessed. These are the specific details of what happens inside the company.

In both directions we must list all the **constraints** — those coming from outside and those arising inside. Then the goals and objectives of the assessment itself must be defined, which requires the **participation of decision makers**.

Context establishment is built on three sharp distinctions plus an explicit statement of assumptions:

- The **target of assessment** is the parts and aspects of the system that are the subject of the risk assessment.
- The **scope of the assessment** is its extent or range — it **defines what is held inside and what is held outside** the assessment, that is, the **boundaries**.
- The **focus of the assessment** is the main issue or central area of attention: the **identification and documentation of the assets** with respect to which the assessment is conducted. The focus is a *refinement within* the scope — one narrows from the broad range down to the specific assets and the specific risk dimensions that matter. For one asset we might care only about confidentiality; for another, about accountability; and so on.
- **Assumptions** are the things taken for granted or accepted as true about the system in question. Stating them explicitly keeps the analysis honest and prevents hidden premises from distorting the result.

The output of this step is a **context description**, which is the input to the rest of the assessment. It must contain, in order: (1) **identification of the party** involved in the assessment — from the party we derive the focus and the target, and from there the assets; (2) the **declaration of assumptions**; (3) the identification of the **relevant assets** for the assessment (the focus) — here a methodology is used to distinguish **primary assets from secondary ones**, which requires a **dependence analysis**; (4) the definition of **risk scales** for consequences and likelihoods — these can be quantitative or qualitative, continuous, discrete, or given as intervals; and (5) the **risk evaluation criteria**, the terms of reference by which the significance of a risk is judged. Fixing the criteria means deciding how many levels the **risk matrix** will have and where the boundaries of each column lie — the combination of the two scales that yields the final risk level. Doing all of this rigorously guarantees the subsequent analysis is **fair** and not merely swayed by whatever is most visible in the environment. Once the boundary of the analysis is known, the analysis of the risks can begin.

8.2 Step 2 — Risk Identification

Risk identification is the set of activities aiming to identify, describe, and document risks and their possible causes. Two observations frame it.

Observation 1: a risk is always associated with an incident. There is no free-floating risk; every risk is anchored to a specific unwanted event.

Observation 2: there are three elements without which there can be no risk — Asset, Vulnerability, and Threat. Remove any one and risk vanishes:

- **Without an asset there is nothing to harm.**
- **Without a vulnerability there is no way to cause harm.** If an asset faces a threat but holds no vulnerability, the incident cannot materialise — and if there are no vulnerabilities, no time should be spent. In the cyber domain this reasoning is treacherous, because unknown vulnerabilities (**zero-day vulnerabilities**) may exist even when none are visible.
- **Without a threat there are no causes of harm.** An asset may be genuinely vulnerable, yet if nothing is trying to harm that vulnerability, no risk arises.

This yields a precise terminology that must be read as a chain:

- A **threat source** is the potential cause of an incident (the attacker, the actor).
- A **threat** is an action or event, caused by a threat source, that may lead to an incident.

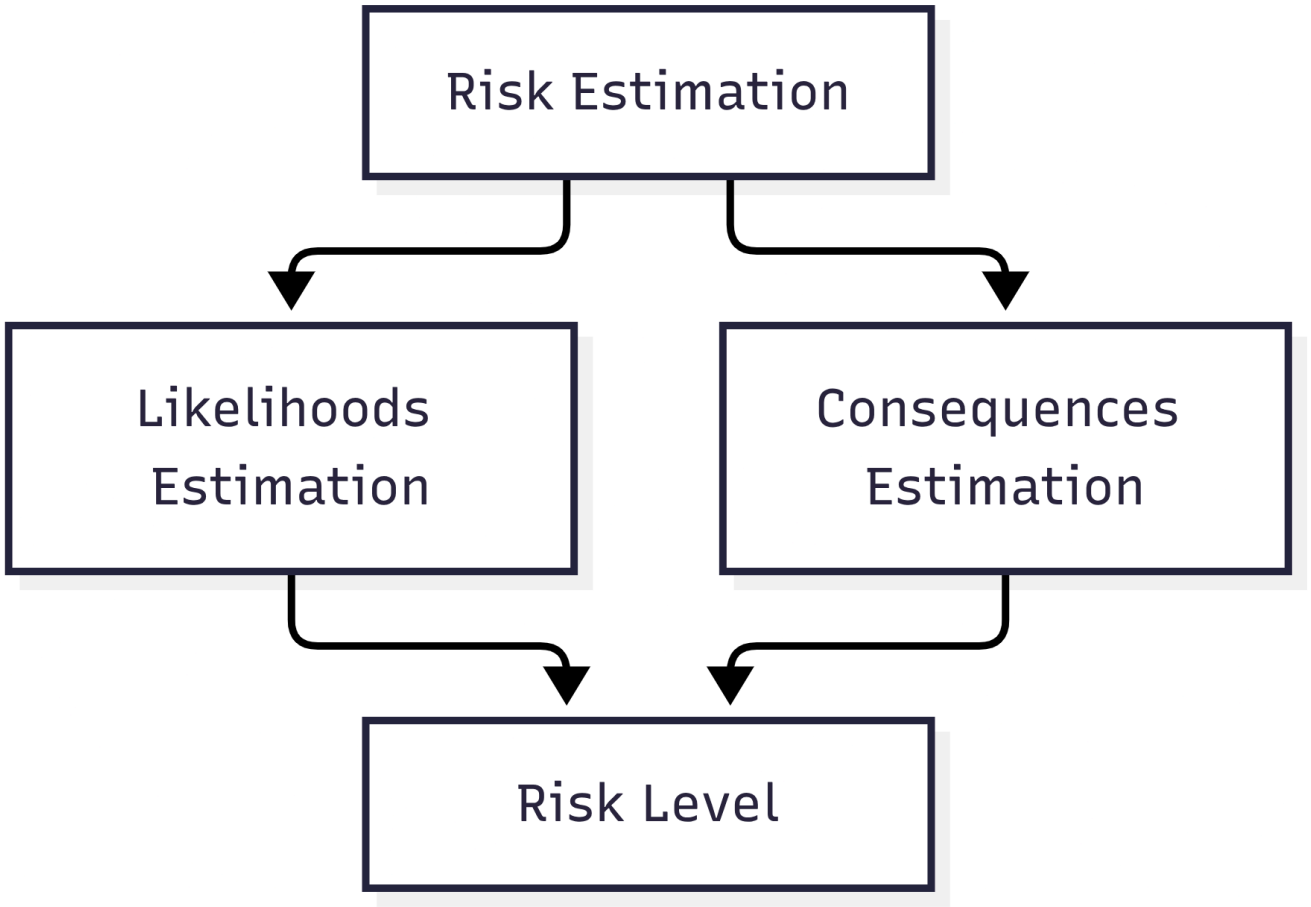
- A **vulnerability** is a weakness, flaw, or deficiency that can be **exploited** by a threat to cause harm to an asset.
- When a threat exploits a vulnerability, it **leads** to an incident, and the incident on a valued asset is the **risk**.



The scope of identification is therefore to work *with respect to the identified assets* by (1) identifying the **threats** and (2) understanding how those threats may lead to incidents — and thereby to risks — by **exploiting vulnerabilities**. Operationally: find all the possible open doors (vulnerabilities), then all the potential actors interested in entering (threat sources and their threats), and then draw the links showing how an attacker could materialise a threat by exploiting a vulnerability. A single vulnerability may translate into **several different threats**. Every such element must be analysed, because all of them feed the later estimation of likelihood.

8.3 Step 3 — Risk Analysis

Risk analysis is the activity aiming to estimate and determine the level of the identified risks. Its governing observation: the **risk level is derived from the combination of likelihood and consequence**. The composite activity, **Risk Estimation**, is precisely the sum of two estimations — **Likelihoods Estimation** plus **Consequences Estimation**.



Likelihoods Estimation determines the frequency or probability of incidents occurring, using the likelihood scale defined during context establishment. It requires techniques for gathering empirical data, and many risk-modelling techniques — **Bayesian networks, attack trees, and CORAS diagrams** — support both the estimation and its documentation. The practical aim is to understand how risks are

most likely to arise and which threat sources matter most: one tries to estimate the likelihood that **threat sources initiate threats**, and then the likelihood that **those threats lead to incidents**. The natural approach formalises everything as a probability, estimating the aspects behind each vulnerability; the difficulty is that the factors are many and often hard to quantify.

Consequences Estimation rests on a key recollection: **an incident represents one risk for each of the assets it harms**, so the consequence must be estimated separately for *each* affected asset. The focus shifts to what the incident actually means for a given asset, measured on the appropriate scale. The estimation should be performed by a **walk-through of all identified incidents**, assigning estimates with the involvement of personnel who represent the party — or someone who can judge consequences on its behalf. Bridging all the layers is essential: one must consider the infrastructure, the people working, and what happens if a specific part stops functioning. In complex systems a failure at one point can cascade into failures elsewhere, producing a **domino effect**, and the analysis must try to capture this propagation.

8.4 Step 4 — Risk Evaluation

Risk evaluation is the set of activities that compares the risk analysis results against the risk evaluation criteria to determine which risks should be considered for treatment. Given the estimates and criteria the step is largely straightforward — it is where risks are placed into the **risk matrix** and prioritised for treatment — but four sub-steps structure it:

1. **Consolidation of risk analysis results.** Look at each risk individually, revisit its analysis, and plug it into the risk matrix, whose two dimensions are likelihood and consequence crossed to find the correct cell. Special attention goes to the estimates we are **uncertain** about, where that uncertainty casts doubt on the actual risk level.
2. **Evaluation of risk level.** For each risk, judge whether the level — and the amount of error we can tolerate in it — is acceptable. This is the moment to decide whether to **go back to the analysis phase** to revisit a shaky estimate.
3. **Risk aggregation.** Investigate whether certain sets of risks should be aggregated and evaluated as a single risk. The purpose is to **avoid accepting a set of risks that are individually non-critical yet unacceptable in combination.** Two natural aggregation points: several separate incidents that harm the **same asset**, and distinct incidents that share the **same threat source**.
4. **Risk grouping.** Group risks that have elements in common — most usefully, risks that **share a common mitigation** — so they can be treated together.

The output is a prioritised list of risks handed to the treatment step, which decides what to do with them.

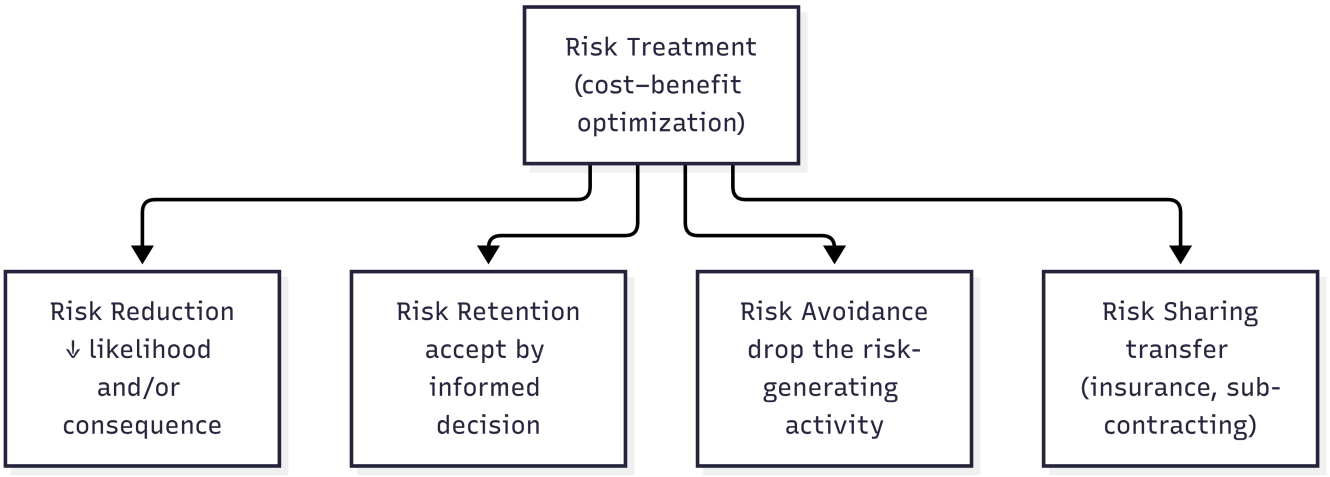
8.5 Step 5 — Risk Treatment

Risk treatment is the set of activities aiming to identify and select the means for risk mitigation and reduction. The guiding idea is that one should in principle seek to treat every **unacceptable** risk — but in the end this is always a question of **cost and benefit**, regardless of the nominal risk level. If a low, acceptable risk is very cheap to eliminate, we might eliminate it anyway; if the cost of treating a very high risk is unbearable, there may be no option but to accept it. In the real world we rarely have a fixing strategy for every risk, because of constraints on time and budget — so treatment is in effect an **optimization problem**: reduce the overall level of risk as much as possible given the resources available. We work on the risks aggregated by group, finding for each group a suitable set of mitigation actions.

Because treatment can have side effects, the activity must involve both the **identification and the analysis** of treatments: some treatments **create new risks**, and some groups of treatments **reduce each other's isolated effect**, so their interactions must be weighed rather than each treatment judged alone.

There are **four main options** for treating a risk:

- **Risk Reduction** — take the factors defining the risk and put in place actions that reduce the **likelihood and/or the consequence** of incidents (one or both).
- **Risk Retention** — accept the risk by an informed decision.
- **Risk Avoidance** — avoid the activity that gives rise to the risk altogether; sometimes the only option for an unacceptable risk.
- **Risk Sharing** — transfer the risk, or part of it, to another party, for example through insurance or sub-contracting.



9. Monitoring and Review

Monitoring is the continual checking, supervising, critically observing, or determining of the current status in order to identify deviations from the expected or required status. **Review** is the activity of determining the suitability, adequacy, and effectiveness of the risk management process and framework, as well as of the risks and their treatments. Together they apply at four levels: the underlying **risk management framework**, the **risk management process**, the **identified risks**, and the **measures** the organization implements to treat those risks.

The main purposes of the Monitoring and Review process are to ensure that controls remain effective and efficient; to obtain further information that improves the risk assessment; to analyse and learn lessons from incidents, changes, trends, successes, and failures; to detect changes; and to identify emerging risks.

9.1 Monitoring and Review of Risks

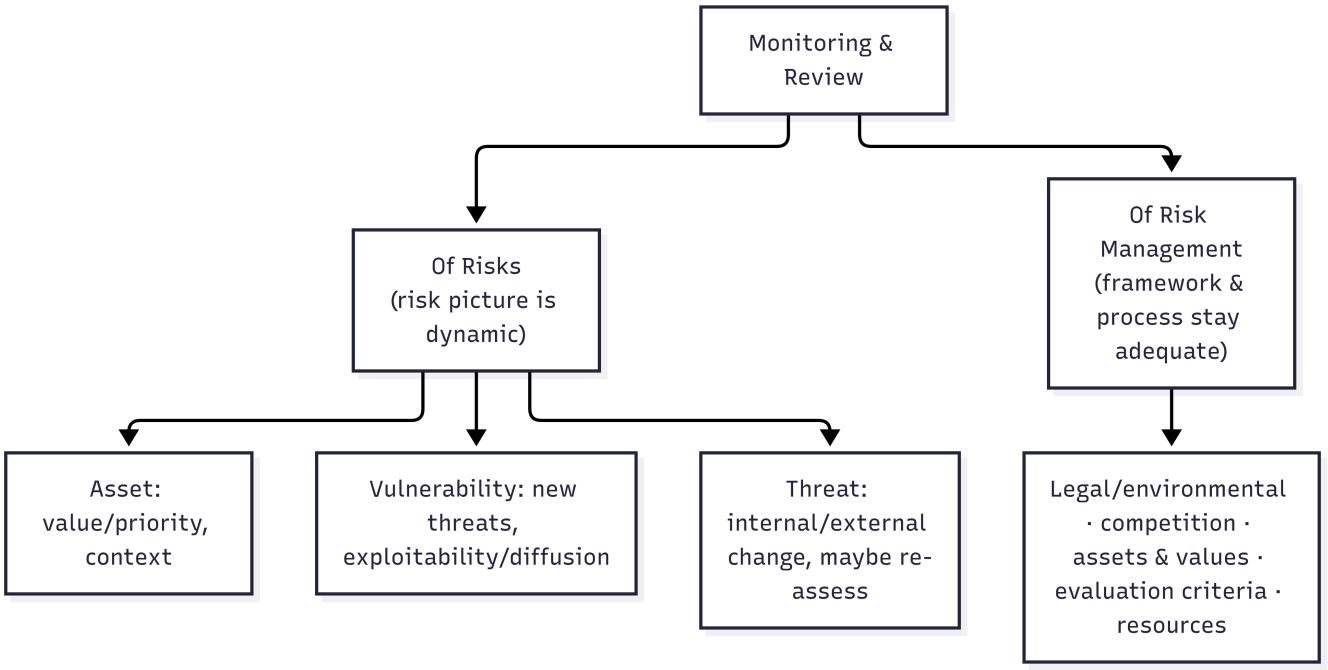
Risks are **not static** and must therefore be monitored and reviewed; this monitoring serves as the basis for taking action — modifying the risk picture or conducting new assessments. The monitoring maps directly onto the three irreducible elements of risk:

- **Asset** — check for changes in asset **value or priority over time**, and in the internal or external **context**.
- **Vulnerability** — check for vulnerabilities that could potentially be exposed to **new threats**, and for changes in vulnerability **parameters** such as exploitability and diffusion.

- **Threat** — check for internal or external changes; sometimes new threats can be observed directly, while sometimes a **new risk assessment** is needed to surface them.

9.2 Monitoring and Review of Risk Management

Beyond the risks themselves, the **risk management apparatus** must be monitored. The reason — *why* monitor the process and framework — is to ensure that the framework, the process, and all related activities, procedures, roles, and responsibilities remain **relevant, appropriate, and adequate** for the organization. What should be monitored are the changes in internal or external context that may affect that adequacy, including the **legal and environmental context**, the **competition context**, the **assets and their values**, the **risk evaluation criteria**, and the **resources required** for adhering to the risk management framework.



CHAPTER 3_bis: Risk Management pt. 2

The previous chapter built the general theory of risk management on a deliberately neutral footing: the definitions of asset, incident, likelihood, consequence, and the ISO 31000 machinery of principles, framework, and process apply to *any* kind of risk. Financial risk, operational risk, and physical risk all share the same skeleton — a risk is always associated with an incident, which is associated with an asset, and to evaluate its probability and consequence we must understand the relation between the asset, the vulnerability, and the threat that materialises the incident over that asset. Nothing in that structure is specific to computers. The present chapter asks what changes when the risk lives in the **cyber domain**, and the answer is not that the theory changes but that each step becomes harder, larger, and more adversarial — hard enough to demand specialised procedures, catalogues, and scoring systems of its own.

1. Cyber-Systems and the Cyber Domain

To speak precisely about cyber-risk, three nested definitions are needed.

A **cyberspace** is a collection of interconnected computerized networks — including services, computer systems, embedded processors, and controllers — together with the information held in storage or in transit across them. Informally, it is everything we put into operation using digital information to support the business processes of an organization: the networks, software, and hardware that connect everything, and crucially the **information** that flows over them. The emphasis on information rather

than mere data is deliberate: a cyberspace carries not only raw data but the information that can be *inferred* by correlating that data.

A **cyber-system** is a system that makes use of a cyberspace. It is, in other words, a system built on top of the cyberspace — anything digital that requires data, that allows information to be transferred, and that at its lowest level rests on the network, software, and hardware tying the pieces together.

A **cyber-physical system** is a particular, important class of cyber-system: one that **controls and responds to physical entities through actuators and sensors**. These systems bridge the digital and the physical world. They have a digital component — the network and control infrastructure — but also a genuine physical component that they monitor and act upon. The canonical examples are the critical infrastructures that control physical services: a **water distribution network** or an **energy distribution network** (the electrical grid), controlled remotely through monitors and actuators that modify the service in the physical world. A failure or attack here does not merely corrupt data; it can stop water or electricity from flowing.

2. Cyber-Security and Cyber-Threats

Cybersecurity is the protection of cyber-systems against cyber-threats. The definition narrows the universe of adversaries: a **cyber-threat** is a threat that **exploits a cyberspace**. We are therefore restricting attention to those who inject problems *through* the cyberspace, rather than to threats of every conceivable origin.

Within this restricted universe, cyber-threats split into two classes, and the distinction organizes the entire rest of the chapter:

- **Malicious** threats are caused by **intention** — raised by an attacker who deliberately wants to create damage to an infrastructure. Denial-of-service (DoS) attacks and injection attacks are typical examples. A crucial observation sets the cyber domain apart from ordinary life: in a normal, non-cyber scenario the number of malicious actors is small relative to the number of benign ones, whereas in cyberspace malicious actors are abundant and may sit anywhere in the world.
- **Non-malicious** threats are **accidental** — things that happen without intent, through mistakes, configuration errors, programming defects, or environmental factors. Examples include a crash due to a programming error, or the loss of an Internet connection because of wear and tear of communication cables or other hardware.

2.1 Cybersecurity versus Information Security

Cybersecurity and **information security** are closely related but not identical, and the relationship is best seen as two overlapping circles with a large intersection.

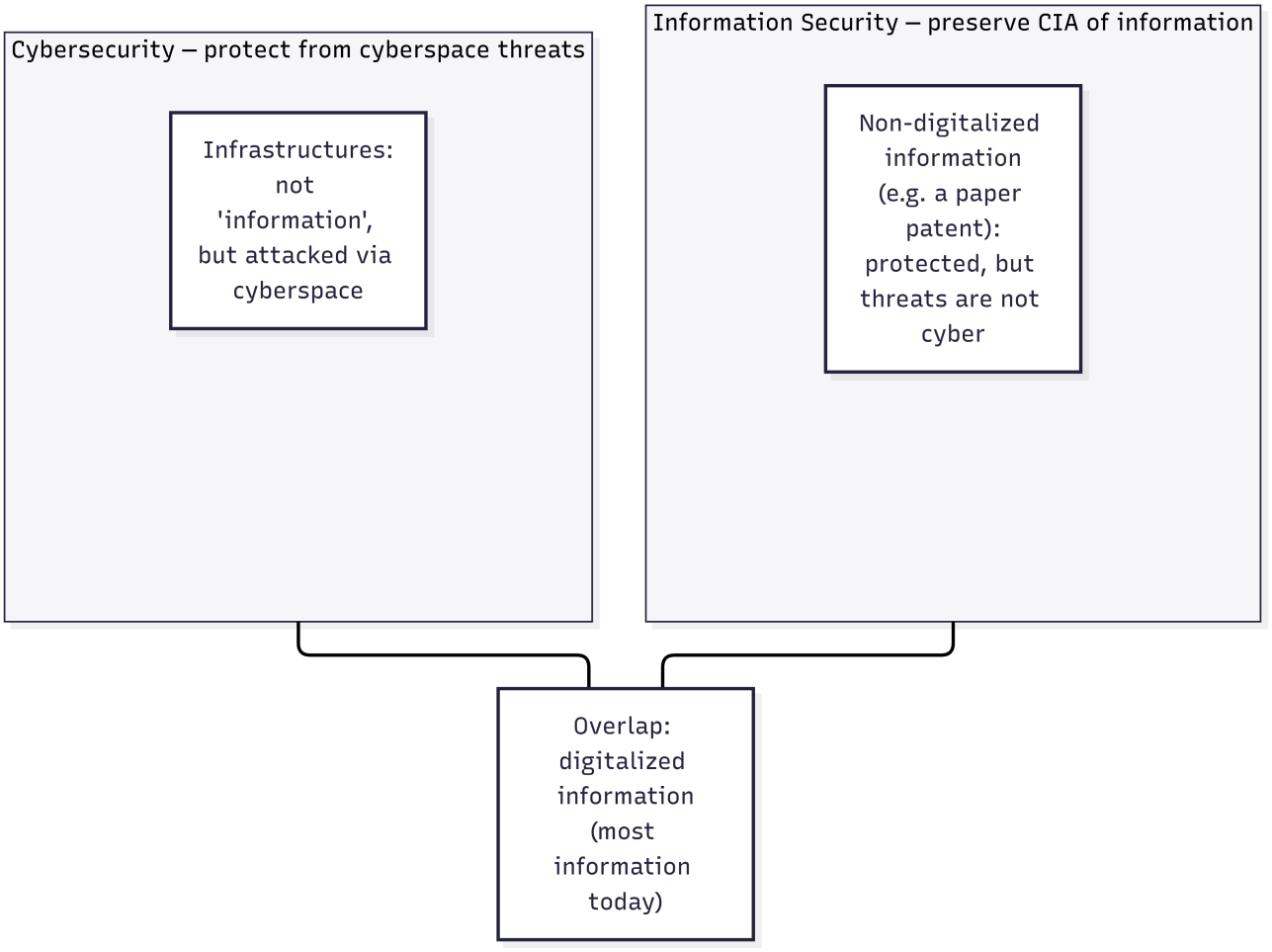
Information security is the preservation of the **CIA properties** of information — Confidentiality, Integrity, and Availability — regardless of the form that information takes. **Cybersecurity** concerns protection from threats that use a cyberspace, regardless of whether the protected thing is "information" in the classical sense.

The overlap is large because, today, most information is digitalized and therefore lives in a cyberspace. But neither circle contains the other:

- There exists **information that must be protected but whose threats do not come from the cyberspace** — for instance a **patent** or a trade secret that is not digitalized, which must be

protected but has nothing to do with the IT infrastructure. This falls under information security but outside cybersecurity.

- Conversely, **infrastructures** are an example of an asset that is not "information" yet must be protected from cyberspace threats — these fall under cybersecurity but outside classical information security.



2.2 Cyber-Risk

A **cyber-risk** is a risk that is caused by a cyber-threat — a risk that materialises in the cyberspace, with assets living in the cyberspace. Mirroring the threat taxonomy, cyber-risks are **malicious** (behind them a malicious cyber-threat) or **non-malicious** (behind them an accidental cyber-threat).

The decisive subtlety is that the *same* risk may sit in the **intersection**, reachable by both a malicious and a non-malicious threat. Consider a **loss of confidentiality of sensitive data**: the identical incident — unauthorized disclosure — can be caused by a **hacker** who breaks in to steal the data (malicious cyber-risk) or by the **accidental posting** of the data on an open website, or an employee leaving a laptop open for anyone to see (non-malicious cyber-risk). Because one incident can have roots on both sides, analysing cyber-risk means examining problems from two different perspectives at once, and it makes the **aggregation and grouping** of risks — already discussed in the general process — especially important in the cyber setting, since a single risk may legitimately belong to different categories.

2.3 Why Cyber-Risk Assessment Is Different

Two structural features make cyber-risk assessment harder than generic risk assessment:

1. The **potentially far-reaching extent of a cyberspace** implies that the origins of threats are widespread, possibly **global** — an attacker may act from anywhere on the planet.

2. The **number of potential threat sources and threats**, both malicious and non-malicious, is **very large**.

The practical response to this explosion of possibilities is the same throughout the chapter: there is a **need to define procedures and techniques that provide guidance and direction**, and to lean heavily on shared, public knowledge rather than trying to enumerate every threat unaided.

3. Communication and Consultation of Cyber-Risk

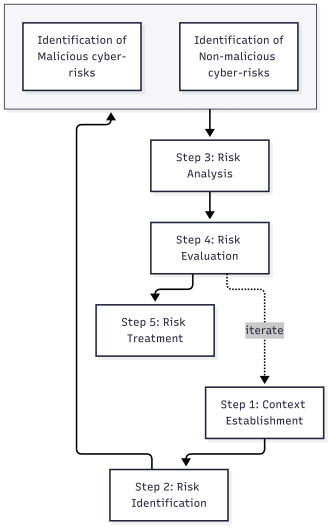
The general process is unchanged in form — communication and consultation is still the sub-process that defines how information is gathered, managed, and distributed, built around a consultative team (including management) that fixes the procedures for feeding the outcome back into decision-making and awareness. But two **additional challenges** appear when the system is a cyber-system:

1. Cyber-systems may potentially have **stakeholders everywhere** — in a networked service, essentially *any* user could be a stakeholder, which makes the stakeholders hard to identify and bound.
2. There may potentially be **adversaries everywhere**, with specific and varied intentions.

The way out of both difficulties is to **leverage common knowledge** — to push hard for **information sharing**, both consuming and contributing public information about cyber-threats, vulnerabilities, incidents, confirmed adversary profiles, and current mitigation strategies. Dedicated repositories of up-to-date information exist precisely for this. The obstacle is that everyone shares information in their own way, so the organization must still **define procedures and techniques** that turn this flood of heterogeneous public knowledge into usable guidance.

4. Cyber-Risk Assessment: the Five Steps Revisited

The five-step structure carries over exactly — Context Establishment, Risk Identification, Risk Analysis, Risk Evaluation, Risk Treatment — and it remains iterative. The first visible divergence from the general case appears in **Step 2, Risk Identification**, which **splits into two parallel sub-activities**: the *Identification of Malicious cyber-risks* and the *Identification of Non-malicious cyber-risks*. These two feed back together before the analysis in Step 3.



Before the split matters, one must recall the attacker's economics. Every company has a **mission** — it provides services to earn money. From the attacker's point of view, the target is **most often not the business itself but the data**; the attacker is not interested in the business as such, only in the ways through which it can interfere with it or extract value from it. This reframing guides where the defender should look.

4.1 Step 1 — Context Establishment for Cyber-Risk

Context establishment retains its purpose: the preliminary documentation of internal and external context, assets, and constraints. In the cyber setting its hardest and most dangerous part is **understanding the boundary of the context**, which in the digital world is anything but obvious — a networked system has no clean physical perimeter.

The device that makes the boundary tractable is the **attack surface**: all of the different points where an attacker or other threat source could get *into* the cyber-system, and where information or data could get *out*. Because we cannot be precise about where the system ends, we instead confine the infrastructure by identifying its **entry points** — the attack surface — and we then reason about every asset in terms of **its placement with respect to that attack surface**.

Typical assets of concern in a cyber-risk assessment fall into two families:

- **Information** — for example a specific set of data. A hospital managing patient records holds sensitive data that must be protected from loss of confidentiality and integrity.
- **Information infrastructures** — the "more material" elements, including **software, services, and networks** that make up the critical infrastructure.

4.2 Step 2a — Identification of Malicious Cyber-Risk

Here the analysis takes the shape of a **game of strategy**. On one side sits a **rational attacker** with a strategy and an objective, who wants to compromise something. On the other sits the **defender** — the company, characterised by a target and a set of assets — who must guess what the attacker intends in order to defend. Standing beside the defender is the **risk assessor**, whose job is precisely to anticipate how the attacker wants to play the game and to suggest the defender's next move. Each time the attacker makes a step, the assessor reassesses the situation, weighs the risk of every action the defender could take, and plans the response.

The governing observation is that **what we can expect from the adversary depends on four things**: the adversary's **(i) motives, (ii) abilities, (iii) helpers, and (iv) resources**. To make this tractable, malicious identification proceeds through four methodological stages, flowing from an initial *Assets and Target Description* and producing a **Risk Model** that expresses the risk in terms of the category of attacker, threat, and vulnerability:

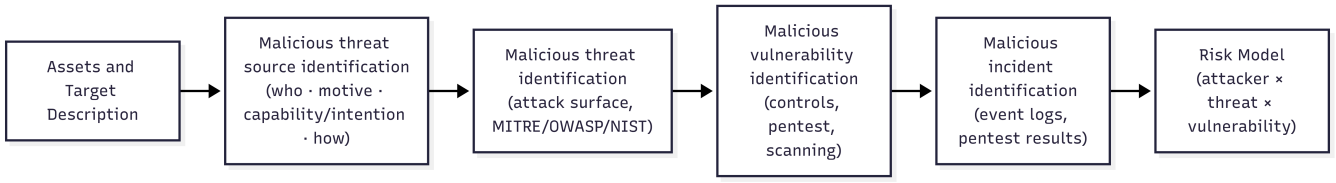
Malicious threat source identification. We first ask who could realistically want to attack, narrowing to the sources with a stronger interest in this particular company. Four questions structure the stage: **who** may want to initiate attacks (a human, a piece of software, an automated agent); **what motivates them** — which is often the hardest to determine, and may range from a competitor seeking to destroy our reputation to ideological activists; **what their capabilities and intentions are** — an adversary able only to launch a small DoS using an off-the-shelf tool like Metasploit is a different proposition from a well-resourced terrorist group; and **how the attack can be launched** — some attacks are easy to detect, others far subtler, involving social engineering. A warning runs through this stage in red: **threats and threat sources are not just external.** The attacker usually arrives from outside, through the attack surface, but may equally come from **inside** — a disgruntled employee already within the cyber-system.

Malicious threat identification. Next we reason about how those sources could become actual threats to the company, paying particular attention to the **interface to the cyberspace** and the documented **attack surface**, and making active use of the target-of-assessment description to investigate *where and*

how attacks can be launched. This is where public knowledge becomes indispensable: helpful catalogues and repositories — those provided by **MITRE, OWASP, and NIST** — are used to avoid reinventing the threat landscape.

Malicious vulnerability identification. We then search for the vulnerabilities that could let threats become incidents, focusing on the identified attack surface. This has technical and non-technical layers. Technically, we **investigate existing controls and defence mechanisms** to judge their strength and adequacy against the identified threats and assets, and we run **security testing — penetration testing and vulnerability scanning** — to check whether and how easily a given threat source could actually launch an attack, to gauge the severity of known vulnerabilities, to hunt for potential ones, and to foresee the incidents they might lead to. Beyond the technical infrastructure (addressed with scanning tools and SIEM, and backed by a consolidated state of the art), we must also examine **non-technical** weaknesses — such as new employees who are not fully trained — and vulnerabilities in the **processes** themselves.

Malicious incident identification. Finally we investigate how the malicious threats can actually harm the identified assets given the identified vulnerabilities. Guidance comes from **event logs about previous incidents** of relevance and from reasoning about the kinds of incidents that the threats and vulnerabilities may produce, informed by the penetration-testing results — always focusing on what is **more probable in our own environment**.



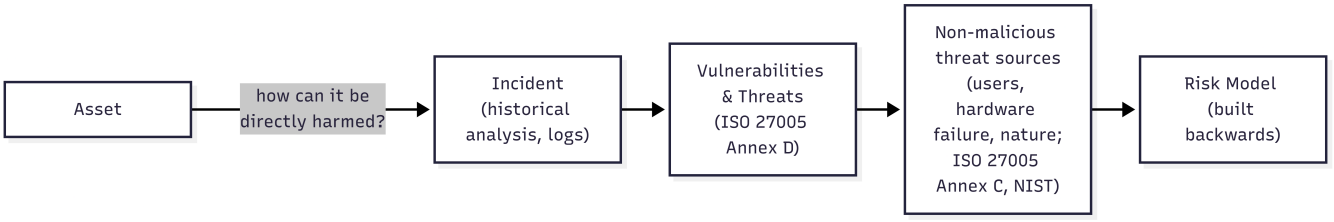
4.3 Step 2b — Identification of Non-Malicious Cyber-Risk

For non-malicious risk the attacker-first method collapses, because there is **no intent or motive** to impersonate and therefore no adversary to start from. There is still a *threat source* — a hardware failure, an act of nature, a careless user — but we cannot begin by hunting for it. Instead, the analysis **runs backwards**: we start from the valuables to be defended and the incidents, and reconstruct the risk model in reverse.

Concretely, three steps in reverse order:

1. **Answer the question "In which way may the considered asset be directly harmed?"** Each distinct possibility corresponds to an **incident**. Non-malicious incidents are typically fewer in number and more easily standardised than malicious ones, and they are usually **recurring and known**, so **incident identification leans on historical analysis** — logs, monitored data, and other historical records of how assets are represented and related to the target of assessment. For example, a loss of data caused not by an attacker but by a **blackout** affecting the datacenter: the effect is the same (the data is gone) but the source is accidental, and to list such incidents one looks at the history.
2. **Identify the vulnerabilities and threats that may cause these incidents**, focusing only on the parts and aspects of the target relevant to the identified incidents. Continuing the example: the machine storing the data was **not placed behind a continuity (UPS/continuity) server**. Public knowledge supplies candidate vulnerabilities here — notably **ISO 27005**, whose informative **Annex D** lists examples of vulnerabilities organised by type (Hardware, Software, and so on), each with example vulnerabilities and the example threats that might exploit them.

3. **Identify the non-malicious threat sources that can cause the threats.** We ask who the users of the system are and how they can cause unintended or accidental events, and we deliberately include **non-human threat sources** — hardware failure, wear and tear, acts of nature. Here too **ISO 27005 (Annex C, typical threats)** and the **NIST risk assessment guide** provide categorized lists. Annex C classifies each threat by origin with the codes **D (deliberate), A (accidental), E (environmental)** — for example *Fire* is marked A, D, E (it can be arson, accident, or natural), while *Seismic phenomenon* is purely E — which is exactly the information needed to separate the non-malicious (A, E) contributions from the malicious (D) ones.



At the end of Step 2 the assessor holds **two risk models** — one malicious, one non-malicious — ready to be carried into the analysis.

5. Analysis of Cyber-Risk

With two risk models in hand, the third step — estimating likelihood and consequence to derive the risk level — proceeds much as in the general case, but **two aspects distinguish cyber-risk analysis** from risk analysis in general, one a difficulty and one an advantage.

1. **Likelihood is hard to estimate for malicious threats.** Where there is **human intent and motive** behind a threat, estimating the probability of occurrence is genuinely difficult: the information is incomplete, and — decisively — it **changes very quickly**. An attacker's capabilities, the availability of exploit code, and the fashion for particular attacks all shift on short timescales, so a likelihood estimated today may be stale tomorrow.
2. **Cyber-systems offer rich instrumentation.** The flip side is that the digital nature of the system gives us many options for **logging, monitoring, and testing**, and this empirical data can be fed directly into the analysis to ground the estimates that would otherwise be guesswork.

The technique that reconciles the two is **threat modelling**. Rather than asserting a bare probability, we build **threat models and attack models** that describe the relevant factors — attack prerequisites, the attacker skill or knowledge required, the resources required, the attacker's motive, the attack opportunity, and so forth. Similar descriptive models are built for **vulnerabilities**, capturing attributes such as **ease of discovery** and **ease of exploit**. We then attach to these models the information on the likelihood of exploiting individual vulnerabilities (and groups of them), together with **temporal information** about how those likelihoods evolve. In combination, this structured information is what lets us **derive the likelihoods of threats and incidents** in a defensible way, instead of pulling a number from the air. Consequence estimation is unchanged from the general case: an incident still represents one risk per harmed asset, estimated on the appropriate scale.

6. Evaluation of Cyber-Risk

Evaluation keeps its four sub-steps, and the overall shape is "not too much different from the general case" — but each sub-step carries a cyber-specific nuance, and the unifying theme is that **malicious and non-malicious risks are kept as two separate entities** for as long as it is useful to do so.

1. **Consolidation of risk analysis results.** As before, we focus on the cyber-risks whose estimates are **uncertain**. The cyber addition is the explicit need to **estimate the level of uncertainty** in both the likelihood and the impact estimates: if that uncertainty is too great, we must go back and acquire additional data before trusting the result. From the outset the consolidation **distinguishes malicious from non-malicious** risks.
2. **Evaluation of risk level.** For convenience it is possible — and recommended — to **evaluate malicious and non-malicious cyber-risks separately**. In practice this means maintaining **two distinct risk matrices**, one for each class, which are **merged only later**.
3. **Risk aggregation.** This is exactly as in the general case: we look for sets of risks that should be treated as one, investigating situations where several separate incidents harm the **same asset** or where incidents share the **same threat source**.
4. **Risk grouping.** Here the malicious/non-malicious separation is deliberately **undone**: because grouping looks ahead to *treatment*, we now try to **merge malicious and non-malicious risks** that share a common mitigation, grouping them so as to improve the selection of the most appropriate treatments.

The logic of the ordering is worth noting: the two classes are held apart through consolidation and level-evaluation (where their differing natures matter for estimating likelihood and uncertainty), and are brought back together at grouping (where what matters is the shared remedy).

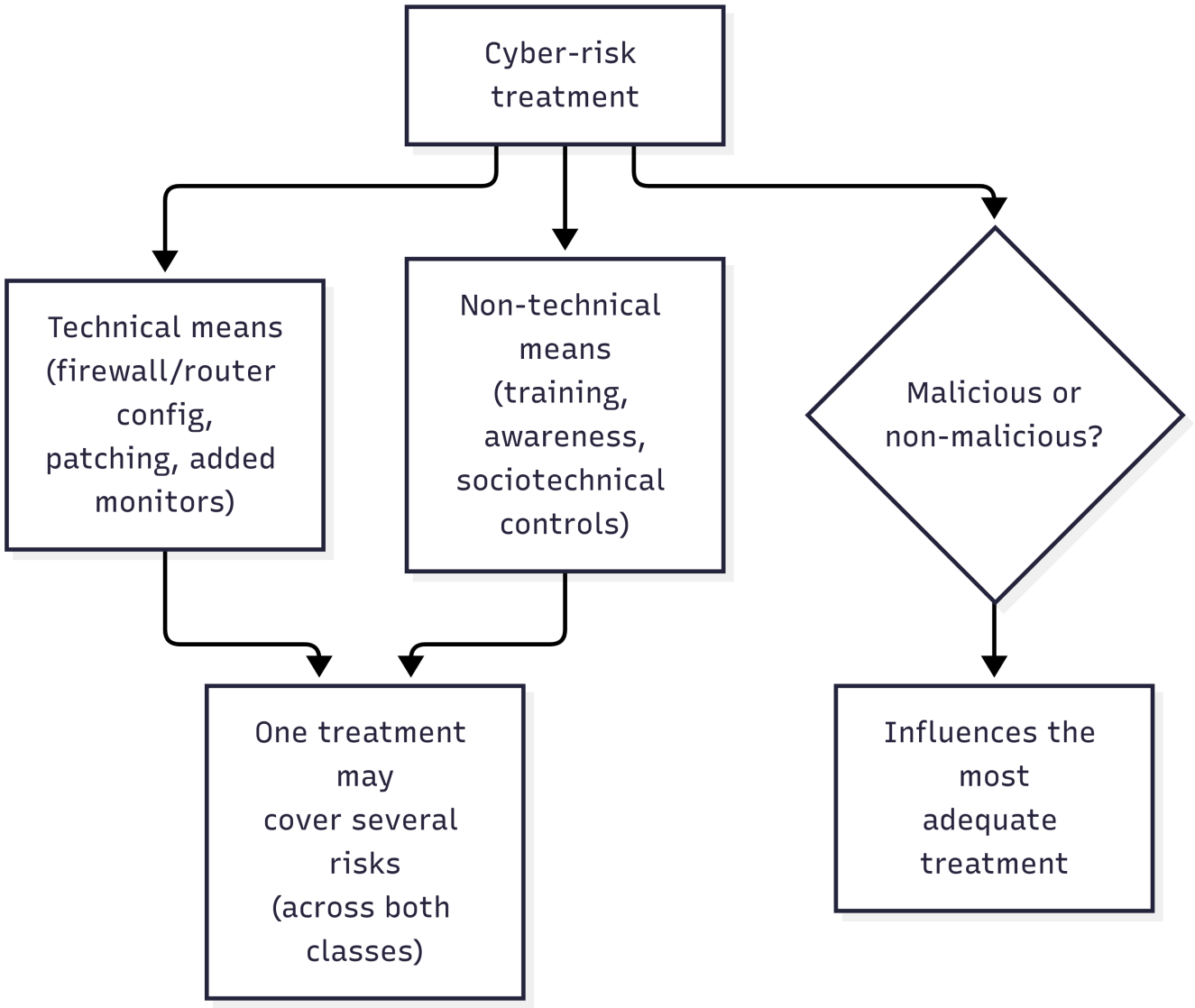
7. Treatment of Cyber-Risk

Two features in particular distinguish the treatment of cyber-risk from the general case.

The treatment options are themselves highly technical. Because cyber-systems are technical, the natural levers are technical too: acting directly on the infrastructure, for example by changing the configuration of a **firewall** or updating the **policies of routers** to reduce a risk. But the technical lever is not always available or sufficient, and the **sociotechnical aspects and human involvement** must also be considered. The archetypal case is a server that **cannot be upgraded because of compatibility constraints**: unable to patch it, we turn to **non-technical** treatment — **training** the people who interact with the machine so they become aware of common vulnerabilities, while **in parallel** adding compensating controls such as additional monitors around the vulnerable component. Treatment therefore ranges across the full four options from the general case (reduction, retention, avoidance, sharing), realised through a technical or a non-technical means as the situation allows.

The malicious/non-malicious distinction has implications for the most adequate treatment. The class of a risk influences which treatment fits best. At the same time — and this is why grouping merged the two classes — a **single treatment may provide benefit to more than one risk** across both categories, which is precisely the efficiency that grouping is meant to capture.

For **Monitoring and Review** there is **no significant difference** from the general case: risks remain dynamic and must be watched for changes in assets, vulnerabilities, and threats, and the framework and process must be checked for continuing adequacy, exactly as described for generic risk management.



8. Supporting Repositories and Catalogues

The recurring prescription of the whole chapter — lean on shared public knowledge — is realised through a family of community-maintained catalogues. Each occupies a distinct position on the chain **threat source** → **threat** → **vulnerability/weakness** → **incident**, and knowing which catalogue answers which question is itself an exam-relevant skill.

8.1 MITRE CAPEC — attack patterns

CAPEC (Common Attack Pattern Enumeration and Classification) is a publicly available catalogue of **attack patterns**, together with a comprehensive schema and classification taxonomy, created to assist in the building of secure software. Its premise is that understanding how the adversary operates is essential to effective defence, so it provides a dictionary of known patterns of attack employed by adversaries to exploit known weaknesses in cyber-enabled capabilities. An **"attack pattern"** describes a common method for exploiting software from the **attacker's perspective**, along with guidance on how to mitigate it. CAPEC can be used by analysts, developers, testers, and educators, and its list can be browsed **by Mechanisms of Attack** or **by Domains of Attack**. It is the natural reference for the **malicious threat identification** stage.

A representative CAPEC entry — *HTTP Response Splitting* — shows the richness of each pattern. Beyond a name and a **typical severity** (High), it records a **description** of how the attack works (a vulnerable web server is coaxed into emitting a response stream that gets interpreted as two separate

responses, exploitable when user-controlled input is used unvalidated in the response headers); the **attack prerequisites** (user-controlled input placed in an HTTP header, the ability to inject custom strings, and insufficient input validation); the **typical likelihood of exploit** (Medium); the **methods of attack** (Injection, Protocol Manipulation); concrete **examples/instances** with a CVE reference; the **attacker skill or knowledge required** (High — a solid understanding of HTTP); the **resources required**; **probing techniques**; the **indicators/warnings** of the attack; the **solutions and mitigations**; the **attack motivation-consequences**; and a **CIA impact** line (here Confidentiality High, Integrity High, Availability Low). Finally it lists the **related weaknesses** as **CWE** identifiers — the bridge from an attack pattern to the underlying software weaknesses it exploits.

8.2 MITRE CWE — software weaknesses

CWE (Common Weakness Enumeration) is a community-developed list of **common software security weaknesses**. It serves three roles: a **common language** for discussing weaknesses, a **measuring stick** for software security tools, and a **baseline** for weakness identification, mitigation, and prevention. Its list can be viewed by **Research**, **Development**, or **Architectural** concepts.

Where CAPEC describes *how an attack is carried out*, CWE describes *the underlying flaw that makes the attack possible* — the two are explicitly linked, as the CAPEC entry's "related weaknesses" field shows. A CWE entry (for example **CWE-415, Double Free**) includes the name of the weakness type, a description of the type, alternate terms, descriptions of the **behavior** and the **exploit** of the weakness, the **likelihood of exploit**, the **consequences** of the exploit, **potential mitigations**, **demonstrative examples**, **observed examples** (real CVEs exhibiting the weakness), **node relationship** information placing it in the CWE hierarchy, **source taxonomies**, and **code samples** for the relevant languages and architectures.

8.3 CVE and the NVD — disclosed vulnerabilities

Weaknesses (CWE) are generic types of flaw; a **vulnerability** is a concrete instance of such a flaw in a specific product. Vulnerabilities may affect a system at many **levels — Hardware, Software, Network, Personnel, Organizational**. The MITRE Corporation maintains a list of disclosed vulnerabilities in a system called **CVE (Common Vulnerabilities and Exposures)**, in which each vulnerability is scored using the **CVSS**. **NIST** collects these scored vulnerabilities and makes them available through the **National Vulnerability Database (NVD)**.

A CVE/NVD entry (for example *CVE-2003-0062*) records an original release date and last-revised date, the source, an **overview** of the flaw (a buffer overflow allowing local users to execute arbitrary code via a long path name), and the **impact** expressed as a **CVSS severity** — a base score with a qualitative rating (e.g. 7.2, HIGH), a **vector string** encoding the metric choices, impact and exploitability subscores, and metrics such as **access vector**, **access complexity**, and **authentication**.

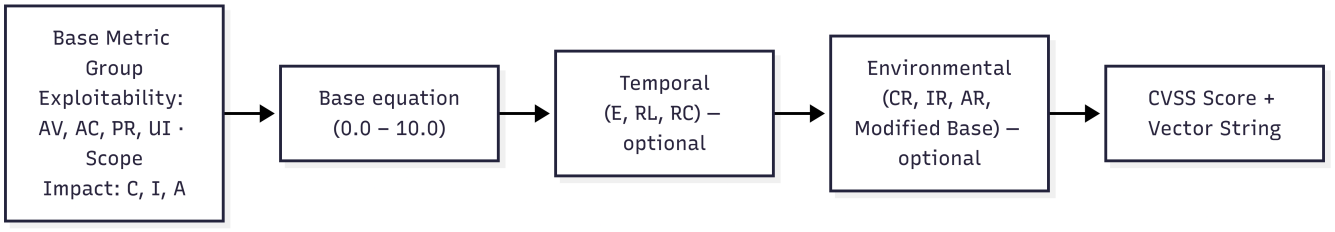
8.4 CVSS — scoring a vulnerability's severity

The **Common Vulnerability Scoring System (CVSS)** captures the principal **technical characteristics** of software, hardware, and firmware vulnerabilities, and outputs a **numerical score** indicating a vulnerability's severity *relative to others*. Its value to the risk assessor is that it provides a **standardized, vendor- and platform-agnostic** methodology within an **open framework** — the score is transparent, because the vector string that produced it is published alongside it.

CVSS is composed of **three metric groups**:

- **Base metrics** reflect the severity arising from a vulnerability's **intrinsic characteristics**, which are constant over time and assume the reasonable worst-case impact across deployment environments. They split into **Exploitability metrics** — Attack Vector, Attack Complexity, Privileges Required, User Interaction — and **Impact metrics** — Confidentiality, Integrity, Availability — together with **Scope**.
- **Temporal metrics** adjust the base severity for factors that **change over time**, such as the availability of exploit code: **Exploit Code Maturity**, **Remediation Level**, and **Report Confidence**. These capture exactly the "information changes quickly" problem identified in the analysis step.
- **Environmental metrics** adjust the base and temporal severities to a **specific computing environment**, accounting for factors like the presence of mitigations and the relative importance of the vulnerable system: **Modified Base Metrics** plus the **Confidentiality, Integrity, and Availability Requirements**.

The scoring pipeline is layered. When an analyst assigns values to the **Base metrics**, the **Base equation** computes a score from **0.0 to 10.0**; this base equation is itself derived from two sub-equations, an **Exploitability sub-score** (from the base exploitability metrics) and an **Impact sub-score** (from the base impact metrics). The **Temporal** and **Environmental** groups are **optional** refinements layered on top, and the final result is reported as a score **together with its vector string**, so that any consumer can see precisely how it was derived.



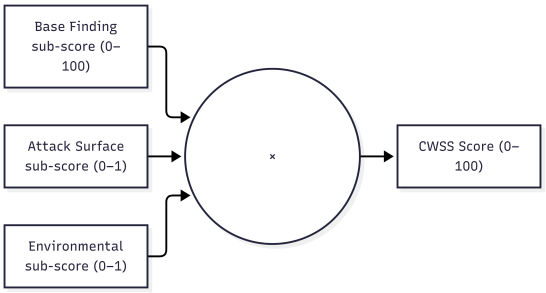
8.5 CWSS — scoring a weakness

Just as CVSS scores concrete vulnerabilities, the **Common Weakness Scoring System (CWSS)** provides a mechanism for **prioritizing software weaknesses** (CWE entries) in a consistent, flexible, and open manner. It is a collaborative, community-based effort spanning government, academia, and industry. CWSS is **distinct from, but not a competitor to, CVSS** — the two have different roles (CVSS scores a disclosed vulnerability, CWSS prioritizes a weakness, often one found during development) and can be leveraged **together**. CWSS offers **quantitative measurements** of the unfixed weaknesses present in an application, a **common framework** for prioritizing security errors, and **customized prioritization**.

CWSS is organized into **three metric groups**:

- **Base Finding** — captures the **inherent risk** of the weakness, the confidence in the accuracy of the finding, and the strength of controls. Its factors include Technical Impact, Acquired Privilege, Acquired Privilege Layer, Internal Control Effectiveness, and Finding Confidence.
- **Attack Surface** — the **barriers an attacker must overcome** to exploit the weakness: Required Privilege, Required Privilege Layer, Access Vector, Authentication Strength, Level of Interaction, and Deployment Scope.
- **Environmental** — characteristics of the weakness **specific to a particular environment or operational context**: Business Impact, Likelihood of Discovery, Likelihood of Exploit, External Control Effectiveness, and Prevalence.

The scoring differs from CVSS in how the groups combine. Each factor in the **Base Finding** group is assigned a value; the values are converted to associated weights and a **Base Finding sub-score** is computed, ranging between **0 and 100**. The **same method** is applied to the **Attack Surface** and **Environmental** groups, but **their sub-scores range between 0 and 1**. The three sub-scores are then **multiplied together** to yield a final **CWSS score between 0 and 100** — so the Attack Surface and Environmental groups act as *multiplicative discounts* on the Base Finding score, reducing it to the extent that attack barriers and environmental factors make the weakness less exploitable or less consequential.



8.6 How the catalogues fit together

The five resources are not interchangeable; each answers a different question along the risk chain, and together they operationalise the "use public knowledge" prescription end to end.

Resource	Maintainer	What it catalogues	Where it helps in the assessment
CAPEC	MITRE	Attack **patterns** (how adversaries operate)	Malicious **threat** identification
CWE	MITRE	Software **weakness** types	**Vulnerability** identification (the generic flaw)
CVE / NVD	MITRE / NIST	Disclosed concrete **vulnerabilities**	Vulnerability identification (the specific instance)
CVSS	FIRST	**Severity score** of a vulnerability (0–10)	**Analysis** — grounding likelihood/impact of a CVE
CWSS	MITRE	**Priority score** of a weakness (0–100)	Analysis/prioritisation of CWE findings

The chain reads naturally: **CAPEC** tells us how an attacker might strike; those patterns point to **CWE** weakness types; a weakness instantiated in a real product becomes a **CVE** recorded in the **NVD**; **CVSS** scores how severe that vulnerability is, with temporal metrics tracking the fast-changing information that made malicious likelihood so hard to estimate; and **CWSS** prioritises weaknesses still being addressed in software under development. Feeding these standardized, shared scores into the threat and attack models is exactly what allows the cyber-risk assessor to attach defensible likelihoods to threats and incidents, closing the gap that the adversarial, fast-moving, globally-sourced nature of cyber-risk had opened.

CHAPTER 3_tris: A case study

The two preceding chapters built the theory twice over — once in the neutral language of ISO 31000, once sharpened for the cyber domain. Theory, however, only becomes usable when it is walked through end to end on a concrete system, where every abstract instruction ("identify the attack surface," "estimate the likelihood," "aggregate risks that pull in the same direction") must be turned into an actual table, number, or decision. This chapter does exactly that. It takes a single realistic target — the **Advanced Metering Infrastructure (AMI)** of a **smart grid** — and carries it through all five steps of the cyber-

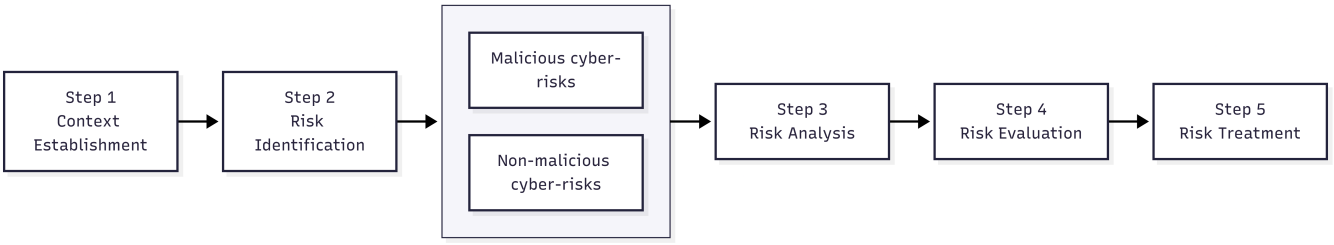
risk assessment, showing not only *what* each step produces but *why* each judgement is made the way it is. Nothing new is added to the method; what is added is the discipline of applying it completely.

1. The Scenario: AMI in a Smart Grid

A **smart grid** is an electricity distribution network that can monitor the flow of electricity within itself and automatically adjust to changing conditions. It is the textbook **cyber-physical system**: a digital control layer superimposed on a physical service of national importance. A central component of the smart grid is the **Advanced Metering Infrastructure (AMI)**, a fleet of power meters that use **two-way communication** both to **collect** information about electric-power usage from customers and to **provide** information back to them. Because the communication runs in two directions, the infrastructure does not merely *read* consumption; it can also *act* — switching power on or off for a customer, or **choking** it (limiting the amount of power delivered).

That capacity to act is what makes the system worth assessing. The stated **aim** of the exercise is to assess the risks for this infrastructure, including the components that switch power on and off and the component that limits the power provided. The **party** — the entity on whose behalf the assessment is run — is the **distribution system operator (DSO)**. This choice of party is decisive and must be held in mind throughout: the whole analysis looks at the infrastructure *from the point of view of the organization that manages it*, not from the point of view of the customer. As the slides stress, the DSO is the **sole** party, which means that **every consequence estimate and every risk-evaluation criterion is defined from the operator's perspective** — the overall business impact to the operator, not the inconvenience to any individual customer.

The entire assessment follows the familiar five-step spine, with the identification step split in two as the cyber method requires.



Most of the analytical heavy lifting in the exercise is done with the **OWASP Risk Rating Methodology**, and along the way the assessment leans on public catalogues and guidelines — CAPEC, CWE, **NISTIR 7628** (smart-grid cybersecurity), and **ISO 27005** (its annexes of vulnerabilities and threats).

2. Step 1 — Context Establishment

Context establishment is the preliminary stage in which the assessment is bounded and furnished with everything the later steps will consume: the internal and external context, the assessment goals, the target/scope/focus, the assumptions, the assets, the likelihood and consequence scales, and the risk-evaluation criteria. The guiding difficulty, as always in the cyber domain, is **fixing the boundary** of a system that has no clean physical perimeter.

2.1 External Context

The **external context** is the description of the societal, legal, regulatory, and financial environment and of the relationships with external stakeholders. Because the smart grid is a cyber-physical system that forms part of a **critical infrastructure**, the DSO is subject to a body of national laws and regulations

governing its operation — in Europe, the **NIS directive** on the security of network and information systems. Identifying and documenting these obligations is not optional: **failure to comply may carry significant legal and financial consequences**, in the worst case putting the operator out of business. The regulation's logic, for a critical-service provider, is that **critical incidents must be avoided**, and when they do occur they must be **reported within a predefined time window** and **resolved within a predefined window** as well.

Two external concerns follow directly. First, **power outages** threaten the availability of a critical service. Second, incidents such as **charging the wrong amount** or **disclosing customer data** damage the **reputation** and public trust in the operator — and reputation, as established earlier, is itself a protected value. The external context therefore already points at the assets that will matter: availability of the service, and the reputation that rides on it.

2.2 Internal Context

The **internal context** describes the relevant goals, objectives, policies, and capabilities that shape how risk should be assessed. The DSO's **mission** is to distribute electrical power to its customers, and from that mission flow three overall goals: to **provide power reliably**, so that customers do not suffer unintended failures; to **exchange correct and timely information** with customers at all times, so that they are charged the right amount; and to **protect the privacy** of customers, so that their data is not disclosed. Reading these goals as security properties yields the three dimensions the assessment will track: the **availability** of the service, the **integrity** of information in transit between infrastructures, and the **privacy** of customers.

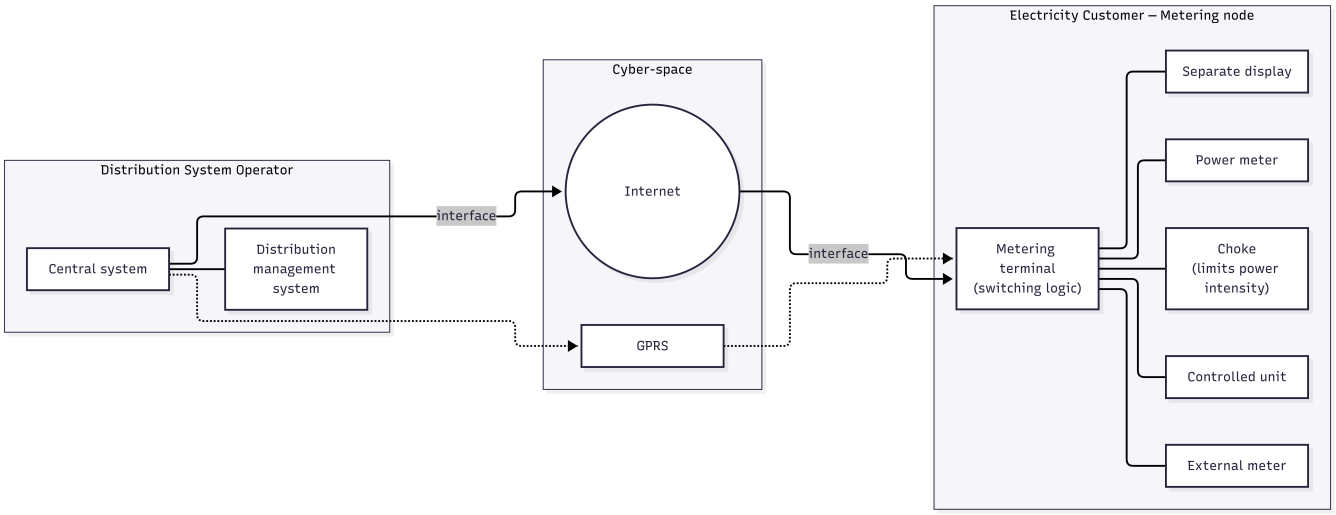
One internal fact about people carries real analytical weight. **Most employees of the DSO have strong technical competence, but only a few have received special training in risk assessment.** The division that will run the assessment is technically excellent yet unaccustomed to risk analysis — a limitation that itself becomes a vulnerability later, and a reason the results must be documented in plain, non-technical language.

2.3 Goals and Objectives of the Assessment

Three objectives are set for the assessment itself. The primary one is to **assess risk with respect to business continuity** — to reduce the risk of incidents that may impact the DSO's business by identifying appropriate treatments for the important risks. The second is **law and regulation compliance** — explicitly, to analyse the risks that would leave the operator non-compliant. The third is to **improve situation awareness**: the assessment must be documented so that a wide range of internal and external stakeholders can understand it, **including those who are not experts** in cybersecurity or smart grids, which means **technical detail should be avoided as far as possible** in the reporting. The latter two objectives are, in effect, documentation requirements layered on top of the core continuity analysis.

2.4 Target, Scope, and Focus

The **target** must be pinned down precisely, and the natural instrument is a **diagram** supplied by the party. The system divides into two sides.



On the **operator side** sit the **central system** and the **distribution management system (DMS)** — the latter being the component the assessment is really aimed at, since it decides how power is provided. To act, it must be connected to the central system, and that connection travels over a network — either the **Internet** or **GPRS**. On the **customer side** sits the **metering node**, installed in the electricity box. It contains the **power meter**; the **metering terminal**, which holds the logic behind switching and is itself subdivided into further components (it also connects to a separate display, a controlled unit, and an external meter); and the **choke**, which regulates the intensity of power. The metering terminal and the choke together perform the switching and choking of power.

The **scope** fixes what is in and what is out. The assessment is limited to **risks due to attacks on or via the target of assessment**. Attacks via back-end systems are **out of scope**, and — importantly — communication between the central system and the metering node over **GPRS is assumed to be covered by a separate assessment** and is therefore **also out of scope**. The scope thus narrows to the **Internet** path.

The **focus** is the refinement within that scope: the **exchange of meter data and control data via the Internet**, and the ways this may affect the provisioning of power, which is the aspect the operator worries about most. Within the scope but deliberately *not* the main focus are attacks via **physical access** to components. Both **malicious and non-malicious** threat sources are to be considered. In terms of functionality, the focus rests on the **basic AMI functions**: **registering customer meter data**, **transfer of data** between customer and operator, and **switching on/off or choking** of the power provided.

The assessment therefore trusts the internal infrastructure and treats the **attack surface** as the set of points where the two sides meet the external world — the **Internet (and GPRS) interfaces** on both the operator and the customer components. An attacker may enter through any of these points; and, because the distribution side is secured but the customer side cannot be guaranteed, the attacker may equally be **internal** to the customer component.

2.5 Assumptions

The analysis is made honest by stating what is taken for granted. The assessment assumes that **threat sources may be both internal and external**; that **malicious and non-malicious threats alike may be internal or external**; that the target may be attacked not only by actors with a purely **financial or personal** motive but also by actors who wish to **disrupt society** (terrorists, activists); and that **all meter data and control data sent between the central system and metering**

nodes are encrypted. There is also a working presumption that the probability of an external source may differ from that of an internal one — a distinction the likelihood analysis will later weigh.

2.6 Assets

From the party, the mission, and the functions in scope, the assessment derives the assets as **security properties over specific components**. Three assets result, each defined from the operator's business perspective.

Asset	Description
Integrity of meter data	The integrity of meter data must be protected all the way from the power meter to the distribution system operator.
Availability of meter data	Meter data from the metering node must be available to the distribution system operator at all times.
Provisioning of power to electricity customers	Power should be switched off or choked *only* as the result of **legitimate** control signals from the central system.

2.7 The Likelihood Scale

Likelihood is expressed in terms of **frequencies**, using a **five-step scale of intervals** rather than exact values. The analyst need only decide *which interval* an incident's frequency falls into, which is a simple and honest way of expressing uncertainty; the granularity chosen depends on the availability of data and the preferences of the decision makers. The five levels, in ascending order, are **Rare, Unlikely, Possible, Likely, Certain**, each mapped to a frequency band (events per unit of time) read off from historical data.

2.8 The Consequence Scales

Because **consequences are tied to assets**, a single universal scale is impossible: the assessment defines **one consequence scale per asset**, even if all three share the same five-level granularity (Insignificant, Minor, Moderate, Major, Critical). Crucially, every scale is written **from the DSO's perspective**, measuring overall business impact, and is calibrated against the legal duty of a critical provider to guarantee certain levels of availability and integrity. The three scales quantify impact by the **number of affected customers** and, for availability, the **duration** of the disruption.

Integrity of meter data — measured by how many customers' data is wrong:

Value	Description
Insignificant	Errors in meter data for up to 100 customers
Minor	Errors for 101–2,000 customers
Moderate	Errors for 2,001–20,000 customers
Major	Errors for 20,001–50,000 customers
Critical	Errors for more than 50,000 customers

Availability of meter data — measured by number of customers *and* duration of unavailability:

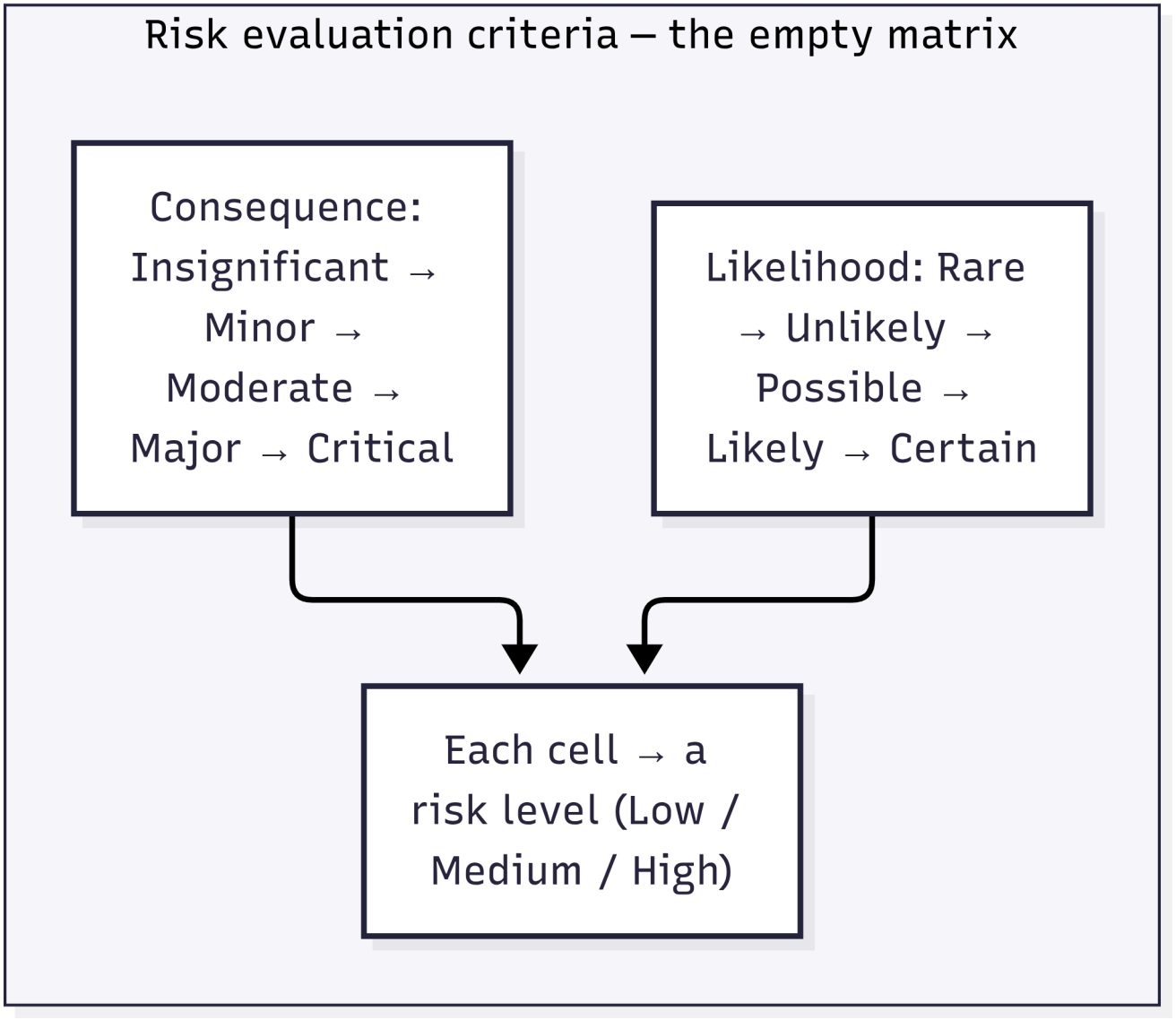
Value	Description
Insignificant	Up to 1,000 customers unavailable for 1–24 hours
Minor	Up to 1,000 customers for more than 1 day, **or** 1,001–10,000 customers for 1–24 hours
Moderate	1,001–10,000 customers for more than 1 day, **or** more than 10,000 customers for 1–24 hours
Major	More than 10,000 customers for 25 hours–7 days
Critical	More than 10,000 customers for more than 7 days

Provisioning of power — measured by number of customers suffering an outage and its duration:

Value	Description
Insignificant	Up to 100 customers for 1–24 hours
Minor	Up to 100 customers for more than 24 hours, **or** 101–1,000 customers for 1–24 hours
Moderate	101–1,000 customers for more than 24 hours, **or** 1,001–10,000 customers for 1–24 hours
Major	1,001–10,000 customers for 25–72 hours, **or** more than 10,000 customers for 1–24 hours
Critical	1,001–10,000 customers for more than 72 hours, **or** more than 10,000 customers for more than 24 hours

2.9 Risk Evaluation Criteria

The criteria are fixed by drawing the **risk matrix**: a 5×5 grid crossing the five likelihood levels against the five consequence levels, with each cell coloured to a risk level (Low, Medium, High). Deciding the colouring — how many bands, and where the boundary of each runs — *is* the act of setting the evaluation criteria, and it is done now, before any risk is seen, precisely so that the later placement of risks is fair and not swayed by whichever risk happens to look most alarming.



With context established, the boundary of the analysis is known, and risk identification can begin.

3. Step 2 — Risk Identification

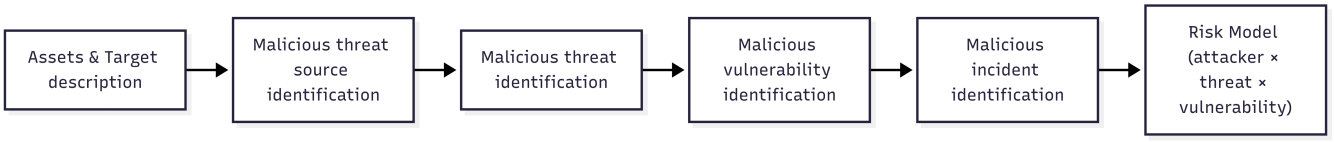
The goal of risk identification is to arrive at a collection of **threat sources, threats, vulnerabilities, incidents, and risks** that is as correct and complete as possible for *this* target and *these* assets. To populate that collection the assessment first gathers information about the environment — from **logs, intrusion-detection systems and other monitoring tools, vulnerability scanners, penetration tests and other security tests, and source-code reviews**; from **external vulnerability and threat repositories**; and from **people who know the target well** from their particular viewpoints. A warning attaches to the historical sources: when using event logs one must **take great care not to assume that tomorrow will be like yesterday**, since the cyber threat landscape shifts quickly.

Identification then proceeds along the two mandated tracks — malicious first (attacker-forward), non-malicious second (incident-backward).

3.1 Identification of Malicious Cyber-Risk

The malicious track is a game of strategy against a **rational attacker**, and it runs through four stages — threat-source, threat, vulnerability, and incident identification — starting from the assets-and-target description and ending in a **risk model** expressing each risk as a combination of attacker category,

threat, and vulnerability.



Threat-source identification asks *who* may want to attack and *why*, documenting for each candidate the **motive and intention**, the **capabilities**, and the **available resources** — the four things on which the potential for harm depends. The assessment records the sources in a table (Table 7.2, "Malicious threat sources") whose columns are exactly *Threat source · Motive and intention · Capability and resources.* Among the sources considered are the **script kiddie** (a naive, relatively unskilled attacker), the **cyber-terrorist**, and the **hacktivist**. The hacktivist entry illustrates the reasoning: motivated by a political, ideological, or religious agenda and using cyber-attacks to pursue it, hacktivists are assumed — though the line from cyber-terrorists is admittedly fuzzy — to be **less willing to go to extremes**, aiming to harm **selected groups, politicians, or individuals rather than society as a whole**; their skill and resources vary widely, since most operate alone or in small, poorly organized groups, but a well-organized hacktivist group can command significant computation and competence. Threat sources, as always, may be **external** (arriving through the attack surface) or **internal** (a disgruntled employee).

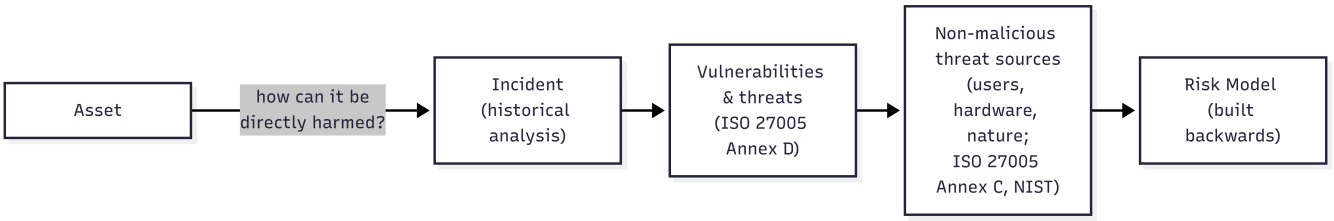
Threat identification then asks, for each source, which **threats** it may initiate, concentrating on how the source could exploit the documented **attack surface**, and drawing on public catalogues such as **CAPEC** to avoid reinventing the threat landscape.

Vulnerability identification searches, for each threat, the weaknesses it could exploit — beginning from vulnerability lists (the **NISTIR 7628** smart-grid guidelines, **ISO 27005**'s catalogue of hardware/software/network/personnel/site/organization vulnerabilities, **OWASP** resources, and MITRE's **CWE**) and continuing with the output of **scanners and security testing**. The result (Table 7.4, "Vulnerabilities with respect to malicious threats") pairs each threat with a vulnerability and an explanation — for example, the threat *DDoS attack on the central system* is paired with the vulnerability *Inadequate attack detection and response on the central system*, explained by the fact that new DDoS techniques constantly emerge to defeat existing countermeasures, and that in a power-distribution domain not historically operated in cyberspace, those countermeasures are rarely updated. The *tampering* threats are paired with *weak encryption and integrity check*, noted to be especially acute at the metering nodes, which have little computing power and are rarely replaced.

Incident identification finally investigates how those threats, through those vulnerabilities, actually harm the assets — guided by **event logs of previous incidents** and by what is **most probable in this environment**. The result (Table 7.5, "Incidents caused by malicious threats") links each threat to a concrete incident and the asset it harms. A single threat source — *metering node infected by malware* — produces **three distinct incidents** against three different assets (malware *compromises* meter data → integrity; malware *disrupts transmission* of meter data → availability; malware *disrupts the choke functionality* → provisioning of power), a vivid reminder that one event can be several risks at once.

3.2 Identification of Non-Malicious Cyber-Risk

For the non-malicious track the attacker-forward method collapses, because there is **no intent or motive** to impersonate. The analysis therefore **runs backwards**: start from the **incident**, then find the vulnerabilities and threats, then the threat sources.

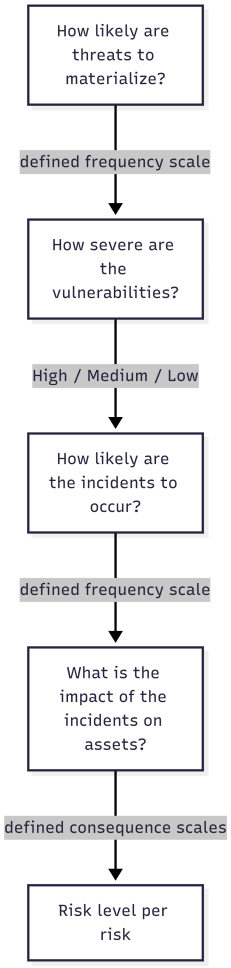


Incident identification here leans on **historical analysis**, because non-malicious incidents are fewer, more easily standardized, and usually recurring and known. The result (Table 7.7, "Incidents caused by non-malicious threats") is organized *asset-first*, listing for each incident the asset harmed and a description of the mechanism. The incidents include *communication between the central system and metering terminal is lost* (harming both provisioning and availability, since control data flows one way and meter data the other); the three *software bug on the metering terminal* incidents (compromising meter-data integrity, disrupting meter-data transmission, and disrupting the choke functionality respectively); two *mistakes during maintenance of the central system* incidents (disrupting control data to the choke, and preventing reception of metering-node data); and *the metering terminal goes down due to damage from lightning* — a purely environmental cause, where lightning physically damages the terminal. Candidate vulnerabilities and threats are drawn from public knowledge, notably **ISO 27005's Annex D** (vulnerabilities by type) and **Annex C** (typical threats, each tagged **D/A/E** for deliberate, accidental, environmental, which separates the non-malicious A and E causes from the malicious D ones).

At the close of Step 2 the assessor holds **two risk models** — one malicious, one non-malicious — and the full enumeration of incidents that the analysis will now quantify.

4. Step 3 — Risk Analysis

Risk analysis estimates the **likelihood** and **consequence** of every identified incident so that a risk level can be derived (risk level = likelihood combined with consequence). The information sources are the same as in identification; the difference is that the assessment now needs the **severity of vulnerabilities**, the **likelihood of threats and incidents**, and the **consequence of incidents**. Operationally it proceeds by answering four questions in order, each against a scale fixed during context establishment.



4.1 Analysing Malicious Threats — the OWASP Method

For malicious threats the likelihood of a threat materializing is estimated from **event logs** and the **expert judgement** of the participants, structured by an approach **inspired by the OWASP Risk Rating Methodology**. Four factors are rated on a **0–9** scale:

Factor	Question	Example anchors (score)
Skill Level	How technically skilled is this group of threat agents?	no skills (1), some (3), advanced user (5), network/programming (6), security-penetration (9)
Motive	How motivated are they to find and exploit this?	low/no reward (1), possible reward (4), high reward (9)
Opportunity	What resources/opportunities are required?	full access/expensive resources (0), special (4), some (7), none required (9)
Size	How large is this group of agents?	developers (2), sysadmins (2), intranet users (4), partners (5), authenticated users (6), anonymous Internet users (9)

The factors are averaged per *(threat, threat-source)* pair. For the threat **DDoS attack on the central system**:

- **Script kiddie** — Skill 3 (unskilled, cannot run complicated attacks), Motive 1 (weak), Opportunity 7 (ample cheap resources), Size 7 (script kiddies reside anywhere in the world) → **AVG 4.5**.
- **Cyber-terrorist** — Skill 7 (significant resources and skill, sometimes nation-state support, capable of long-term planning), Motive 8, Opportunity 7, Size 3 (far fewer than script kiddies) → **AVG 6.25**.

The 0–9 range is then mapped **uniformly** onto the five-level likelihood scale, in equal bands of 1.8:

Interval	Likelihood
0 – 1.8	Rare
1.8 – 3.6	Unlikely
3.6 – 5.4	Possible
5.4 – 7.2	Likely
7.2 – 9	Certain

Taking the **worse case** of the two scores (6.25 for the cyber-terrorist falls in 5.4–7.2), the DDoS threat is estimated **Likely** — an estimate then checked against the event logs and confirmed by the operator's participants. Iterating over all identified threats yields the malicious threat-likelihood table: DDoS → **Likely**; tampering with control data to the choke (all/most) → **Possible**; tampering with data from the metering terminal → **Possible**; malware installed via the external meter → **Possible**; metering node infected by malware → **Rare**; tampering with control data to the choke for selected customers → **Unlikely**; illegitimate control data from the central system → **Unlikely**.

4.2 Analysing Non-Malicious Threats

For non-malicious threats OWASP is inapplicable — **there is no attacker** whose skill, motive, opportunity, and size could be scored. The likelihood is instead taken from **event logs, expert judgement, interviews or questionnaires, and published statistics** about how often similar threats occur in comparable organizations. Historical data carries the estimate; for instance, *mistakes during update/maintenance of the central system* is judged **Certain** on the basis of the operator's own record.

4.3 Analysing Vulnerabilities

Vulnerability severity is rated on a simple three-step scale — **Low (0–3), Medium (3–6), High (6–9)** — again using information from expert judgement, statistics, open repositories, and the output of **vulnerability scans, security testing, penetration testing, and code review**. For *malicious* threats the OWASP-inspired rating uses four factors on 0–9:

Factor	Question	Example anchors (score)
Ease of discovery	How easy is it to discover this vulnerability?	practically impossible (1), difficult (3), easy (7), automated tools (9)
Ease of exploit	How easy is it to actually exploit it?	theoretical (1), difficult (3), easy (5), automated tools (9)
Awareness	How well known is it to the agents?	unknown (1), hidden (4), obvious (6), public knowledge (9)
Intrusion detection	How likely is an exploit to be detected?	active detection (1), logged and reviewed (3), logged without review (8), not logged (9)

Five malicious-threat vulnerabilities were identified in Step 2. Scoring *Inadequate attack detection and response on the central system* gives ease-of-discovery 7, ease-of-exploit 5, awareness 6, intrusion-detection 7 → **AVG 6.25 → High**. Iterating yields: *Inadequate attack detection and response* → **High**; *Weak encryption and integrity check* → **Medium**; *Unprotected local network, no sanitation of input from the*

external meter → **Medium**; *Outdated antivirus protection on the metering node* → **High**; *Four-eyes principle not implemented, no logging of central-system operator actions* → **High**.

For *non-malicious* threats there is **no intent to discover and exploit**, so the four OWASP factors make no sense; instead the analyst gauges **the extent to which barriers are missing** that would stop a threat from becoming an incident. The four non-malicious vulnerabilities (Table 8.4) are: *Single communication channel between central system and metering terminal* → **High** (the Internet is the sole channel for many customers); *Poor testing* → **Medium** (maintenance logs reveal recurring undiscovered bugs; the external software provider's testing is unsatisfactory and the operator does not test updates before deployment); *Poor training and heavy workload* → **Medium** (security awareness is low and key staff are overloaded, though the central-system review/testing routines are strong); *Inadequate overvoltage protection* → **High** (the metering-terminal hardware is not robust to transient overvoltage).

4.4 Likelihood of Incidents

An incident's likelihood is derived by combining the likelihood of the **threat** that causes it with the severity of the **vulnerability** it exploits. For the malicious incident *Data from metering nodes cannot be received by the central system due to DDoS attack*, the logs show only two such incidents in three years (which alone would read **Possible**), but an **increasing trend** of this incident type pushes the estimate up; even allowing that successful attacks are fewer than attempts, the incident frequency is judged to lie in **Likely** — matching its threat (DDoS, Likely) and vulnerability (Inadequate detection, High).

The non-malicious case shows how the same threat can yield different incident likelihoods. The threat *mistakes during maintenance* is **Certain**, and at first glance its two incidents — disrupting control signals to the choke, and preventing reception of metering-node data — look equally frequent. But the operator has **routines for reviewing and testing changes before launch**, and because *provisioning of power* is more critical than the continuous reading of meter data, those routines are **stronger for changes that may affect control data**. Combined with the logs, this lowers the choke-control incident to **Unlikely** while leaving the meter-data-reception incident at **Possible** — identical threat, different incident likelihoods, because the protective barriers differ.

4.5 Consequences of Incidents

Each incident's consequence is judged **for every asset it harms**, read off the relevant per-asset consequence scale, which requires estimating the **expected time to detect and respond** and the **number of affected customers**. For the DDoS incident, the operator's internal investigation reports show that past DDoS attacks **never caused unavailability for more than one day**; however, because the **customer base has grown**, the number of customers whose meter data becomes unavailable can now be higher than before — netting out to a consequence of **Moderate**.

Carrying this through all incidents produces the two master tables of the analysis, numbered 1–8 (malicious) and 9–17 (non-malicious):

No.	Incident (malicious)	Asset	Likelihood	Consequence
1	Metering-node data not received due to DDoS	Availability of meter data	Likely	Moderate
2	False control data received by all/most choke components	Provisioning of power	Unlikely	Critical
3	False meter data for a limited number of customers	Integrity of meter data	Likely	Minor

No.	Incident (malicious)	Asset	Likelihood	Consequence
4	Malware compromises meter data	Integrity of meter data	Rare	Moderate
5	Malware disrupts transmission of meter data	Availability of meter data	Rare	Moderate
6	Malware disrupts the choke functionality	Provisioning of power	Rare	Major
7	False control data to choke for selected customers	Provisioning of power	Rare	Insignificant
8	Power switched off without legitimate reason	Provisioning of power	Unlikely	Moderate

No.	Incident (non-malicious)	Asset	Likelihood	Consequence
9	Communication central ↔ metering terminal is lost	Provisioning of power	Certain	Minor
10	Same (communication lost)	Availability of meter data	Certain	Insignificant
11	Software bug compromises meter data	Integrity of meter data	Unlikely	Moderate
12	Software bug disrupts transmission of meter data	Availability of meter data	Unlikely	Moderate
13	Software bug disrupts the choke functionality	Provisioning of power	Rare	Major
14	Maintenance mistakes disrupt control data to choke	Provisioning of power	Unlikely	Moderate
15	Maintenance mistakes prevent reception of meter data	Availability of meter data	Possible	Minor
16	Metering terminal down due to lightning	Provisioning of power	Likely	Insignificant
17	Same (lightning)	Availability of meter data	Likely	Insignificant

5. Step 4 — Risk Evaluation

Evaluation keeps its four sub-steps, applied here with the cyber habit of holding malicious and non-malicious risks apart until grouping brings them back together.

Consolidation of risk analysis results. The goal is to confirm the **correct risk level** is assigned to each risk — and the central question is *not* whether every likelihood and consequence estimate is individually perfect, but whether the resulting **risk level** is right. Two contrasting examples make the point. For risk 4, *Malware compromises meter data* (Rare, Moderate → **Low**), even raising the likelihood to Unlikely leaves the level **Low**, so the distinction between those two likelihoods is immaterial and not worth more investigation. For risk 15, *Maintenance mistakes prevent reception of meter data*, uncertainty over whether the consequence is Minor or Moderate **does** matter, because it moves the risk level from **Low to Medium** — so that uncertainty must be resolved. Consolidation is also where the assessment checks for risks that are **both malicious and non-malicious** — the case where a malicious and a non-malicious threat lead to the *same incident*, appearing in both tables. In such cases the likelihood and

consequence estimates must be **consistent**, with *both* causes accounted for in the likelihood — an easy thing to overlook precisely because the two classes were handled separately for so long.

Evaluation of risk level. Each risk is plotted in the risk matrix according to its likelihood and consequence, producing **two matrices**, one per class.

Malicious risks (1–8):

Consequence \ Likelihood	Rare	Unlikely	Possible	Likely	Certain
Critical		2			
Major	6				
Moderate	4, 5	8		1	
Minor				3	
Insignificant	7				

Non-malicious risks (9–17):

Consequence \ Likelihood	Rare	Unlikely	Possible	Likely	Certain
Major	13				
Moderate		11, 12, 14			
Minor			15		9
Insignificant				16, 17	10

Risk aggregation. Some risks "pull in the same direction" strongly enough to be evaluated as one. **Case 1** arises when a single **incident X harms two assets A and B**: each may be low alone, yet their **joint consequence** may warrant a higher level — the aggregated risk keeps the same likelihood but takes the combined consequence. **Case 2** arises when **several incidents of the same nature, triggered by the same threat, harm the same asset**: individually low, their combined effect may be higher. Going through the incident tables, **no single incident harms more than one asset, so Case 1 does not apply**. Case 2 does: risk 4 (*Malware compromises meter data*) and risk 11 (*Software bug on the metering terminal compromises meter data*) both concern **software on the metering node** harming **integrity of meter data**, so they merge into a generic *Software on the metering node compromises meter data* — with **likelihood rising from Rare/Unlikely to Possible** while the consequence stays Moderate. By the same reasoning risks **5 and 12**, and **6 and 13**, are aggregated; the rest are retained.

Risk	Likelihood	Consequence
(4) Malware compromises meter data	Rare	Moderate
(11) Software bug compromises meter data	Unlikely	Moderate
(4+11) Software on the metering node compromises meter data	**Possible**	**Moderate**

The matrix after aggregation merges the two classes:

Consequence \ Likelihood	Rare	Unlikely	Possible	Likely	Certain
Critical		2			
Major	6, 13	(6+13)			
Moderate		8, 11, 12, 14	(4+11), (5+12)	1	
Minor			15	3	9
Insignificant				16, 17	10

Risk grouping. Finally, risks that would **benefit from the same treatment** are grouped, so that treatment selection can consider them together. The assessment systematically asks, for each pair of risks, whether they have something in common pointing to a shared remedy — for example, two risks each sitting one step (in likelihood or consequence) away from **Medium**, where a single treatment addressing both is quite likely to be worth its cost. Grouping is deliberately where the malicious/non-malicious wall comes down, because the only thing that matters now is the **shared mitigation**.

6. Step 5 — Risk Treatment

Treatment begins by **identifying treatments for selected risks**, then assessing their effect and deciding whether the **residual risk** is acceptable; if it is, the documentation is finalized and the process ends, otherwise another iteration of treatment identification follows.

Selecting the risks to treat. Since time and resources are always limited, the assessment cannot treat everything and so **selects the most important risks** from the evaluation results — those in the higher-risk cells of the aggregated matrix.

Documenting each treatment. For each selected risk a small table records the risk number, incident, asset, threat source, threat, attack point, vulnerability, and proposed treatment. For risk 1:

Element	Value
Risk n.	1
Incident	Data from metering nodes cannot be received by the central system due to DDoS
Asset	Availability of meter data
Threat Source	Script kiddie; Cyber-terrorist
Threat	DDoS attack on the central system
Attack Point	Internet connection to the central system
Vulnerability	Inadequate attack detection and response on the central system
Treatment	Implement state-of-the-art DDoS detection and response mechanism on the central system

Here the two distinctive features of cyber-treatment appear. First, treatments are **highly technical** — acting on the infrastructure (reconfiguring a firewall, updating router policies, deploying detectors) — but when the technical lever is unavailable (a server that cannot be upgraded for compatibility reasons), the assessment turns to **non-technical** means: **training** the staff who operate the machine and, in parallel, adding **compensating monitors**. Second, the **malicious/non-malicious class influences which treatment fits best**, yet a **single treatment may benefit several risks across both classes** — exactly the efficiency that grouping was designed to surface.

Risk acceptance and cost–benefit analysis. Every treatment carries a cost, so its **effect** (reduced risk level for the affected risks) is weighed against that cost, qualitatively or quantitatively. For the DDoS treatment on risk 1 (risk level **High**), the reasoning is instructive: the treatment will **hardly prevent** script kiddies or cyber-terrorists from *launching* attacks — **no effect on the threat** — but **early detection reduces the likelihood that an attack becomes the incident**, moving likelihood from **Likely to Possible**, and a **prompt response** means fewer customers are affected for a shorter time, moving the consequence from **Moderate to Minor**. The combined effect drops the risk level from **High to Low**. The cost, however, is **High**: the treatment requires significant investment in hardware and network infrastructure, and assembling an adequate set of detectors (ideally combining anomaly-based and signature-based approaches) takes real time and effort.

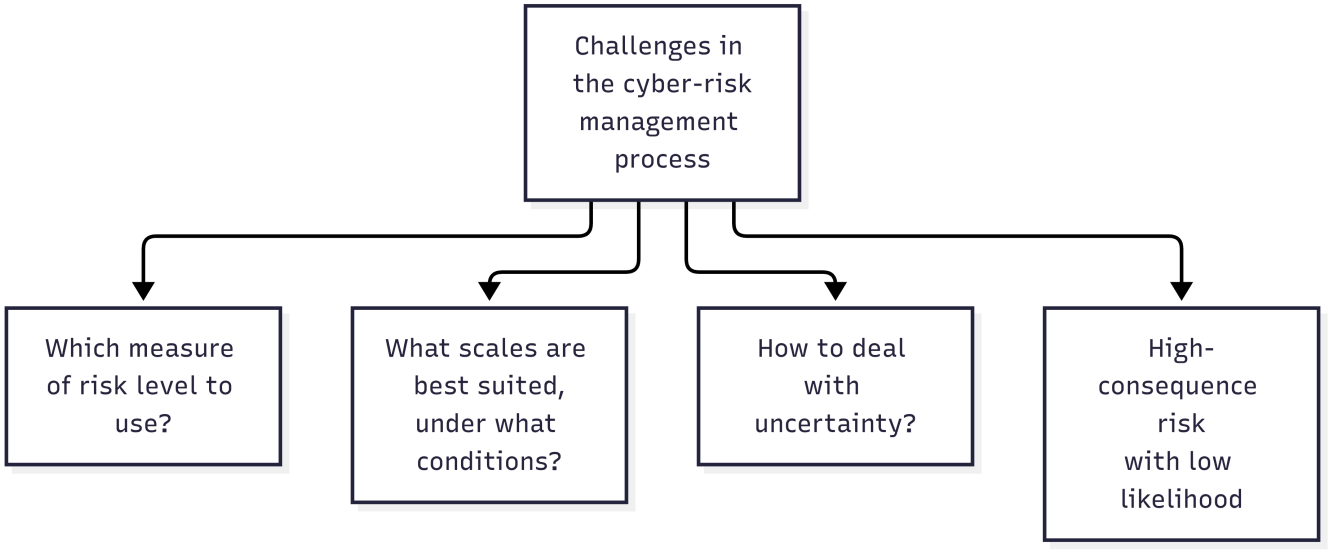
Iterating over the selected risks produces the final **effect-of-treatments** table, which is the deliverable the whole assessment has been building toward:

Treatment	Risk	Effect	Cost
Implement state-of-the-art DDoS detection and response on central system	1	High → Low	High
Stronger integrity checking of received meter data on central system	4; 11; (4+11)	Low→Low; Low→Low; **Medium→Low**	High
Hire more staff	14, 15	Low → Low	High
Develop executable scripts for routine maintenance tasks	14, 15	Low → Low	Low

The table captures the economic reality that runs through the entire discipline. The DDoS treatment buys a dramatic reduction (High → Low) but at high cost, and must be justified against the operator's budget. "Hire more staff" and "develop executable scripts for routine maintenance" both address risks 14 and 15 with the same Low→Low effect, but at **High versus Low cost** — so the scripting treatment is plainly the better buy for the same benefit, a decision only visible because the risks were grouped by shared mitigation. And the residual-risk logic closes the loop: the risks that remain in the **green (Low)** cells of the matrix are **typically treated by acceptance** — an informed decision to retain them because the cost of further treatment is not justified by the small reduction it would bring. With treatments selected, their effects estimated, and the residual risks judged acceptable, the documentation is finalized and the cyber-risk assessment of the AMI is complete.

CHAPTER 3_tetrakis: Risk Management: Challenges and Guidelines

Having walked a complete assessment end to end, it is tempting to think the method is now simply a matter of execution. It is not. Every estimation in that case study concealed a choice that could have been made differently, and each of those choices is a place where a real assessment can quietly go wrong. This chapter steps back from the mechanics to confront the **main challenges that arise during the estimation process**, and to set out guidelines for handling them. Four questions organize the discussion, and they correspond to the four genuine decision points an assessor faces once the procedure is understood: **which measure of risk level to use**, **what scales are best suited under what conditions**, **how to deal with uncertainty**, and **how to handle high-consequence risks of low likelihood**.

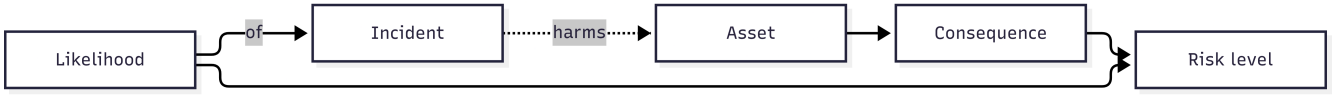


1. Which Measure of Risk Level to Use?

Risk can be described from several points of view, and the first challenge is to choose the right **factors** through which the risk level will be measured — because the measurement, once chosen, fixes what the rest of the assessment can say. The choice is essentially a choice of **how many factors** to decompose the risk into: two, three, or many. The three models are not rivals so much as instruments suited to different heights in the organization.

1.1 The Two-Factor (Classical) Measure

The most general definition characterizes risk by just two factors: the **consequence** (the loss of asset value when a potential incident occurs) and the **likelihood** (how often this happens). This is the classical two-factor measure used throughout the case study, and when only two factors are in play things are simple — the risk level is fully determined by them. The likelihood here is tied to a **specific incident**, while the consequence is defined by looking at the **asset**, in connection with that incident.



This characterization belongs at the **top of the hierarchy**, with strategic management. When risk information must be reported at a high level, more elaborate models are useless: following the **Von Solms** principle that information should be **aggregated as it rises**, it is better to collapse everything into few factors than to hand executives a count of ten vulnerabilities. The price of that aggregation is a **loss of sensitivity**: collapsed into two factors, many distinct risks come to look equal to one another. At the top level this is not a problem — strategic management still grasps that there *are* issues and can act on them. The trouble only appears lower down.

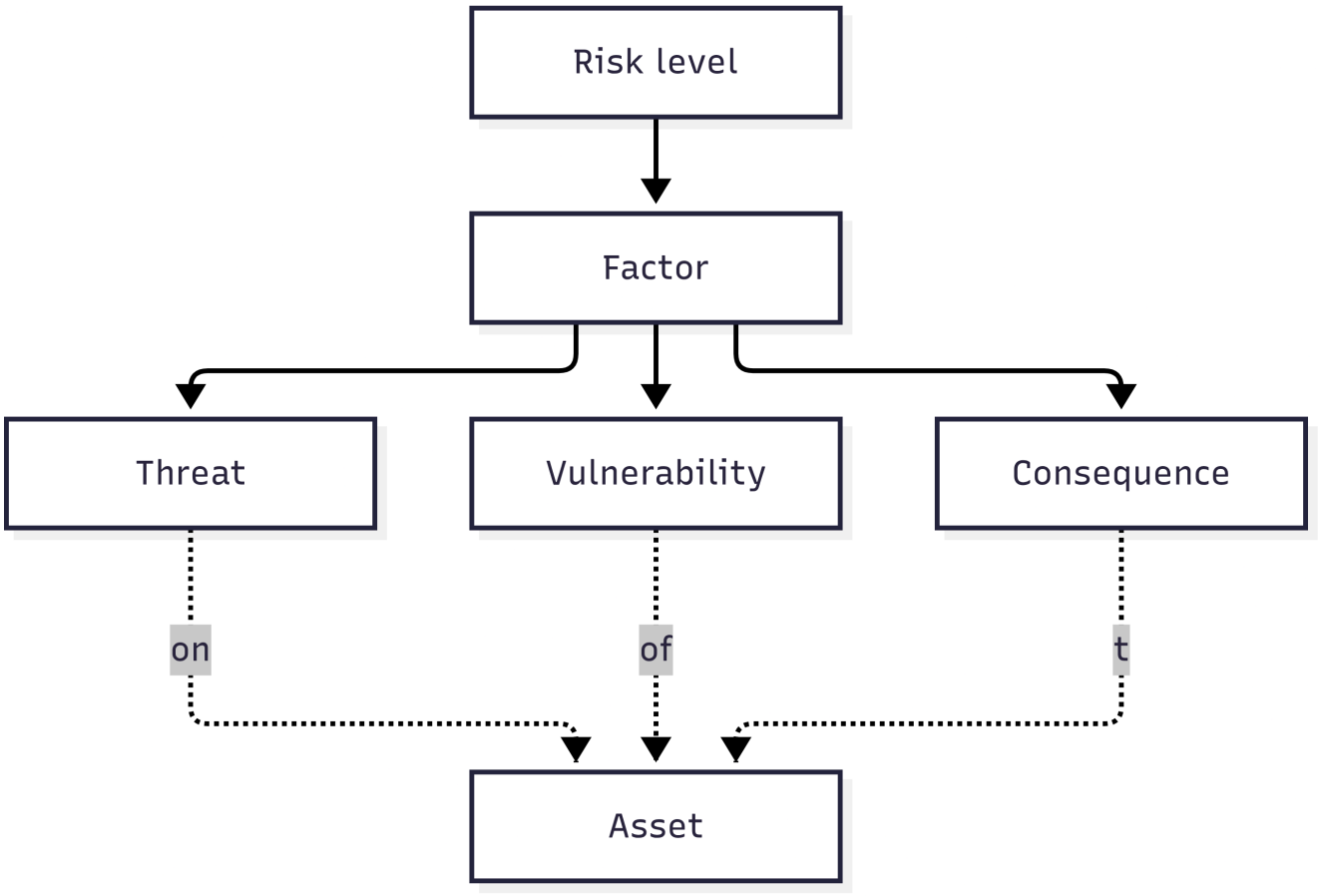
1.2 The Three-Factor Measure

Sometimes it helps to say more precisely what "likelihood" means, by decomposing the probability itself. The **NIACAP** standard defines risk as "*a combination of the likelihood that a threat will occur, the likelihood that a threat occurrence will result in an adverse impact, and the severity of the resulting impact.*" The key move is splitting likelihood into **two distinct probabilities**:

- the probability that **a threat will occur** — a measure of the extent to which the target is *subject to* a certain threat, estimated by studying the company and its environment; and

- the probability that **the threat occurrence will result in an incident** — a measure of the **vulnerability** of the target with respect to that threat.

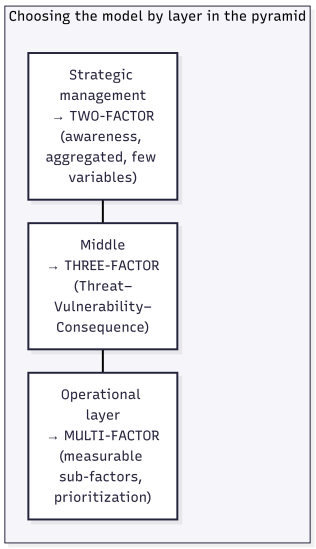
The distinction matters because the mere existence of a threat does not guarantee an incident: the attacker *tries* to materialize the threat, but there is a probability the attempt succeeds and a probability it does not. The result is a **three-factor model** built on **Consequence, Threat, and Vulnerability**, where threat and vulnerability are first analysed **independently** and only then combined into the likelihood — with everything related back to the asset, and the vulnerability becoming relevant only when considered together with a specific threat on a specific asset. This is exactly the model used in the AMI case study, and it sits at a **middle point** in the hierarchy.



1.3 The Many-Factor (Multi-Factor) Measure

At the operational layer still more points of view open up, and some methodologies — **OWASP** is the example — analyse **threats and vulnerabilities under separate factors**. The likelihood can be decomposed into the probability that a specific threat agent is *interested* in a threat, that the threat *happens*, that it *materializes*, and so on, each combined back together; and the consequence can likewise be split into **technical impact** factors and **business impact** factors (a technical damage may cost little in business terms). Considering all these perspectives **refines the model** and yields additional information — but only if there is **data** to quantify each factor.

The payoff of the multi-factor model is richer differentiation. Where the aggregated models make many risks look equal, a multi-factor model gives many variables to hold in mind and therefore supports **different prioritizations** of otherwise similar risks. Since the ultimate aim is to protect the infrastructure **without losing money** — to optimize treatment in a cost–benefit manner — this finer prioritization is precisely what the people "close to the stuff" need. The multi-factor model is used close to the operational layer.



The contrast between the two ends is worth stating plainly. The **three-factor** model is simple and conceptual (Threat–Vulnerability–Impact), good for awareness and high-level decisions, but offers limited differentiation — many risks look "equal." The **multi-factor** model breaks probability and impact into measurable sub-factors, giving more objective and repeatable scoring and enabling smarter prioritization. In a phrase, the multi-factor model is the move **from *understanding* the risk to *managing* it effectively**.

1.4 Which Measure to Use for Cyber-Risk

There is no universally correct answer: the approach and the way it is used **depend on the context and the risk-assessment situation**, with the position in the pyramid as a first guide and several practical considerations layered on top.

The dominant parameter is **data availability**. With good data on frequency and consequence, one will probably go for the **two-factor** approach; to use a multi-factor model one *needs* the data to instantiate it, and without that data the model collapses. Within cybersecurity, the popularity of multi-factor measures is **growing**, precisely because at the bottom of the stack cyber-systems generate logs automatically for a large number of indicators — though measuring likelihood with a reasonable degree of uncertainty remains difficult in practice. A sharper way to put the data problem: *the problem is usually not the lack of data, but the lack of the **right kind** of data with respect to the predefined factors.* When the logged indicators do not match the factors, one may **define one's own risk function** from factors that match those indicators — a move that, as the slides warn in red, **requires experience and great care**. Cybersecurity also offers technologies for **data correlation** that help bridge raw data to the chosen factors. Finally, information does not come only from the environment but also from **experts and stakeholders**, and when it does, two guidelines apply: make sure the factors are **carefully defined and easy to keep apart**, and **select the right kind of scale for each factor** — which is the next challenge.

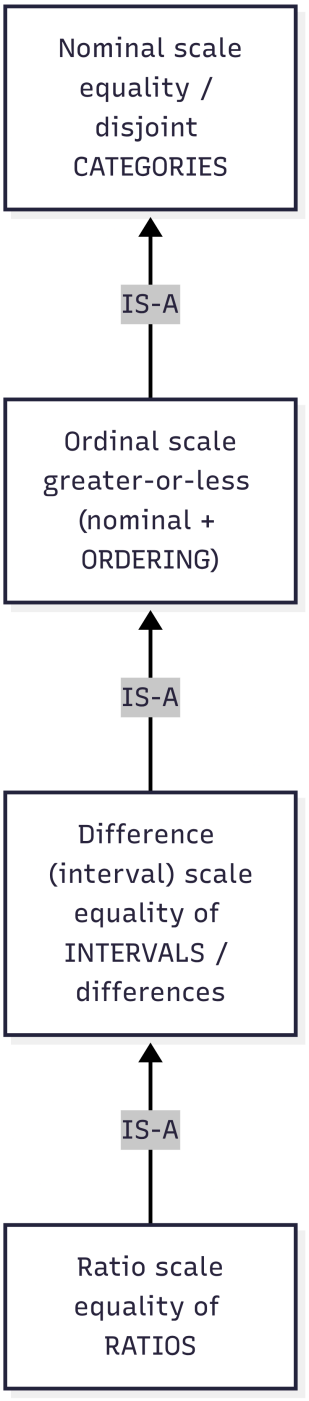
2. What Scales Are Best Suited, Under What Conditions?

Choosing the number of factors is only half the measurement problem; each factor still needs a **scale**, and the scale is a problem in its own right. The suitability of a scale depends on **the factor in question**, **the kind of risk assessment being conducted**, **the target of assessment**, and **the available data sources**. Beyond fitting the factor, a scale must suit the *type* of assessment: if the analysis is multi-factor but its output must reach **top management**, risk cannot be reported as raw numbers, because executives do not know what those numbers mean. The range of values must therefore be chosen

deliberately — a preliminary assessment need not be precise and can stay **qualitative**, whereas greater refinement calls for **quantitative** evaluation with more values per scale — and there must be enough data to actually distinguish the levels of whatever scale is chosen.

2.1 Classification of Scales

Scales form an **IS-A hierarchy**, each level adding a capability to the one below it:



- A **Nominal scale** allows the determination of **equality** and represents **disjoint categories** — for example "non-human threat source," "accidental human threat source," "intentional human threat source." It can group elements into classes and tell which risks look equivalent, but says nothing about order.
- An **Ordinal scale** adds **ordering** (greater or less) on top of the nominal categories — for example "minor," "moderate," "major."

- A **Difference (interval) scale** allows the determination of **equality of intervals or differences**: equal differences at the level of values correspond to equally distinct phenomena. The **Celsius** scale is the canonical example — a 10 °C difference between two correct measurements reflects the same temperature difference whether the pair is (−10, 0) or (100, 110) — but it has no meaningful zero, so ratios are not defined.
- A **Ratio scale** adds a true zero and so allows the determination of **equality of ratios** — for example "the number of identity thefts in Europe per year" or "the amount of financial loss (€) caused by cyber incidents per year," where statements like "twice as many" are meaningful.

The first two levels (nominal, ordinal) are **qualitative**; the latter two (difference, ratio) are **quantitative**.

2.2 Qualitative Versus Quantitative Assessment

The qualitative/quantitative split is not a matter of taste but of what the information allows. **Quantitative** assessment fits when the information to be quantified is **homogeneous**, and it tends to work better when the assessment is at a more **technical** level or requires a **fine level of granularity**. **Qualitative** assessment is for information that is **not homogeneous** — reputation, political impact, public perception — where a single number would be a fiction.

A crucial asymmetry governs movement between the two: **going from quantitative to qualitative is easy, but the reverse is difficult.** Quantitative is attractive in theory, since it lets one define functions and algorithms and set up optimization problems, yet in practice it often fails for want of the data needed to instantiate the model — and then everything collapses. A **purely qualitative** approach, on the other hand, is **not satisfactory on its own**, because the result of any risk assessment must ultimately be converted into a quantitative scale (typically **costs measured in money**) to support a cost–benefit decision. The guideline is therefore to **merge the two**: stay quantitative as far down as the data allows, switch to qualitative where limitations arise (missing or imprecise data), and **aggregate toward the qualitative as one moves up the pyramid**. The deeper one is in the operational layer, the more quantitative the assessment; every risk must eventually be translated into numbers — cost, time, or impact avoided — and the art is **balancing quantitative precision with qualitative practicality**.

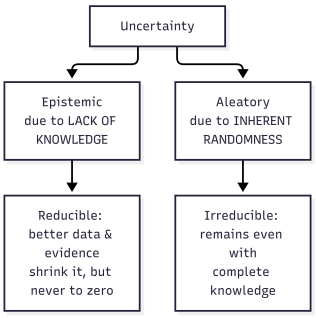
For **likelihood** specifically, there is much uncertainty in the measurements, and estimates often rest on historical data that are not always accurate enough. The advice is to **avoid complicated probabilities**; where probabilities are used, accompany them with explicit information about the uncertainty that decision makers can use; and **avoid continuous scales in favour of ranges** (e.g. Rare / Unlikely / Possible / Likely / Almost Certain), because broad categories **reduce the illusion of precision** and support more reliable decisions. For **consequence**, recall that it is ultimately tied to the **treatment** phase — we must weigh the cost and the gain of treating, an indirect evaluation of the consequence — so when defining a consequence scale one should keep in mind the criteria of the later cost–benefit analysis, and define a **specialized scale for each asset** fitted to its intended usage (a scale good for communicating with decision makers may be unsuited to technical discussions). The difficulty is uneven across assets: if the asset is a **bag of diamonds**, the consequence equals the monetary value stolen; if it is the **integrity of a customer database**, one can count the records harmed but not easily say what that means in euros (so the scale may be records-stolen over the whole database, or compared against the past); if it is the company's **reputation**, both the impact and its euro equivalent are hard even to characterize. The typical cyber practice is to associate consequences with **direct and indirect costs** not directly in money but through a **cost function** that is then mapped onto economic factors.

Cyber-risk has one **simplifying** feature and one **complicating** one. The simplifying feature is that cyber-risk concerns systems which are **largely computerized**, and computerized parts are well suited to automatic measurement and logging. The complicating feature is the **openness of cyberspace** and the frequent need to measure **human intentions and skills**, which resist quantification.

3. How to Deal with Uncertainty?

No amount of quantitative rigour removes uncertainty; it will always be present, and the task is to **represent it correctly**. ISO 31000 defines uncertainty as "*the state, even partial, of deficiency of information related to, understanding or knowledge of an event, its consequence, or likelihood.*"

3.1 Two Kinds of Uncertainty



Epistemic uncertainty arises from a **lack of knowledge**: if knowledge were perfect it would disappear, and better data and evidence can reduce it — though in practice knowledge is never perfect, so some epistemic uncertainty always remains. **Aleatory uncertainty** arises from **inherent randomness** in the process and cannot be controlled; the clean test is that *if uncertainty remains even with complete knowledge, it is aleatory, not epistemic.* The discipline concentrates on the **epistemic** kind, which it attacks through data collection and data analysis, while measuring how much uncertainty remains and how much it affects the results.

3.2 Representing Uncertainty

Representation depends on the scale. With a **quantitative** scale, uncertainty is represented by **intervals**, the **width** of the interval expressing the level of uncertainty; how much is tolerable depends on how the uncertainty impacts the **decision procedure**. Plotted in the risk matrix, a risk acquires a **confidence interval** in each direction — one horizontal (likelihood) and one vertical (consequence) — defining a region of how many mistakes can be tolerated. The dangerous case is a risk whose interval straddles a boundary so that the **uncertainty could change its risk level** (a risk hovering between Moderate and Minor): to judge whether the uncertainty is tolerable, the information must be represented *together with* its uncertainty.

With a **qualitative** scale, uncertainty is instead expressed as a **separate attribute** — a natural-language label attached to each measurement on its own ordinal scale — rather than plotted. A consequence table can then carry an extra **Uncertainty** column, so that two incidents with the *same* consequence are distinguished by our confidence in the estimate (one "No" uncertainty, the other "Considerable"). This documentation belongs in the report accompanying the risk assessment. The visual and the explicit representations are **not alternatives but complementary tools**.

Incident	Consequence	Uncertainty
Information leakage	Low	Some
Breakdown of server	High	No

Incident	Consequence	Uncertainty
Identity theft	High	Considerable
Spyware installed	Medium	Some

3.3 Reducing Uncertainty

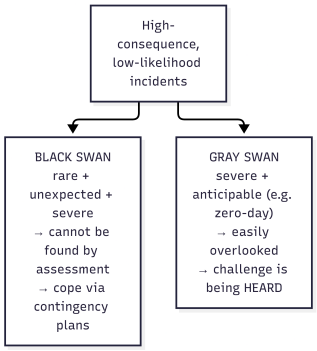
Beyond representing it, epistemic uncertainty can be actively **reduced** using data already acquired, by several methods: **fuzzy logic**; **iterating data collection** (improving the quality of the data); **comparative analysis** (comparing the situation under investigation with what is already known); and **testing** the risk model against historical data, or conducting surveys across larger groups of stakeholders — in effect, testing whether the issue is really there.

4. High-Consequence Risk with Low Likelihood

The last challenge concerns the risks that the matrix is worst at handling: those that are **unlikely but devastating**, sitting in the "yellow" borderland where a routine assessment is tempted to let them pass. Two species must be told apart.

A **black swan** is an incident that is **extremely rare and unexpected** but has **very significant consequences**. Black swans are, by their nature, **not likely to be discovered by risk assessment** at all — they are the genuinely unforeseen. The right response is therefore not better estimation but preparation: **developing good contingency plans** is the best way to cope with them, and the existence of a risk assessment does **not** make contingency planning (preparing and planning for major incidents and disasters) obsolete. Their danger is exactly that they occupy the low-likelihood region yet carry critical impact.

A **gray swan** also has far-reaching consequences, but **unlike a black swan it can be anticipated to a certain degree** — the archetype being a **zero-day vulnerability**: we assume our system is not free of them and try to estimate what could happen. The characteristic danger of gray swans is that they are **easily overlooked** — they may not appear in the documentation we take as input, we may be interacting with the wrong stakeholders, or we may be unable to extract the required information — even though, **by definition, a relevant gray swan is known *somewhere* in the organization**, if not documented then implicitly in stakeholders' knowledge or inferable from existing data.



Because a gray swan is in principle knowable, the real challenge is **not estimating it but making sure it is heard**. Communicating it well means defining an effective process to convey the message to managers: **using probability is not recommended**; when a quantitative scale is used it should **always carry a reference**; and if there is **considerable uncertainty**, that must be communicated to the relevant decision makers.

Handling a gray swan then becomes a **treatment** decision aimed at helping the decision makers. The lever is **cost of treatment**. When the cost is **Low**, simply treat the gray swan — reducing both its likelihood and its consequence. When the cost is **High**, there is no free move, and the decision is a genuine **trade-off between the cost of treatment and the residual severity of the risk**. The textbook example is a **healthcare data breach**: strong but costly **prevention** weighed against **rapid detection and response planning**, which is less costly but leaves more residual risk. In the end, for gray swans the decision is exactly that balance — what it costs to reduce the risk against how severe the risk remains after treatment.

CHAPTER 4: Auditing

Part 1 — Foundations of Auditing

1.1 What Auditing Is

Auditing is the systematic and independent evaluation of processes, systems, and controls carried out to establish whether an organization's objectives are actually being achieved — effectively, securely, and in a way that can be demonstrated to others. The emphasis on *systematic* and *independent* is deliberate: an audit is not an informal opinion or a casual review, but a structured examination that follows a defined method and is conducted by someone who is not responsible for the thing being examined. This independence is what gives the conclusion its value.

Three terms form the conceptual backbone of the discipline, and they must be kept distinct.

Audit is the independent, objective evaluation of whether controls, processes, or activities meet *defined criteria*. The phrase "defined criteria" is not decoration. Criteria are indispensable, because without an agreed reference point there is simply no way to evaluate anything — a judgment of "good" or "adequate" is meaningless unless it is measured against a stated standard, policy, or requirement. Everything an audit concludes is a comparison between observed reality and some pre-established benchmark.

Compliance is the degree to which an organization actually follows the applicable rules, standards, or internal policies. The key idea is *degree*: compliance is not a binary yes/no but a measurement. The purpose of assessing compliance is to quantify, as precisely as possible, the alignment between the criteria on one side and what has actually been implemented on the other. An audit therefore does not merely ask "do they comply?" but "how closely, and where are the gaps?"

Assurance is the independent confidence that information, controls, or processes are reliable and effective. Assurance is the ultimate product of the whole exercise — it is the confidence that the auditor provides to the organization (or to its stakeholders) on the back of the assessment that was actually performed. When an organization says it wants "assurance," it is asking for a credible, independent statement that things are as they are claimed to be.

The competencies this discipline builds on can be summarized as the ability to **define** audit and assurance within a cybersecurity context, to **explain** the principles of risk-based auditing, to **identify** the major controls and governance structures, to **describe** IT general controls and their relevance to information integrity, and to **apply** audit reasoning to evaluate cybersecurity and compliance mechanisms. Underlying all of these is a single methodological requirement: wherever possible, conclusions must rest on *measurement*, and every measurement and every judgment must be supported by **evidence**. This bridges classical audit theory with contemporary cybersecurity practice, treating risk-based approaches, evidence collection, and control verification as the practical tools of organizational assurance.

1.2 Why Auditing Matters

Auditing is not a bureaucratic overhead; it is one of the core processes that make **digital trust** possible. Digital trust depends on the demonstrable integrity of systems and data — "demonstrable" being the operative word, because trust that cannot be shown to a third party is not trust that an organization can rely on commercially or legally. Auditing is precisely the mechanism that transforms technical compliance into *credible assurance*, and in doing so it enables transparency, accountability, and stakeholder confidence in an organization's cybersecurity posture. It provides an objective and independent way to state that a given process, system, or information-security component genuinely behaves as it is asserted to behave.

The most important structural property of auditing is that it is **evidence-based**. The auditor cannot leave anything to chance and cannot leave anything unexplained: every conclusion must be traceable to concrete evidence. This single principle shapes almost every practical decision in the audit process — what to test, what records to collect, how to protect those records from tampering, and how to reason from them to a defensible conclusion.

It is essential to distinguish auditing from **inspection**. Inspections are rule-based and essentially punitive: they are performed by inspectors against a fixed set of rules, in a uniform way, and their purpose is to detect and sanction non-conformity. Auditing is different in orientation. Rather than mechanically checking rules, an audit aims to understand whether governance, risk management, and control mechanisms *adequately support the organization's strategic objectives*, and it does so by building an evidence-based, risk-focused picture of how well controls are designed and how effectively they operate. This difference between the two mindsets becomes especially visible during certification, where the roles of auditor and inspector are kept clearly separated.

1.3 A Short History

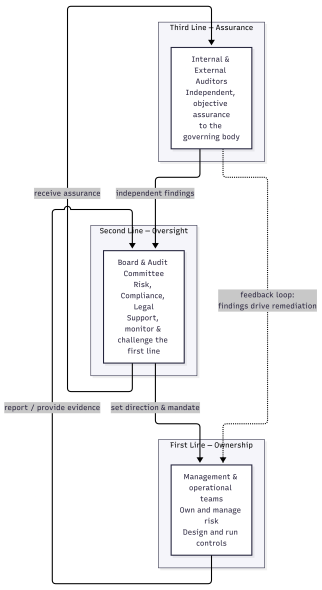
Auditing began, quite literally, because of money. Its earliest formal use was in the economic domain, where it served to verify records and reduce errors or fraud in early economic systems. At that stage it was essentially about checking **transactions** and confirming that **accounts** were accurate — providing evidence for what lay behind each transaction. As organizations grew larger and more complex, this simple verification activity became progressively more structured.

Modern internal auditing emerged in the early twentieth century, when organizations needed a more formal way to review their operations and internal controls. A decisive milestone came in **1941**, with the founding of the **Institute of Internal Auditors (IIA)** and the publication of the first major book on internal auditing. This marked the point at which internal auditing became a recognized profession with its own identity, language, and standards, and it allowed audit practice to spread well beyond finance into many other domains — including, for our purposes, information security.

The IIA is the global professional association and standard-setting body for the internal audit profession. It defines what internal auditing is, sets the rules and guidance that practitioners must follow, and supports auditors through certification, education, research, and advocacy. In other words, it is the global foundation that grants the profession its guidelines and best practices, with the explicit mission of supporting the role and the tasks of auditors in carrying out their work. Today, auditing is tightly bound to governance, assurance, and accountability — especially in complex and digitally dependent organizations.

1.4 Roles and Responsibilities: The Three Lines Model

Auditing works through a set of clearly separated roles, and the governing principle is simple: **management owns the controls, while audit provides independent assurance on whether those controls actually work**. If the people who run a control were also the ones who judged it, the judgment would not be independent — so the responsibilities are deliberately divided into three hierarchical "lines."



The **first line** consists of management and the operational teams. These are the people who own and manage risk and who design and run the controls. Management is the **owner of the risk** and the first accountable party whenever a weakness is identified: it is responsible for designing, implementing, and maintaining controls; it responds to audit findings, defines corrective actions, and ensures remediation is completed. Because the first line ultimately bears the consequences of any damage or impact, it is also the party that decides which controls must exist in the first place and, by extension, which controls will need to be assessed. Conceptually this is the top of a governance pyramid: risks and their owners are defined first, high-level criteria are set, and the loop closes through feedback from the controls that are actually operated.

The **second line** comprises the board and the audit committee, together with risk, compliance, and legal functions. Its role is to support, monitor, and challenge the first line. The board sets **direction**, approves the audit mandate, and oversees the entire assurance system; the audit committee is the body that receives internal audit reports, monitors significant findings, and follows up on remediation. The defining characteristic of the second line is that its role is **oversight, not execution** — it sits between the board and the people doing the operational work, translating high-level governance intentions into the language and priorities of audit, challenging management, and using audit results to make informed decisions. It directs and supervises, but it does not carry out the audit work itself.

The **third line** is internal audit (and, in the external case, external auditors), which performs the actual assurance work. Internal audit is independent, objective, and risk-based. Its job is to evaluate governance, risk management, internal controls, and compliance processes, and then to report its findings to the board and to management. It may also **advise on improvements**, but it must never become responsible for the controls it audits — the moment it owns a control, it loses the independence that makes its assurance worth anything. External auditors likewise belong to this assurance line but provide an independent opinion that is usually focused on financial reporting and statutory assurance; they may coordinate with internal audit, but they are **not a substitute** for it. The underlying division of purpose is that external audit serves external stakeholders, whereas internal audit serves governance *inside* the organization.

1.5 Internal versus External Auditing

Although both internal and external auditors sit in the assurance line, they differ in independence, scope, cadence, and the standards they follow.

External auditing is conducted by independent auditors or assurance firms that sit outside the organization. Because the external auditor is structurally independent, its evaluation carries weight with outsiders — but that same independence means it must work strictly from the evidence the organization is able to provide. External audit follows international standards such as the **ISA** (International Standards on Auditing) and, for assurance engagements, **ISAE 3402** and **SSAE 18**. It is typically **periodic rather than continuous** — external auditors are called in when needed, for example for a certification — and it is subject to formal reporting obligations. Its focus is external accountability, regulatory compliance, and public trust, and in many cases the same external auditors also handle the financial side of the organization.

Internal auditing is performed by an independent function *within* the organization, reporting to the board or the audit committee. Because the internal auditor works inside the organization, it knows the context far more intimately. Its objective is to evaluate and improve governance, risk management, and internal-control effectiveness, drawing on frameworks such as **COSO Internal Control**, **COBIT**, and the **NIST Cybersecurity Framework**. It operates on a continuous, improvement-oriented basis and provides management with insights and recommendations to strengthen operations and reduce risk. Its focus is internal value creation, control maturity, and process improvement. Internal audit work is frequently organized around an internal audit model that, while not itself a certifiable standard, offers more implementation detail and technical depth to guide the audit team — yet even when the audit is internal, it must still preserve objectivity.

In practice the boundary between the two is not perfectly sharp: external auditors are not confined to certifiable standards and may also apply more specialized, technical criteria, while internal auditors may align their work with certifiable frameworks. The distinction is one of emphasis and independence, not a rigid wall.

1.6 Certification and Professional Competence

Certification is where the external, formal face of auditing becomes most visible — and often mandatory. When a product, system, or management system is certified, the external audit that supports it must be as precise and as unambiguous as possible, because a certificate is a statement the whole market will rely on. This is exactly why auditing is indispensable in a certification process: the auditor must always supply the evidence, the reasoning behind each conclusion, and an explicit account of what that evidence demonstrates in relation to the security criteria. External auditors supporting certification follow international standards precisely because the certificate must carry international recognition.

Professional **certifications** of the auditors themselves — such as **CISA**, **ISO 27001 Lead Auditor**, and the relevant **ISACA** frameworks — establish recognized competence benchmarks for auditing and cybersecurity assurance. These credentials validate not only technical knowledge but also the practical ability to plan audits, gather and evaluate evidence, report findings, and follow up on remediation. They also demonstrate familiarity with professional **ethics**, including independence, objectivity, due care, confidentiality, and accountability. By defining common expectations for skills and conduct, certifications standardize audit quality across organizations and industries, and because many of them require ongoing professional education, they push auditors to keep their skills current as threats, standards, and regulations evolve.

It is useful to distinguish the parties involved in an audit, because the same methodology can be exercised from different vantage points:

Party	What it is	Typical purpose
1st-party audit	Internal audit	The organization examines itself
2nd-party audit	External provider audit; audit by another external interested party	A customer, partner, or interested party audits a supplier
3rd-party audit	Certification and/or accreditation audit; statutory, regulatory, and similar audit	An independent body audits for certification or legal compliance

The progression from first to third party corresponds to increasing independence and increasing external weight: a first-party audit is the organization looking at itself, a second-party audit is an interested outsider (typically a customer or partner) looking in, and a third-party audit is a fully independent body whose verdict can confer certification or satisfy a legal requirement.

Part 2 — The Auditing Process

2.1 Audit Types: One Methodology, Many Focuses

Before examining the process itself, it is worth situating it among the various *types* of audit, because although the method is largely shared, the focus shifts depending on what the audit is meant to establish. The classical families are the **financial audit** (which validates the accuracy of financial statements), the **operational audit** (which evaluates the efficiency and effectiveness of processes), the **compliance audit** (which tests adherence to laws, regulations, or standards), the **performance audit** (which measures the achievement of objectives), and the **IT audit** (which examines the technological infrastructure and the control environment). There is no single canonical list — audits can also be categorized by domain, giving us financial auditing, healthcare auditing, and so on — but the unifying insight is that they all follow a **common methodology with a different focus**.

Within cybersecurity, one useful way to organize the field is by the *question* each approach is primarily trying to answer:

Audit approach	Main question	Typical focus
Compliance-based auditing	Are we complying with required standards and regulations?	ISO 27001, NIST, GDPR, NIS2, DORA
Controls-based auditing	Are security controls properly designed and implemented?	Access control, logging, incident response, encryption
Risk-based auditing	Are the most significant risks adequately addressed?	Risk exposure, likelihood, impact, prioritization
Process-based auditing	Are processes correctly defined and consistently executed?	Change management, vulnerability management, incident handling
Performance-based auditing	Are security measures achieving their intended outcomes?	KPIs, control effectiveness, incident rates, remediation time
Continuous auditing	Can deviations and control failures be detected continuously or near real time?	Automated checks, telemetry, configuration drift, alerts
Technical auditing	Do systems satisfy technical security requirements?	Configuration reviews, vulnerability scanning, penetration testing

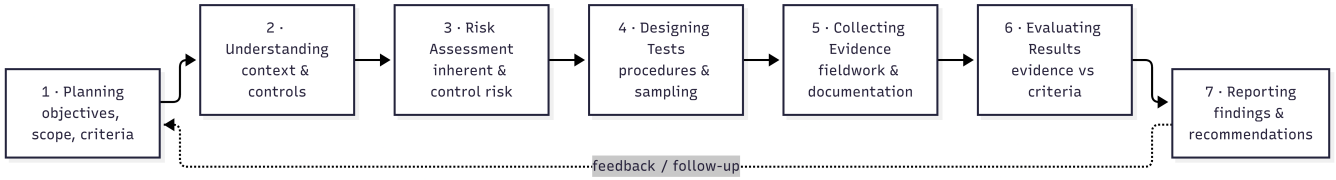
Audit approach	Main question	Typical focus
Forensic auditing	What happened, how, and who or what was responsible?	Incident reconstruction, digital evidence, attribution

The **risk-based** approach is highlighted deliberately, because it is the organizing philosophy of the process that follows. A process-based audit, for instance, is what you would run to judge whether an incident-management process actually works — whether the organization is handling incidents effectively — whereas a risk-based audit concentrates its effort on evaluating the risk-assessment process and the risks themselves, directing attention to wherever the exposure is greatest.

2.2 Auditing as a Documented Process (ISO 19011)

The formal reference for conducting audits is **ISO 19011** (*Guidelines for auditing management systems*). Its definition is worth stating precisely, because every subsequent step is derived from it: an audit is a *systematic, independent, and documented process for obtaining evidence and evaluating it objectively against established criteria.* Each keyword carries weight — *systematic* (it follows a defined method), *independent* (the auditor is not the owner of what is examined), *documented* (nothing is informal or unrecorded), *evidence* (the raw material of every conclusion), and *established criteria* (the benchmark without which evaluation is impossible).

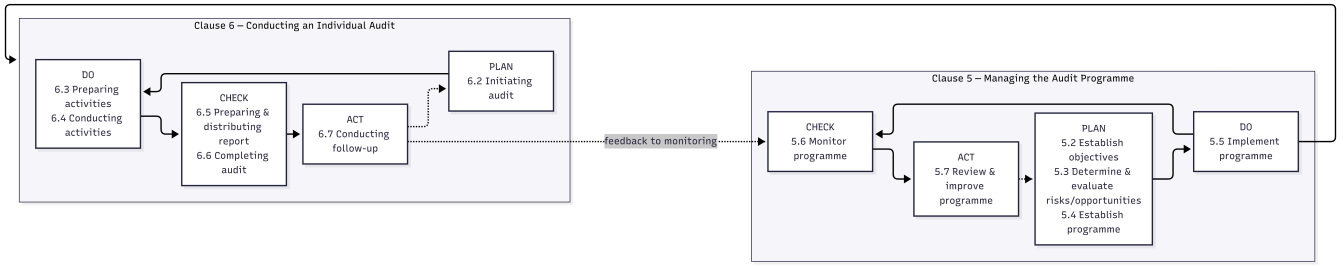
From this definition the process unfolds in **seven phases**:



Running throughout the rest of this chapter is a single worked case, **PHP2Shell**, which makes the abstract phases concrete. The situation: two critical, unauthenticated remote-code-execution flaws in the PHP interpreter itself (CVE-2026-109618 and CVE-2026-109619) are disclosed on 20 October 2026; fixes ship the next day as PHP 8.5.12, 8.4.27, 8.3.36 and 8.2.35, but they are not installed automatically, and branch 8.1 and older receive no release at all. After disclosure, the organization wants assurance that it can identify every exposed PHP system and remediate it within policy. The audit therefore centers on the PHP asset inventory, the vulnerability-alert intake, patch records, vendor-hosted systems, and detection logs.

2.3 The Deming (PDCA) Cycle in ISO 19011

The seven linear phases sit inside a larger cyclical structure. ISO 19011:2018 organizes auditing into two nested **Plan–Do–Check–Act** cycles — one for *managing an audit programme* (Clause 5) and one for *conducting an individual audit* (Clause 6) — and the two run one below the other, the lower feeding back into the upper.



In the **programme-level** cycle you first establish *what the audit programme's objectives are*, then determine the risks and opportunities tied to those objectives, establish the programme (how the auditing will be carried out) — all of which is the **Plan** — then implement it (**Do**), monitor it (**Check**), and review and improve it (**Act**), looping back to the objectives. The **audit-level** cycle, nested beneath, initiates the audit (**Plan**), prepares and conducts the activities (**Do**), prepares and distributes the report and completes the audit (**Check**), and conducts the follow-up (**Act**) — whose output flows back as feedback into the monitoring step above. These are, in effect, two views of the same discipline operating at two scales.

2.4 Phase 1 — Planning

Planning defines the **objectives, scope, and criteria** before any fieldwork begins. At this stage the auditor determines *what* will be examined, *why* it matters, and *against which standards* the audit will be judged, and good planning also surfaces the resources, timing, and evidence needs of the engagement. Responsibilities are assigned to objectives — which may include associating risks with their owners.

In the PHP2Shell case, the **objective** is to verify that the critical PHP vulnerabilities disclosed on 20 October are identified, prioritized, and fixed within the deadline set by the patch policy. The **scope** covers all internet-facing PHP applications, the patch-management platform, and vendor-hosted PHP systems, over the period from 20 October 2026 (public disclosure) to the audit date. The **criteria** are the internal vulnerability-management policy (for example, critical fixes within seven days), the asset-inventory procedure, and the vendor-contract SLAs — the latter precisely because some of the systems belong to the vendor, a fact that must be reflected when the risks are assessed.

2.5 Phase 2 — Understanding the System

Here the auditor gathers background **information** about the organization, its processes, and its environment, and identifies the key activities, responsibilities, and existing controls relevant to the audit scope. The purpose is to build **context** and avoid the cardinal mistake of testing controls without understanding how the system actually works. Crucially, "context" means not only the *internal* context of the organization but also the *external* context — the publicly available information (advisories, released patches, threat intelligence) that both the auditor and the organization must take into account.

For PHP2Shell, the auditor learns how alerts arrive (vendor advisories, CERT notices), who triages them, and who deploys the fix. A typical flow is: the security team receives the advisory, IT checks the inventory, system owners approve the change, and operations deploys the patch. The auditor also learns which patched branches exist — fixes were released for 8.5.12, 8.4.27, 8.3.36 and 8.2.35, while 8.1 and older receive no release, so some systems need an *upgrade*, not merely a patch. From this understanding, the relevant **control points** emerge: asset inventory, advisory triage, emergency-change approval, firewall rules, and web-shell detection. The first part of this knowledge is internal (the organization's own data and chain of responsibility); the second part is external (which patches actually exist in the world).

2.6 Phase 3 — Risk Assessment

The auditor now determines the **main risks** associated with the area under review, assessing **inherent risk** and **control risk** in order to *prioritize* what matters most. The output of this phase is a sharper focus on the areas where evidence and testing are most needed.

In the case, three risks crystallize. The **first** is that an unpatched PHP server can be compromised through a *single unauthenticated request* — and because the flaws are rated **CVSS 9.2** and affect the PHP interpreter itself rather than any one application, the exposure is not confined to a single app but

spreads across the whole estate. The **second** is that unknown or vendor-hosted PHP systems are missing from the inventory and therefore never patched. The **third** is that unsupported branches (8.1 and older) have no fix available at all. Weighing these, the auditor concludes this is a **critical-risk** area: inherent risk is high, and the potential impact includes data exposure, service disruption, and loss of server control.

2.7 Phase 4 — Designing Tests

Design translates the audit objectives into concrete **procedures** and **sampling** methods. The auditor defines how each control will be tested, what evidence will be collected, and how the sample will be selected; this is the phase that makes the plan **operational** and ensures every test is explicitly linked back to the criteria.

For PHP2Shell, the auditor decides to test three things: whether the inventory is **complete**, whether patches were applied within the **deadline**, and whether **detection** would have caught exploitation. Concretely, 20 of the 120 PHP hosts are selected *by risk* (internet-facing, running mod_php, on an unsupported branch, or vendor-managed), plus 5 **random** hosts added specifically to avoid sampling bias; the auditor also pulls 3 emergency-change tickets and the advisory-triage log. The procedures include re-performing a PHP **version check** on the sampled hosts and reviewing the firewall and web-shell detection rules.

2.8 Phase 5 — Collecting Evidence

Fieldwork is now **executed** to gather evidence that is *sufficient, appropriate, and relevant.* Evidence may come from documents, logs, interviews, observations, or testing results, and all work must be carefully **documented** so that the findings can be supported later. A point stressed heavily in practice: the auditor must also assure that the evidence itself is **not compromised** — for example by taking an integrity hash of the collected logs — because evidence that could have been tampered with cannot support a defensible conclusion.

In the case, the auditor collects the patch-management export listing installed PHP versions, the emergency-change tickets, the triage log, and the vendors' written **exposure statements** (which, for vendor-hosted machines outside the asset inventory, are often the *only* evidence available). The auditor also runs or witnesses a version check on the sampled hosts and requests file-integrity alerts for new web shells. The fieldwork surfaces concrete items — for instance, one host still shows PHP 8.4.26 installed after the fixed 8.4.27 release, and another host appears in no inventory export at all. These are the raw findings-in-waiting.

2.9 Phase 6 — Evaluating Results

Evaluation **compares** the collected evidence with the audit criteria and identifies the **gaps** between what should happen and what is actually happening. This is where findings begin to take shape, as the auditor interprets whether the evidence supports compliance, demonstrates effectiveness, or reveals a control weakness. In essence it is a data-analysis step: measuring what was actually done against what was expected.

Comparing evidence to criteria, the auditor finds that most sampled hosts were patched within seven days, but **3 of 25 were not**, including one internet-facing server; additionally, two vendor-hosted systems have **no exposure statement**, and one application runs PHP 8.1 with no available fix. The reasoned conclusion is nuanced: the remediation **process exists** — most tested hosts were in fact patched — but it is **not consistently operating**, especially for assets that sit outside the central

inventory. The three unpatched hosts and the missing exposure statements are precisely the evidence of that inconsistency.

2.10 Phase 7 — Reporting

Finally, the auditor **summarizes** the findings, conclusions, and recommendations in a clear report that explains what was examined, what was found, why it matters, and what should improve. A strong report turns audit work into action by helping management understand the priorities for remediation. The standard chain used to write each finding is:

> **Criterion → Condition → Cause → Effect → Recommendation**

That is: state the criterion that applied, describe the condition actually observed, explain the cause, articulate the effect (the risk or impact), and give a recommendation. For PHP2Shell, typical recommendations are to complete the PHP inventory (so the previously invisible machines are included), upgrade or isolate the unsupported branches (since some systems cannot be patched because of their older PHP version), obtain vendor attestations, and add automated version scanning. Critically — and this is a recurring principle — **every finding and recommendation must be assigned an owner and a deadline** (for example, 30 days for the unsupported system) in order to be effective, so that remediation can be tracked and validated later. The judgment involved here is ultimately a human one, which is exactly why it must be supported throughout by concrete evidence.

Part 3 — Audit Methods and Audit Principles

3.1 Audit Methods

Once the process is understood, the auditor needs a repertoire of **methods** — concrete ways of gathering and corroborating the evidence on which every conclusion rests. A standard set of methods, ordered roughly from the simplest to the most involved, runs as follows.

The **review of records** is the most straightforward: the auditor collects records and examines what is written in them. **Feedback** gathers perceptions from people inside the organization — providing some input and obtaining output through structured conversation. The **interview** has the auditor prepare a set of questions (often based on the applicable criteria), put them to the organization, and collect the answers; some interviews are effectively interviews *with the records themselves*, such as logs. **Observation** has the auditor watch what is actually happening in the organization — and here the scope must be very tightly defined, so the auditor is clear about *what* is to be observed and records precisely what was done during the observation. **Testing** is formal and hands-on, penetration testing being the canonical example. Finally, the **post-audit review** closes the loop and is used, for instance, where an organization must demonstrate that it is *continuously* compliant over time.

These methods vary along two axes, captured in the ISO 19011 activity matrix: **location** (on-site versus remote) and **extent of human involvement** (with human interaction, i.e. *interactive*, versus no human interaction, i.e. *non-interactive*). On-site activities are performed at the auditee's location; remote activities are performed anywhere else, regardless of distance. Interactive activities involve the auditee's personnel (interviews, jointly completed checklists, witnessed document review, sampling); non-interactive activities involve no people but do involve interaction with equipment, facilities, and documentation (record review, data analysis, observation via surveillance).

	On-site	Remote
Human interaction	Interviews; checklists/questionnaires with auditee; document review with auditee; sampling	Interviews, observation, checklists and document review via interactive communication means
No human interaction	Document/records review, data analysis; observing work performed; on-site visit; checklists; product sampling	Document review and data analysis; observing work via surveillance means; analysing data

A practically important nuance: on-site, interactive methods tend to yield more **direct and less biased** evidence and can be faster and more immediate than purely documentary approaches. But human-mediated methods carry a translation burden. The people being interviewed are typically *not* auditors and may "speak a different language" — so the auditor's task is to transform what the human reports into the precise language of the audit. Non-interactive and computer-assisted methods, by contrast, come into play for remote work, large-scale data analysis, and automated inspection of specific technical points.

3.2 The Six Audit Principles

The process and its methods are necessary but not sufficient. An audit is only valid if a set of **principles** is satisfied throughout — and the crucial point is that these are not optional niceties. If, by the end of your report, any of these principles has been violated, the evaluation itself cannot stand: a conclusion reached in breach of the principles is void, no matter how much work went into it. There are six:

1. **Integrity and ethical conduct → Assurance**
2. **Independence and objectivity**
3. **Due professional care and competence**
4. **Evidence-based approach**
5. **Confidentiality and discretion**
6. **Professional skepticism and judgment**

3.3 Principle 1 — Assurance

Assurance is the first and arguably the most important principle, because it is the very purpose of auditing: an **independent and objective** evaluation that provides confidence to stakeholders about the reliability, integrity, and effectiveness of an organization's processes, controls, or information. A subtle but essential idea is that assurance is **both an engagement and its outcome** — it is the activity the auditor performs *and* the confidence that results from it, grounded in evidence-based conclusions.

Its defining features are that it is **independent** (performed by parties not involved in the operations being examined — internal audit, external audit, certification bodies), **objective** (evidence-based and free from bias or influence, with the evaluation quantified by metrics wherever possible), **evidence-driven** (conclusions rely on verifiable data and documented testing), and directed at a single **purpose** — to enhance trust in management's assertions and governance processes. A critical timing point is that assurance must be realized *during* the process, not bolted on afterwards: it is something the auditor must be evaluating continuously as the audit proceeds, so that the final report leaves no question unanswered.

Risk Management versus Assurance

It helps to contrast assurance with risk management, because the two are complementary but distinct: **risk management creates confidence, while assurance validates that confidence**. The

responsibility even shifts between them — management owns and runs risk management, whereas the auditors own assurance.

	Risk Management	Assurance (Internal Audit)
Objective	Identify, assess, and mitigate threats to achieving objectives	Provide independent evaluation of how risks and controls are managed
Responsibility	Management and operational staff	Internal audit and other assurance providers
Nature of work	Proactive and continuous	Reactive and periodic (independent review)
Focus	Managing risk exposure and implementing controls	Testing, verifying, and reporting on control effectiveness
Output	Risk registers, mitigation plans, risk-appetite statements	Audit reports, assurance opinions, recommendations
Key question	"Are we managing our risks effectively?"	"Is our risk management effective?"

Levels of Assurance

Assurance is not all-or-nothing; it comes in graded levels. **Reasonable assurance** is high but not absolute confidence, based on sampling and sufficient testing — it is not absolute precisely because the auditor does not test the entire population, only a sample. **Limited assurance** is moderate confidence, typical of review engagements (for example interviews, where the auditor cannot be fully certain of what respondents report). **No assurance** corresponds to purely descriptive or advisory observations, offering a general view rather than a tested conclusion.

The decisive conceptual point is that **assurance does not mean a positive result**. It represents confidence based on evidence, whether the findings turn out good or bad. When an audit reveals weaknesses or non-compliance, it still provides assurance — it assures stakeholders about the *true state* of the controls, including the assurance that the controls do **not** meet the expected standards. The value of assurance lies in **transparency and reliability**, not in favorable outcomes; a negative finding and a low-quality process are two entirely different things, and a credible negative finding is itself a valuable product.

Ethics and Quality in Assurance

Because assurance rests on integrity, auditors must uphold ethical codes emphasizing **confidentiality, objectivity, and competence**. Ethical lapses undermine trust, damage professional credibility, and can outright invalidate assurance engagements. Quality is safeguarded through **quality-assurance mechanisms** — internal reviews, peer evaluations, and external assessments — that ensure conformity with professional standards, while continuous improvement reinforces the reliability and relevance of the audit function over time.

3.4 Principle 2 — Independence and Objectivity

Auditors must remain independent **in fact and in appearance**, avoiding conflicts of interest that could bias judgment. **Objectivity** means making balanced assessments based on facts, not on loyalty, assumptions, or personal preferences, and this principle protects the credibility of the audit by preventing auditors from auditing work they themselves are responsible for managing.

A clarification worth stressing: independence does *not* necessarily mean the auditor must be external to the organization. An internal auditor can still be independent, provided they are not evaluating their own work. The classic illustration is penetration testing — the person who performed the penetration test cannot also be the one who audits the penetration-testing policy, because that would be judging one's own work; a *different* person within the organization must test that independence.

3.5 Principle 3 — Due Professional Care and Competence

Due professional care begins with a **questioning attitude**, which is essential to identify inconsistencies and potential misstatements. Auditors critically evaluate evidence, seek corroboration from multiple sources, and avoid relying solely on management assertions. They are expected to work with diligence, sound judgment, and appropriate technical competence — planning carefully, applying the right methods, and staying alert to errors, omissions, or fraud indicators. Competence also implies **keeping skills up to date**, since audit quality depends directly on the auditor's ability to understand evolving systems, risks, and control environments. This is also where the auditor's authority to *demand explanations* comes from: a methodical auditor is entitled to ask "why" and cannot be left without an answer, because every relevant detail must be accounted for.

3.6 Principle 4 — Confidentiality and Discretion

Auditors routinely handle **sensitive** operational, financial, and security information, so they must protect it carefully. Confidentiality means **not disclosing information** without proper authorization, unless there is a legal or professional duty to do so. **Discretion** also sustains the trust between auditors and stakeholders that is essential for effective evidence collection and open communication. In practice this is formalized through confidentiality agreements between the auditor and the organization — a point especially relevant for external auditors, who are bound by such agreements with respect to internal information.

3.7 Principle 5 — Professional Skepticism and Judgment

Professional **skepticism** means keeping a questioning mind and critically assessing audit evidence, especially when something looks incomplete, inconsistent, or *too convenient*. Professional **judgment** is the complementary ability to interpret evidence, weigh alternatives, and decide what is material and what is not. Together they help auditors avoid accepting explanations too quickly and thereby improve the quality of audit conclusions.

3.8 Principle 6 — Evidence-Based Approach

Audit evidence must be **sufficient** (in quantity) and **appropriate** (in quality) to support conclusions, because reliable evidence is what strengthens the credibility of the auditor's opinion. Conclusions must rest on sufficient, relevant, and reliable evidence rather than on intuition or managerial claims. Concretely, this requires the auditor to collect evidence through **documentation and records** (policies, logs, reports, configuration files), **observation of processes** (direct review of control execution in real time), **interviews and inquiries** (discussions with process owners to corroborate evidence), **analytical procedures** (data comparisons, trend analysis, correlation testing), and **re-performance of controls** (independently repeating activities to confirm effectiveness). In short, credible, verifiable, and traceable evidence underpins every audit conclusion.

The flow from raw information to a defensible conclusion can be drawn as a pipeline:



Each stage constrains the next: evidence is only as good as the sampling that produced it, findings are only as good as the criteria they are measured against, and conclusions are only trustworthy once the findings have been reviewed.

3.9 Challenges in Modern Auditing

Modern auditing faces new complexities: **massive** data volumes and automation, **evolving** cybersecurity threats and cloud environments, and the integration of **AI** and analytics into control testing. The discipline adapts to these pressures through continuous auditing, data-driven testing, and risk intelligence. The unifying idea is that auditing in cybersecurity **translates traditional assurance principles to digital evidence** — the century-old logic of evidence, independence, and assurance is preserved, but its raw material is now logs, configurations, and telemetry rather than ledgers.

Part 4 — Consolidation: The PHP2Shell Case Reviewed

Having walked through the audit process, its methods, and its principles, it is worth drawing the whole discipline together on a single worked scenario. The PHP2Shell situation — two critical PHP flaws (CVSS 9.2), fixes released on 21 October 2026, an organization with 120 PHP hosts, and a policy requiring critical fixes within 7 days — serves as a compact diagnostic exercise. Each of the following questions targets one phase or principle of auditing, and the reasoning behind each answer is the real lesson.

4.1 Planning — Choosing the Right Scope

Question. Which scope best supports the objective "critical PHP vulnerabilities are fixed within policy"? *(a) firewall rules only; (b) inventory, advisory triage, patching, vendor-hosted systems, and detection; (c) the text of the security policy only.*

Answer: (b). The objective is about whether vulnerabilities are actually being *found and fixed within the deadline*, and only a scope that spans the full lifecycle can evidence that. Restricting the audit to **firewall rules** (a) would not tell you the vulnerabilities are being remediated at all — it would miss hosts absent from the inventory and ignore the vulnerability-management process itself. Restricting it to the **policy text** (c) is worse: a document on its own proves nothing about reality, leaving the entire conclusion dependent on subjective human evaluation, which we have repeatedly identified as the weakest possible footing. Only option (b) — inventory, advisory triage, patching, vendor-hosted systems, and detection — covers the chain of activities through which the objective is genuinely achieved or missed.

4.2 Understanding — Why the Patched Branches Matter

Question. Fixes exist for 8.5, 8.4, 8.3 and 8.2, but not for 8.1 and older. Why must the auditor know this *before* testing?

Answer. Because it is itself a **risk** that must be assessed: some hosts simply *cannot* be patched, since no fix exists for their branch. Knowing which branches are supported lets the auditor distinguish genuine non-compliance from acceptable, mitigated risk — an organization running an unsupported branch can still be compliant *provided it has put a compensating control in place* (for example, isolating the host) precisely because updating is impossible. This knowledge also drives the **choice of mitigation**: for supported branches the remedy is simply to upgrade to the fixed version, whereas for unsupported ones

the only options are to upgrade the platform wholesale or to isolate the system. Without this external context, the auditor could not interpret the evidence correctly.

4.3 Designing Tests — How to Choose the Sample

Question. You can examine 25 of the 120 hosts. How do you choose them?

Answer. Select **by risk and exposure**. Internet-facing (exposed) hosts are more critical than internal, non-exposed ones, so the bulk of the sample — roughly 20 hosts — should be the most critical: those that are exposed, run PHP, sit on an unsupported branch, or are vendor-managed. You know which hosts fall into these categories from the **inventory and the risk assessment**, which is exactly why a complete inventory is a prerequisite. The remaining **5 hosts are chosen at random**, and the rationale for randomness is important: it prevents the auditor from systematically skipping part of the infrastructure, and it can surface weaknesses that a purely risk-targeted sample would never reach — side effects such as a corrupted PHP file that is not actively serving requests but lingers in the background. The random slice is an approximation that guards against sampling bias.

A related subtlety raised by this phase concerns the **timing of evidence**. Evidence has a shelf life: a scan performed on 19 October (before disclosure) says little about exposure on 20 October (after the two critical flaws became public). If the only available monitoring ran the day before disclosure and cannot be re-run immediately — for budget or operational reasons — that gap is a real limitation the auditor must acknowledge rather than paper over.

4.4 Evaluating — Effective, Partially Effective, or Not?

Question. Of the 25 sampled hosts, 3 were not patched, and one of those is an internet-facing server. Is the control effective, partially effective, or not effective?

Answer: partially effective. It cannot be rated *fully effective*, because three hosts — most seriously the internet-facing one — remain unpatched. But it is not *ineffective* either, because the process demonstrably exists and most sampled hosts were in fact patched within the deadline. The correct, evidence-based conclusion is therefore that the remediation process **exists but is not fully covered**: by execution it is *partially* operating, and the partiality is quantified concretely (3 of 25). This is the hallmark of a good evaluation — a graded, measured verdict rather than a binary pass/fail.

4.5 Skepticism — Does Conflicting Threat Intelligence Change the Risk?

Question. Sources disagree on whether PHP2Shell is being exploited in the wild: a honeypot recorded working shells, while another vendor observed none as of 28 October. Does this change your risk rating?

Answer: no. Professional skepticism requires weighing the conflicting reports, but the key principle is that **missing or inconclusive evidence of exploitation does not lower a risk that has already been assessed as critical**. The inherent risk — unauthenticated remote code execution in the interpreter itself, CVSS 9.2 — exists regardless of whether exploitation has yet been observed. Absence of evidence is not evidence of absence, and the auditor must not relax a well-founded risk rating simply because one source has not (yet) seen an attack. The news is considered, but the risk rating stands.

4.6 Independence — Who May Report, and Who Must Re-Perform?

Question. The team that patches the systems also produces the compliance report. What is the problem, and which line of defense should re-perform the check?

Answer. The problem is **bias**, and therefore a breach of independence. A team that performed the patching has a vested interest in concluding that the patching was done correctly; its self-assessment is not objective, which makes it effectively worthless as assurance. By the principle that no one may audit their own work, the check must be **re-performed by an independent line** — the **third line (internal audit)**, not the first line that did the patching. This mirrors the penetration-testing rule: whoever ran the test (or found the vulnerability) cannot be the one who audits it. Assurance only has value when the party giving it is structurally separate from the party being examined.